Matriz de pruebas y evidencias

PharmaSoft · Seguridad de la SPA · Sesión 11

26 casos manuales · 25 de octubre de 2026

Matriz · L-01 a L-05

ID	Grupo	Usuario	Pasos	Resultado esperado	Resultado obtenido	Estado	Evidencia
L-01	Login	Sin sesión	Enviar vacío; enviar solo username	Validaciones locales; cero peticiones de login	Dos validaciones obligatorias y Network sin solicitudes al enviar vacío.	Pasa	E010
L-02	Login	Inexistente, admin e inactivo	Enviar credenciales inválidas y cuenta inactiva	Mismo 401 y mensaje; password vacío y username conservado en los tres intentos	Los tres intentos responden 401 con el mismo mensaje; usuario conservado y contraseña borrada.	Pasa	E001-E009
L-03	Login	vendedor	Doble clic rápido en Ingresar con credenciales válidas	Una sola petición POST auth/login; botón deshabilitado mientras responde	Una petición login; Ingresando... deshabilitado; respuesta 200 y acceso a Inicio.	Pasa	E011-E013
L-04	Login	vendedor	Abrir /login?returnUrl=https://sitio-falso.com e iniciar sesión	Destino /inicio; nunca un dominio externo	El destino externo se descarta y el login termina en /inicio.	Pasa	E014-E015
L-05	Login (propio)	vendedor con espacios finales	Iniciar sesión con espacios al final del username	Acceso válido; respuesta con username canónico vendedor	Acepta vendedor con espacios finales y devuelve username canónico vendedor.	Pasa	E016-E017

Matriz · S-01 a S-05

ID	Grupo	Usuario	Pasos	Resultado esperado	Resultado obtenido	Estado	Evidencia
S-01	Sesión	vendedor	Login; F5; cerrar la ventana de prueba y abrir una nueva sin restaurar pestañas	F5 conserva sesión; ventana nueva pide login	F5 mantiene la identidad y consultas 200; la nueva ventana muestra login.	Pasa	E018-E020
S-02	Sesión	vendedor	Cambiar expiraEn a un instante pasado y F5	Sesión guardada descartada; login	expiraEn: 1 se descarta al recargar; login y almacenamiento limpio.	Pasa	E021-E022
S-03	Sesión	vendedor	Reemplazar pharmasoft.sesion por texto no JSON y F5	Login sin excepción que rompa la SPA	Texto no JSON descartado; login operativo y entrada eliminada.	Pasa	E023-E024
S-04	Sesión	vendedor en dos pestañas	Abrir sesión en ambas; logout en A; navegar en B	A queda sin sesión; B conserva su propia sesión; registrar y explicar independencia por pestaña	Logout en A; B continúa navegando con su sesión independiente.	Pasa	E025-E026
S-05	Sesión (propio)	vendedor	Guardar JSON válido con expiraEn de tipo string y F5	Descarta estructura inválida; login sin fallo de la SPA	expiraEn de tipo string se descarta; login sin romper la SPA.	Pasa	E027-E028

Matriz · I-01 a G-03

ID	Grupo	Usuario	Pasos	Resultado esperado	Resultado obtenido	Estado	Evidencia
I-01	Interceptor	vendedor	Inspeccionar GET productos, POST login y petición Angular a un dominio externo	Bearer solo en API protegida; sin Authorization en login ni dominio externo	Bearer en la API protegida; ausente en login y en HttpClient a httpbin.org.	Pasa	E029-E032
I-02	Interceptor	vendedor	Detener backend; abrir Productos; reiniciar backend	Error de conexión, no logout; al reintentar carga el catálogo	Error de conexión sin logout; al reiniciar y reintentar se recuperan Productos y Categorías.	Pasa	E033-E038
I-03	Interceptor	vendedor	Alterar firma del JWT en storage; F5 en /ventas	GET ventas 401; login con Su sesión expiró y returnUrl=/ventas	Ventas devuelve 401 por token inválido; login con aviso y returnUrl=/ventas.	Pasa	E039-E042
G-01	Guards	Sin sesión	Abrir /productos/1/editar, /ventas/nueva e /inicio	Login con returnUrl correcto en cada ruta	Las tres rutas anónimas terminan en login con sus respectivos returnUrl.	Pasa	E043-E046
G-02	Guards	vendedor y almacen	Vendedor abre /categorias/nuevo y /productos/1/editar; almacén /ventas/nueva	Acceso denegado en los tres; sesión conservada	Las tres rutas de escritura muestran Acceso denegado y conservan la identidad.	Pasa	E047-E052
G-03	Guards (propio)	Sin sesión y almacen	Abrir /mi-cuenta sin sesión y luego con ALMACENERO	Sin sesión: login con returnUrl; autenticado: perfil 200 sin permiso de módulo adicional	Anónimo vuelve a login; almacén consulta /mi-cuenta y auth/me responde 200.	Pasa	E069-E070

Matriz · M-01 a E-01

ID	Grupo	Usuario	Pasos	Resultado esperado	Resultado obtenido	Estado	Evidencia
M-01	Menú y acciones	admin, vendedor, almacen, supervisor	Comparar menú, encabezado y controles del catálogo	ADMIN completo; vendedor lectura/ventas/clientes; almacén catálogo editable; supervisor unión sin reportes	Menú y acciones coinciden con ADMIN, VENDEDOR, ALMACENERO y la unión del supervisor.	Pasa	E053-E056
M-02	Menú y acciones	admin -> almacen	Cerrar sesión y entrar como almacén en la misma pestaña, sin F5	Menú y controles cambian reactivamente	De ADMIN a ALMACENERO cambia la identidad y desaparecen los módulos no concedidos.	Pasa	E057-E058
M-03	Menú y acciones (propio)	vendedor y admin	Modificar roles desde Swagger; actualizar Mi cuenta con sesión anterior; restaurar roles	Perfil refleja servidor y muestra Sus permisos cambiaron; sesión y token no se sobrescriben	Cambio [2,3] provoca aviso; encabezado conserva VENDEDOR; restaurar [2] y actualizar retira el aviso.	Pasa	E076-E083
E-01	401 / 403	vendedor	Invocar darDeBaja desde Angular en desarrollo, aunque el control esté oculto	DELETE 403; mensaje del backend en la SPA; sesión continúa y producto no se modifica	Dar de baja desde Angular devuelve 403; alerta visible, sesión conservada y producto 21 activo.	Pasa	E059-E061

Matriz · B-01 a C-02

ID	Grupo	Usuario	Pasos	Resultado esperado	Resultado obtenido	Estado	Evidencia
B-01	Aviso de sesión	vendedor; JWT de 3 minutos	Login nuevo y esperar a que queden 120 segundos	Aviso fijo sobre contenido con role=status y 02:00; aparece aproximadamente al minuto de iniciar	Login de 180 s; aviso visible con 01:56 restantes sobre Productos.	Pasa	E062-E063
B-02	Aviso de sesión	Misma sesión	Observar contador en dos instantes	mm:ss decrece cada segundo sin renovar JWT ni modificar expiraEn	La misma sesión pasa de 01:56 a 01:09 sin un nuevo login en la secuencia.	Pasa	E063-E064
B-03	Aviso de sesión	Misma sesión	Pulsar ×; navegar y F5 antes de vencer	Aviso oculto en esa sesión, contador sigue; nuevo login permite mostrarlo otra vez	× oculta el aviso y la pantalla Productos continúa disponible.	Pasa	E064-E065
B-04	Aviso de sesión	JWT de 3 minutos	Esperar cero; volver a entrar; en nueva sesión usar Cerrar sesión ahora	Cero: login con aviso y returnUrl; cierre manual inmediato limpia sesión y temporizadores	Vencimiento: login con aviso y storage vacío; nueva sesión: cierre manual inmediato sin aviso de expiración.	Pasa	E066-E068
C-01	Mi cuenta	Cuatro usuarios activos	Abrir Mi cuenta e inspeccionar GET auth/me y los cinco módulos	200; nombre, username, roles y ocho permisos marcados según respuesta del servidor	Perfiles por rol, nombres y permisos en cinco módulos; auth/me 200. Duración restaurada a 3600 s.	Pasa	E070-E073
C-02	Mi cuenta	supervisor	Bloquear solo auth/me; Actualizar perfil; desbloquear y Reintentar	Estados de carga/error visibles; conserva sesión ante fallo de conexión y recupera perfil	Bloqueo auth/me muestra error sin logout; al desbloquear se recupera perfil con 200.	Pasa	E074-E075

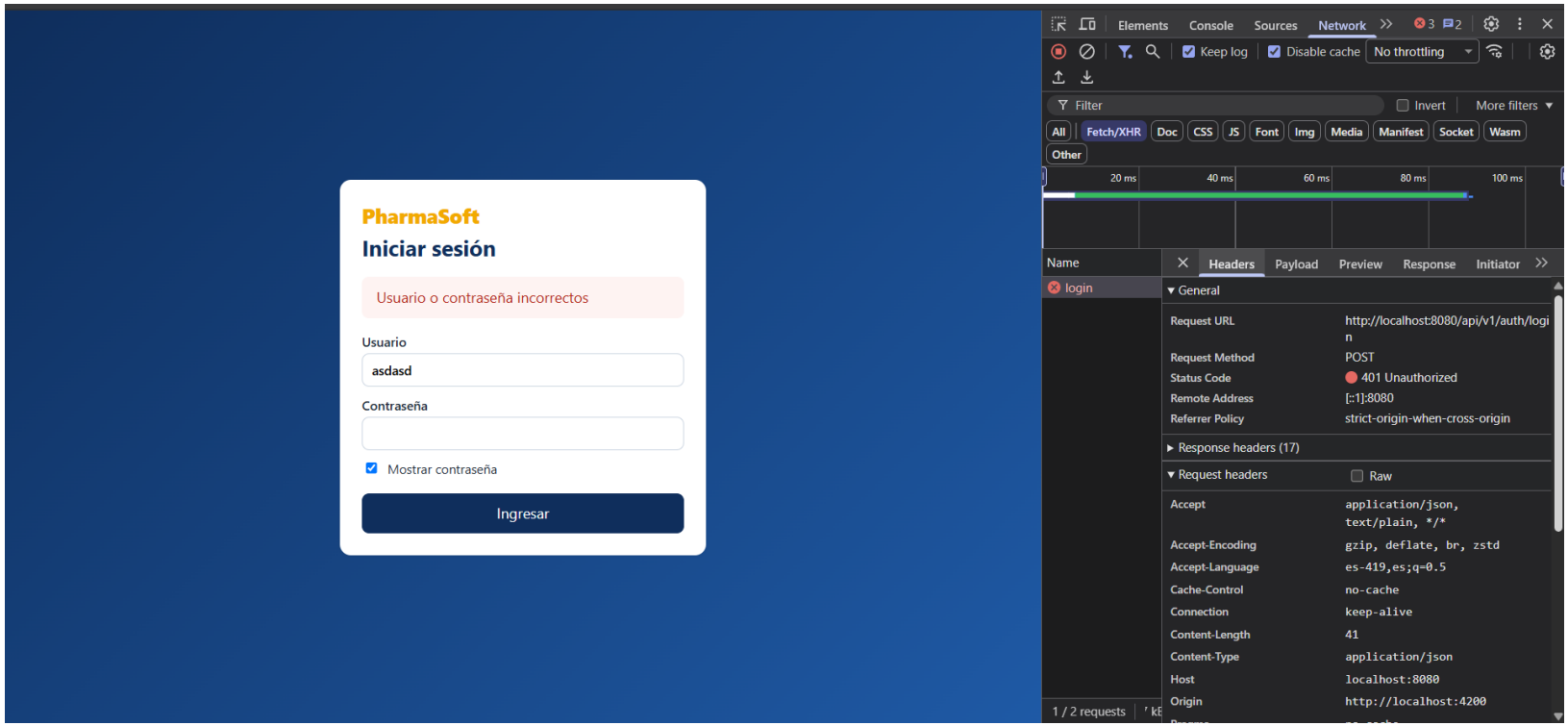
Evidencias

- Login y redirección segura
- Sesión y almacenamiento
- Interceptores y conexión
- Rutas protegidas
- Menú, roles y cambios de permisos
- Autorización HTTP y conservación de sesión
- Aviso previo y cierre de sesión
- Perfil y permisos por módulo

Login y redirección segura

E001 · L-02 · Rechazo de usuario inexistente

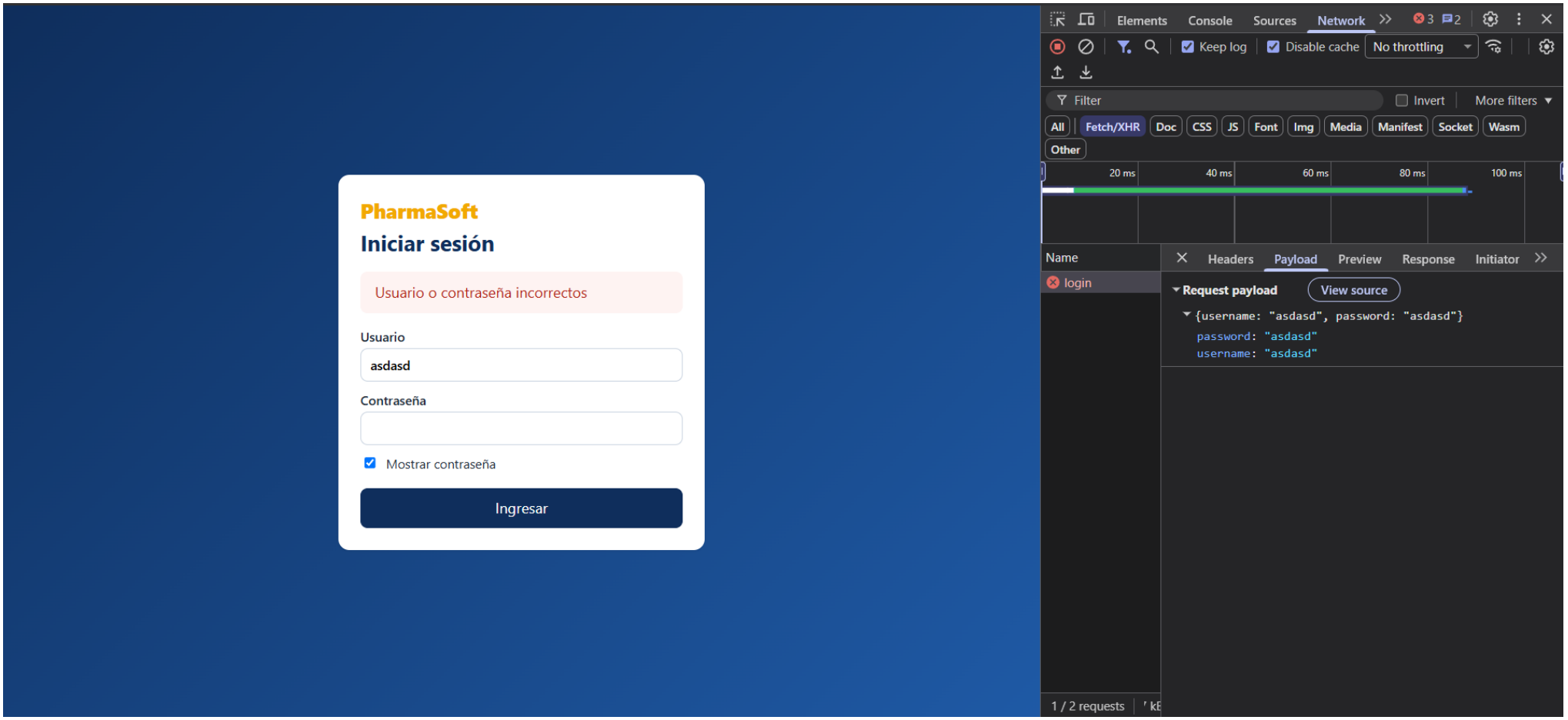
POST auth/login responde 401; se conserva el usuario y se elimina la contraseña del formulario.



Login y redirección segura

E002 · L-02 · Credenciales de usuario inexistente

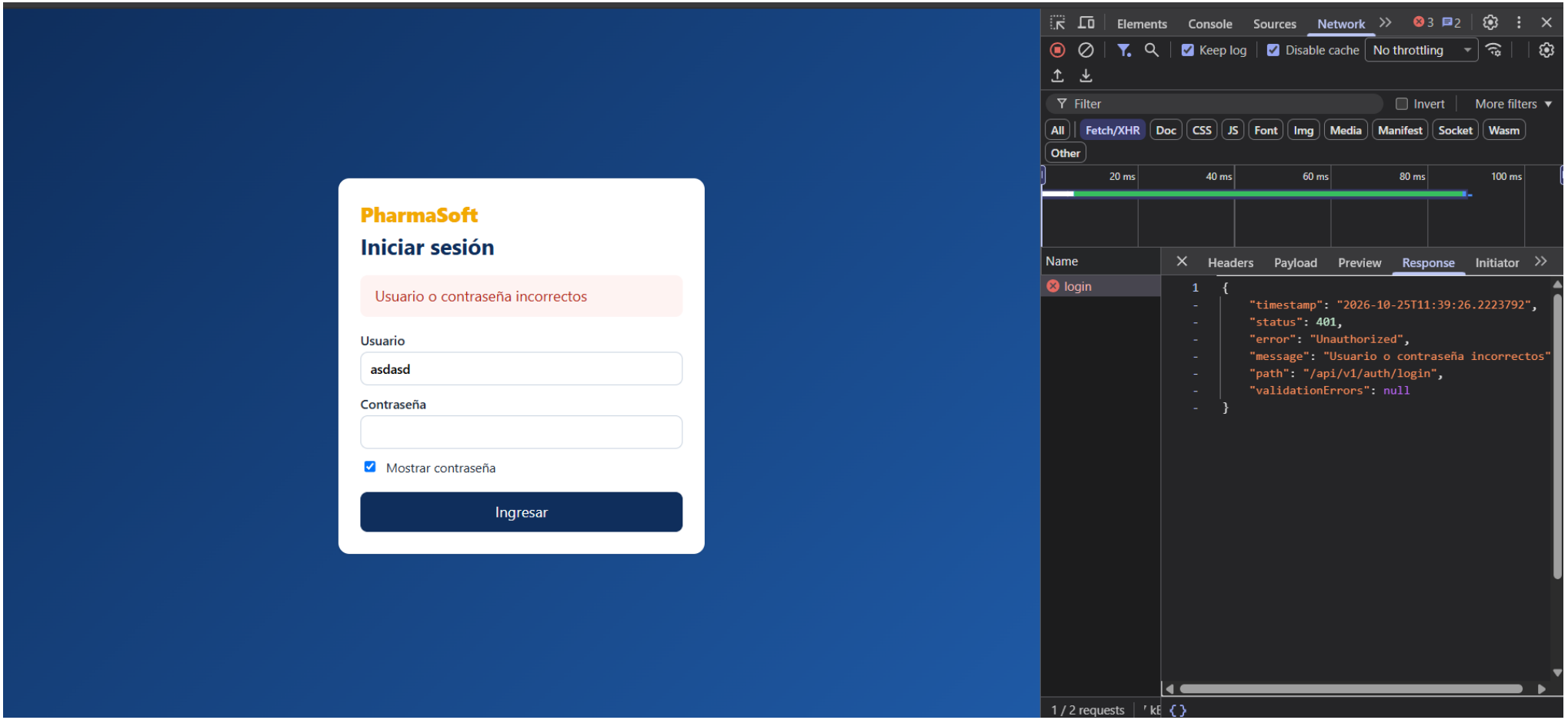
La petición permite identificar el intento de autenticación que se contrasta con el rechazo.



Login y redirección segura

E003 · L-02 · Mensaje para usuario inexistente

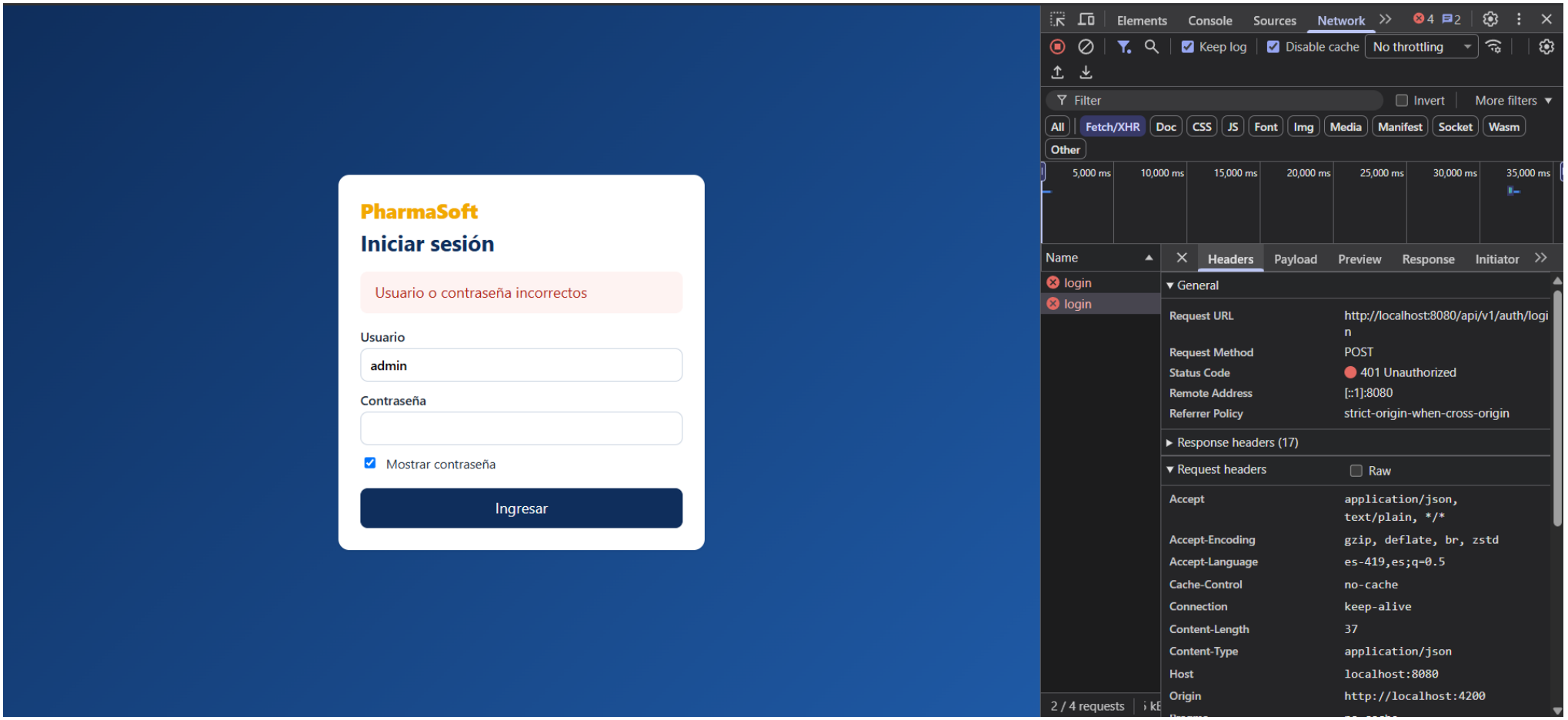
La respuesta mantiene el mismo mensaje genérico: Usuario o contraseña incorrectos.



Login y redirección segura

E004 · L-02 · Rechazo de contraseña incorrecta de admin

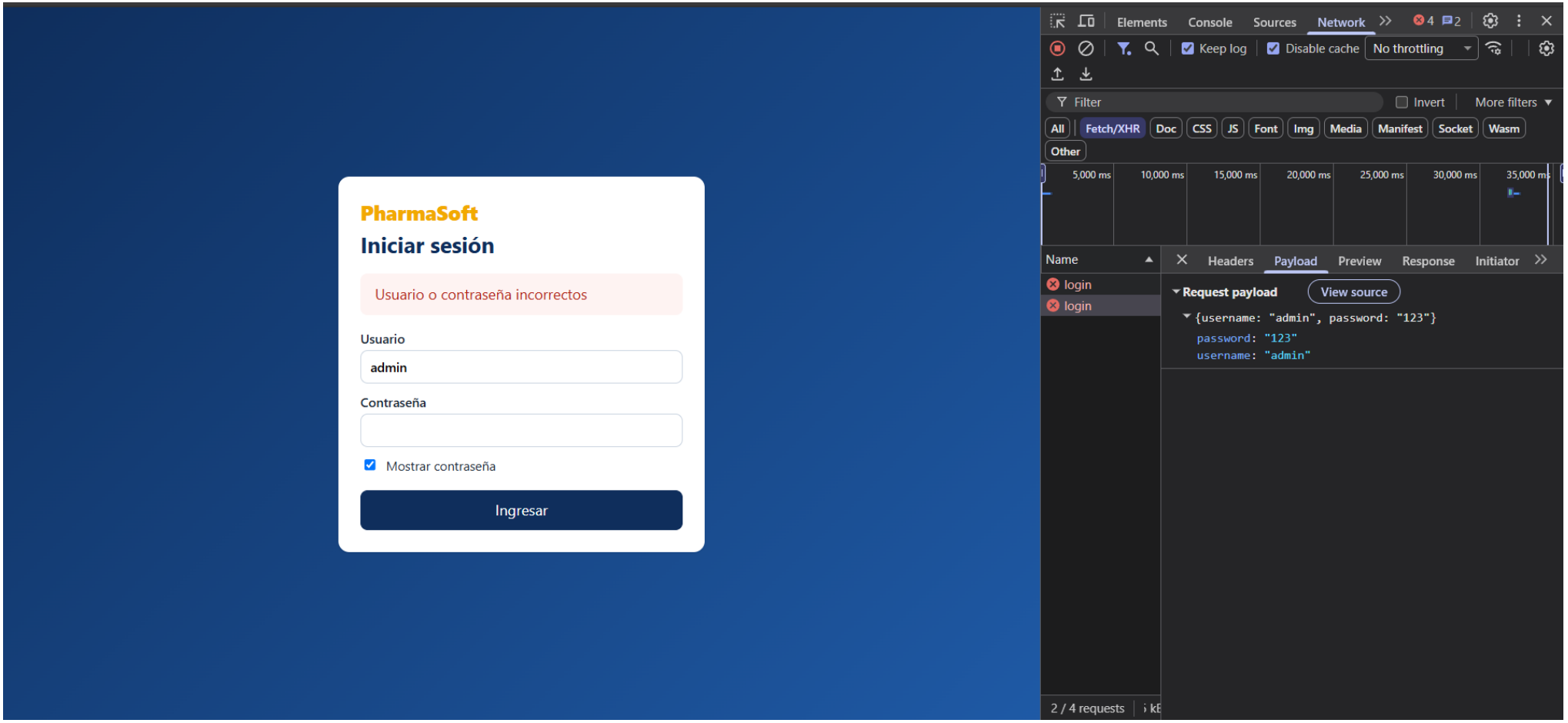
POST auth/login responde 401; se conserva el usuario y se elimina la contraseña del formulario.



Login y redirección segura

E005 · L-02 · Credenciales de contraseña incorrecta de admin

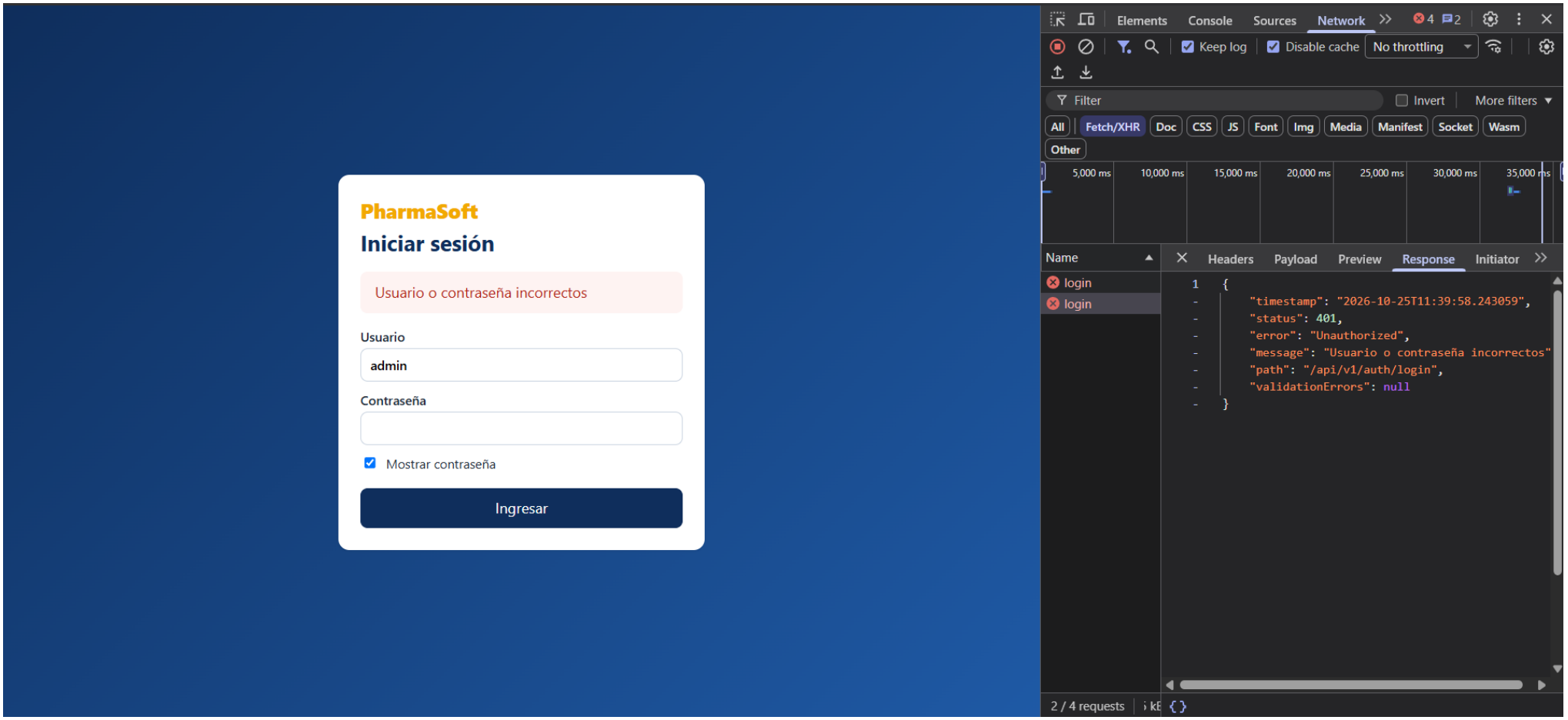
La petición permite identificar el intento de autenticación que se contrasta con el rechazo.



Login y redirección segura

E006 · L-02 · Mensaje para contraseña incorrecta de admin

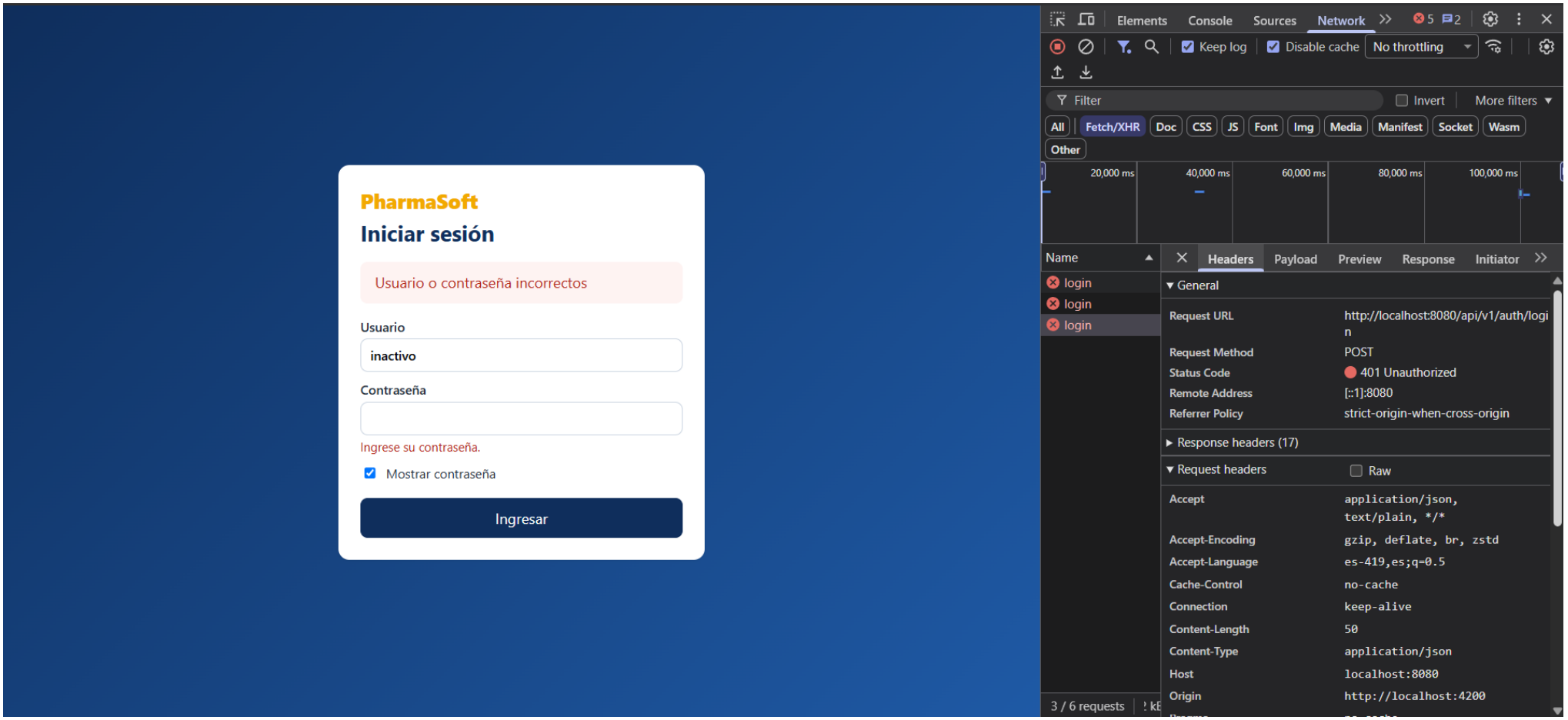
La respuesta mantiene el mismo mensaje genérico: Usuario o contraseña incorrectos.



Login y redirección segura

E007 · L-02 · Rechazo de cuenta inactiva

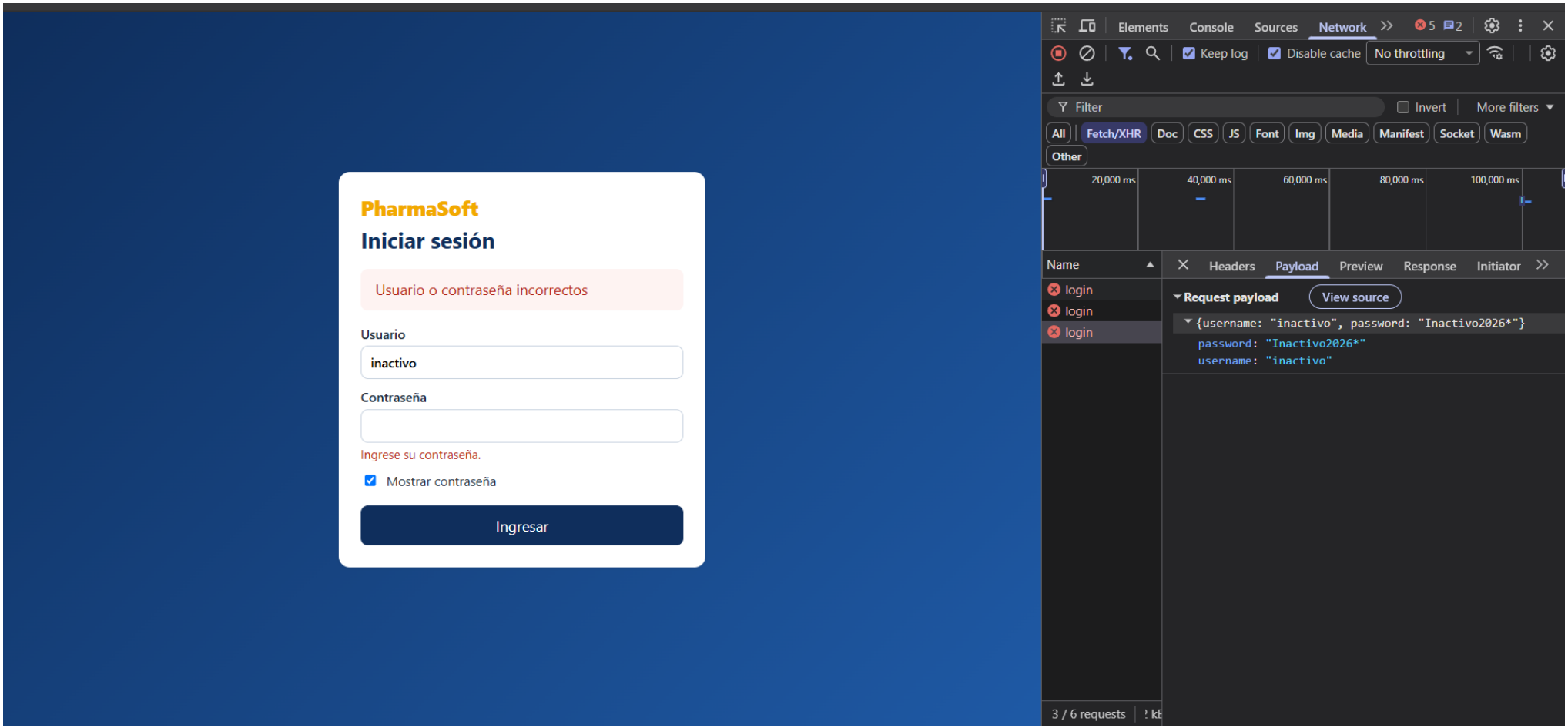
POST auth/login responde 401; se conserva el usuario y se elimina la contraseña del formulario.



Login y redirección segura

E008 · L-02 · Credenciales de cuenta inactiva

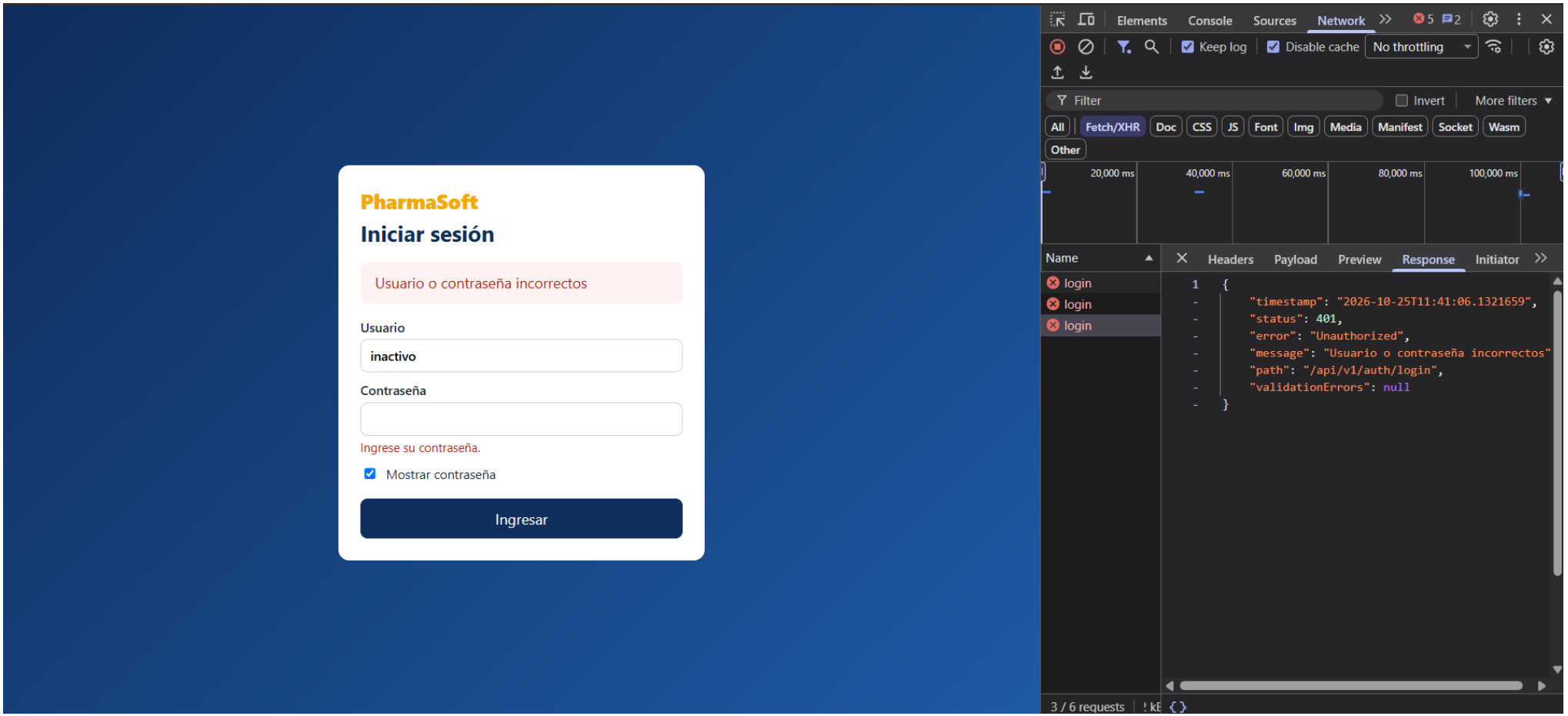
La petición permite identificar el intento de autenticación que se contrasta con el rechazo.



Login y redirección segura

E009 · L-02 · Mensaje para cuenta inactiva

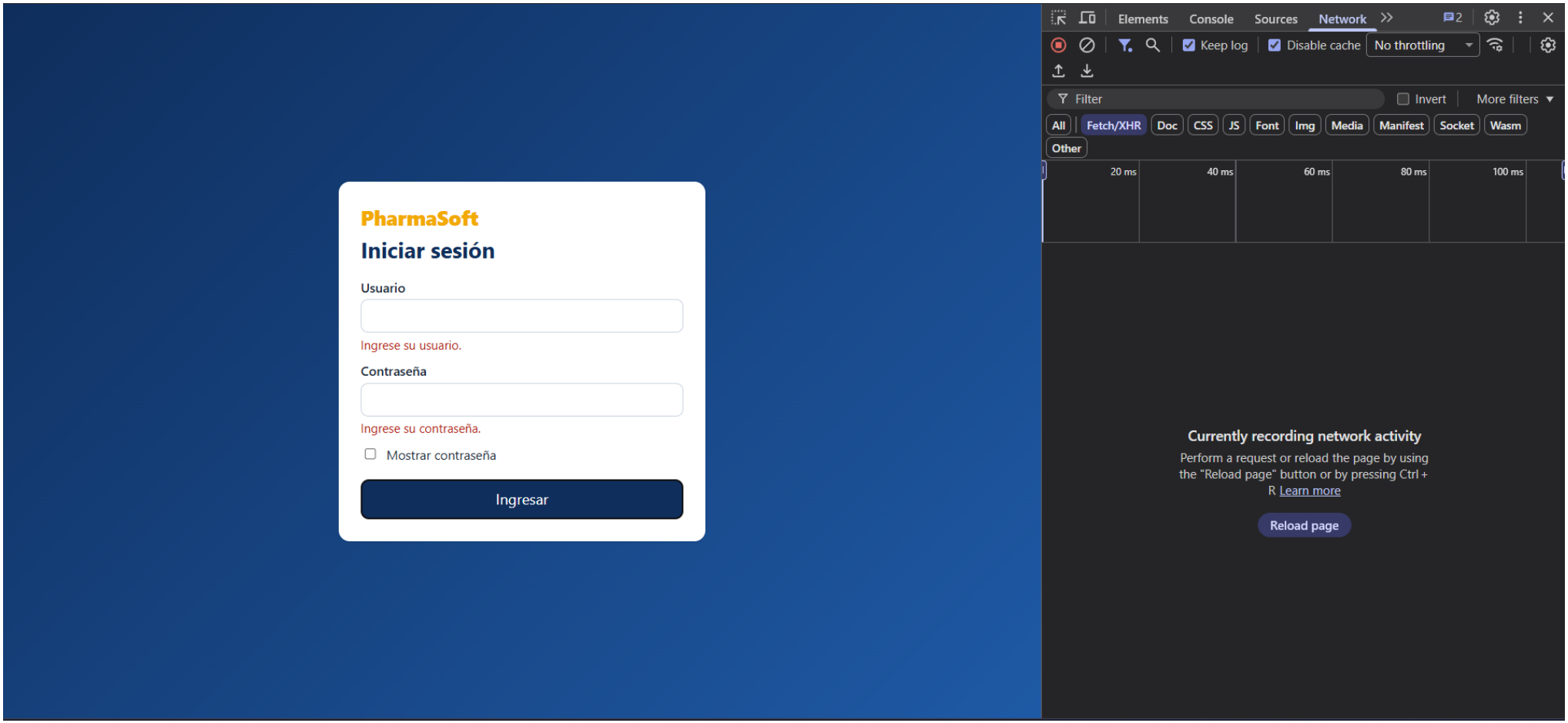
La respuesta mantiene el mismo mensaje genérico: Usuario o contraseña incorrectos.



Login y redirección segura

E010 · L-01 · Formulario vacío

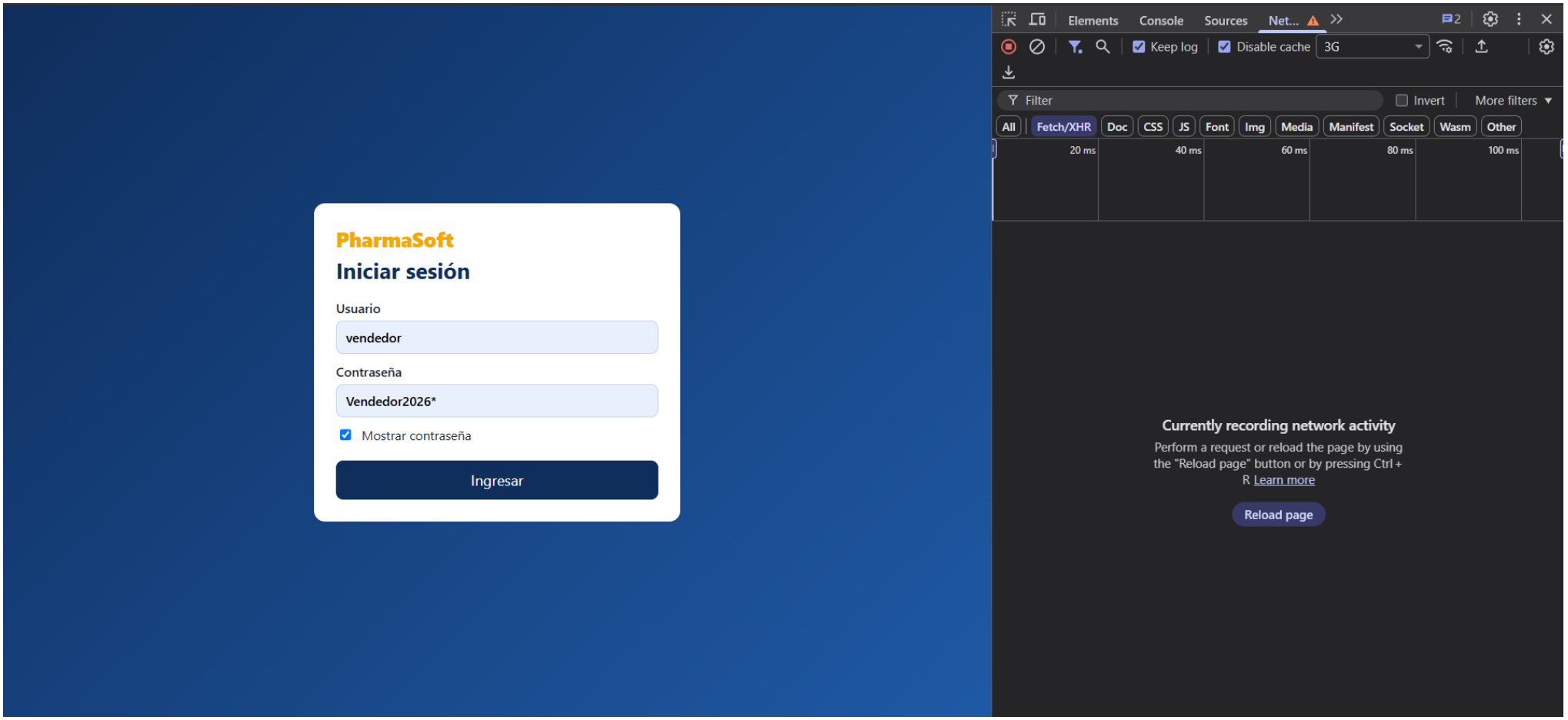
Los campos muestran mensajes obligatorios y Network permanece sin solicitudes de login.



Login y redirección segura

E011 · L-03 · Preparación del doble envío

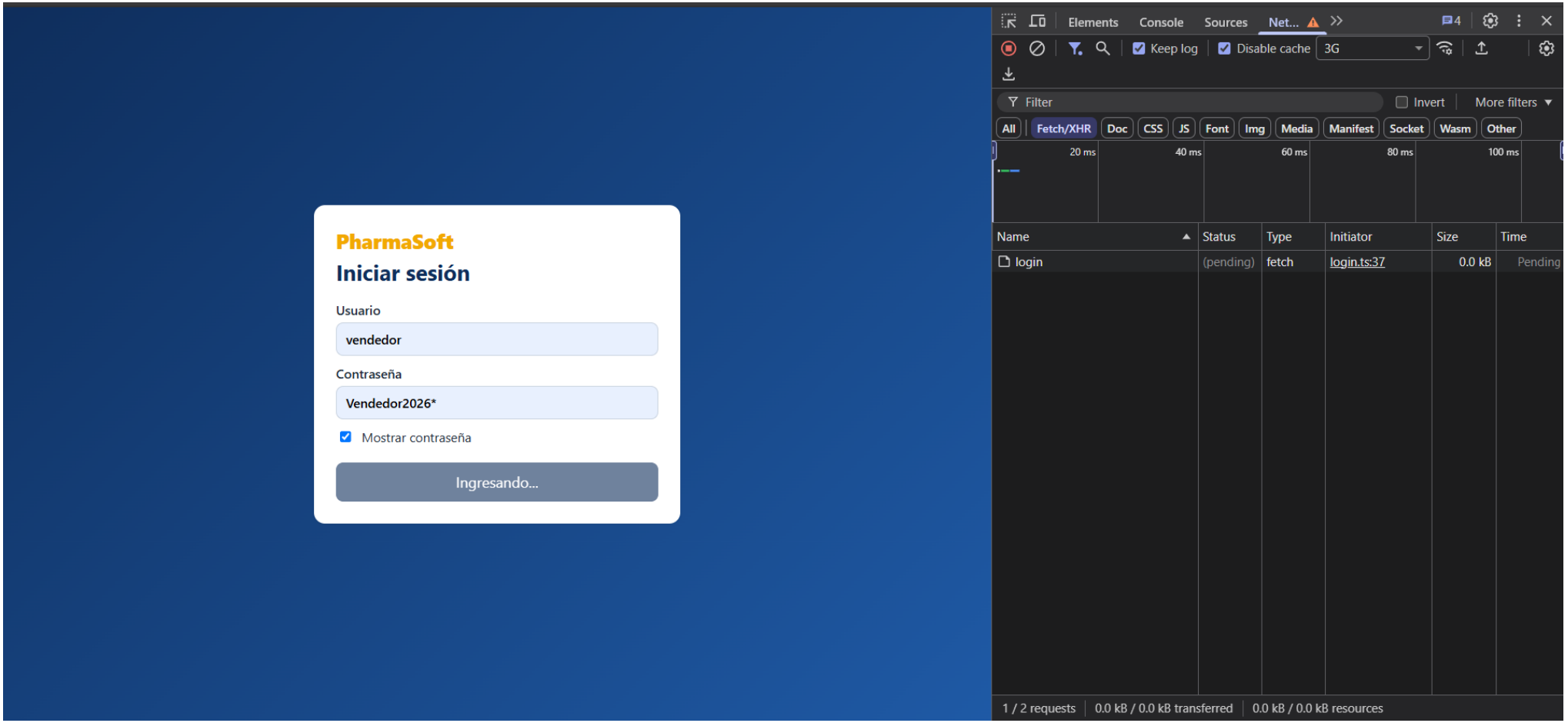
Formulario completo antes de comprobar el bloqueo de envíos simultáneos.



Login y redirección segura

E012 · L-03 · Petición en curso

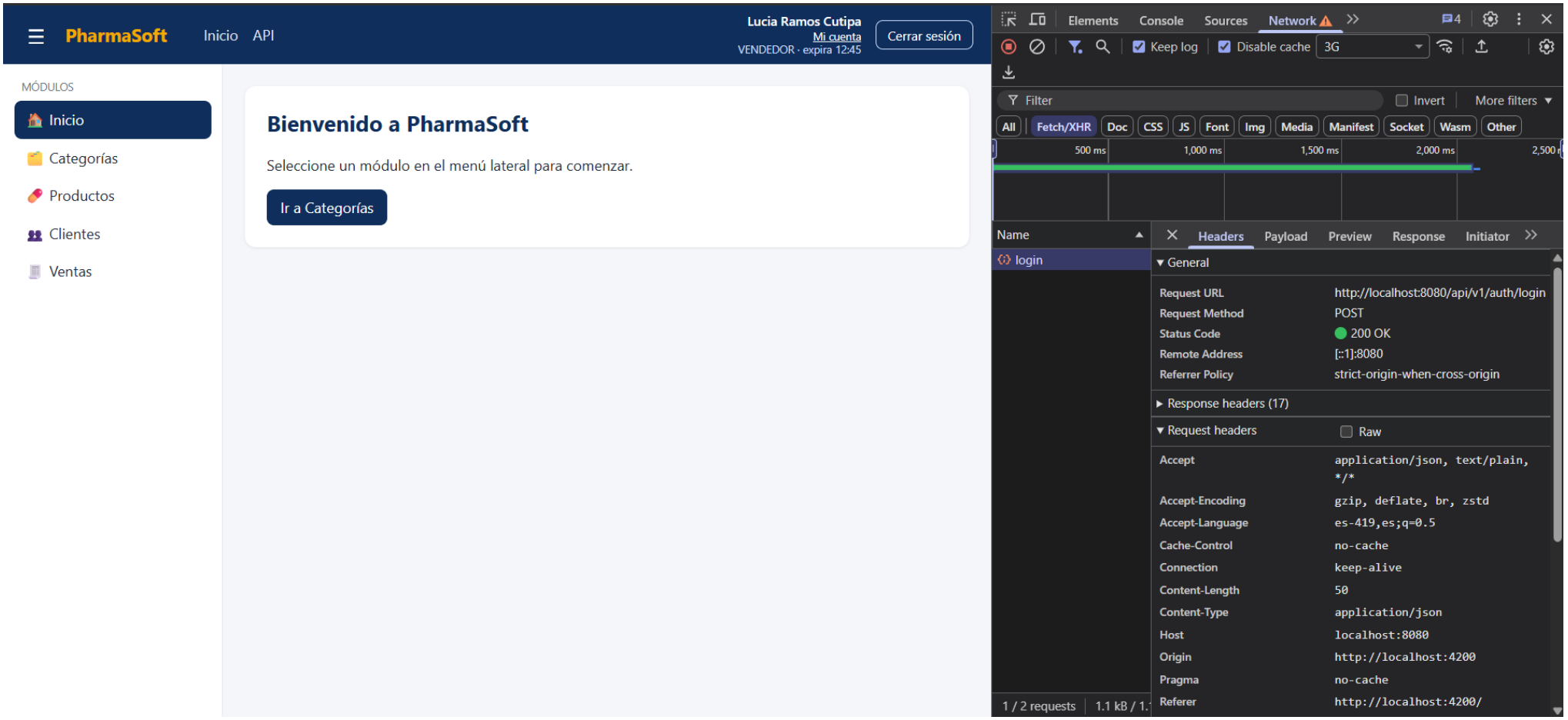
Ingresando... aparece deshabilitado mientras existe una única solicitud login pendiente.



Login y redirección segura

E013 · L-03 · Login completado

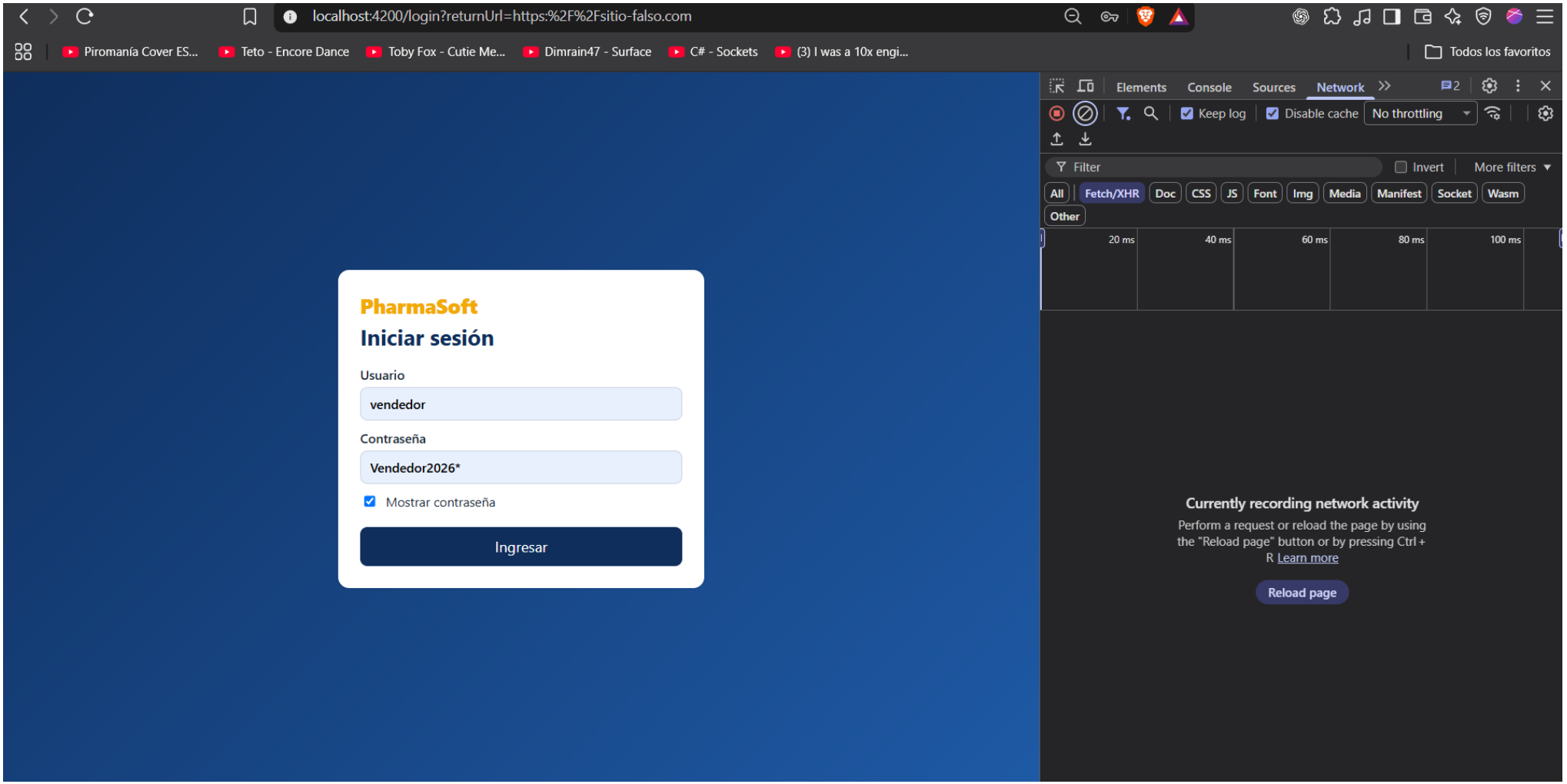
Una petición POST login devuelve 200 y abre Inicio con la cuenta vendedor.



Login y redirección segura

E014 · L-04 · Destino externo solicitado

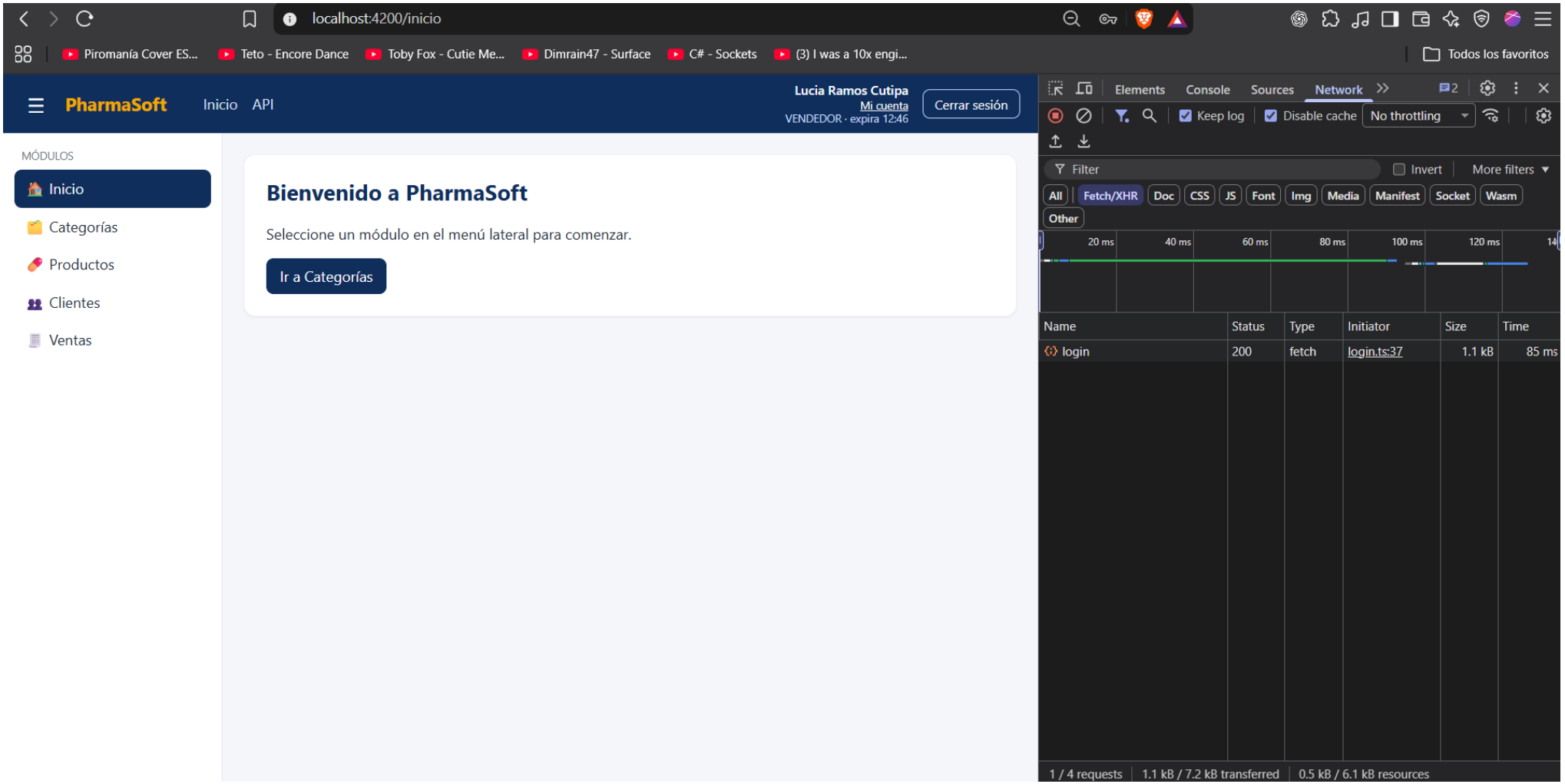
La URL de login incluye returnUrl con un dominio externo de prueba.



Login y redirección segura

E015 · L-04 · Destino interno seguro

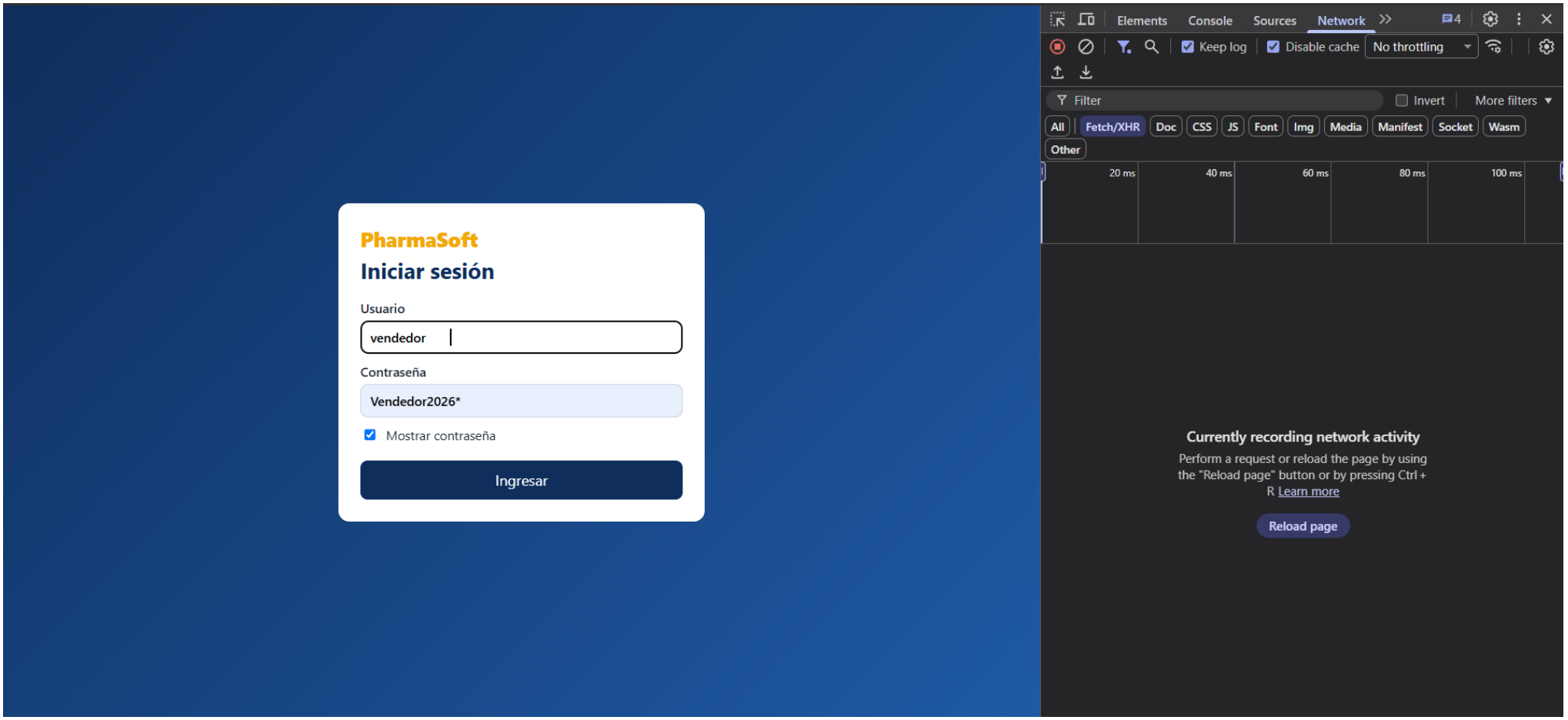
Después del login la navegación termina en localhost:4200/inicio.



Login y redirección segura

E016 · L-05 · Usuario con espacios finales

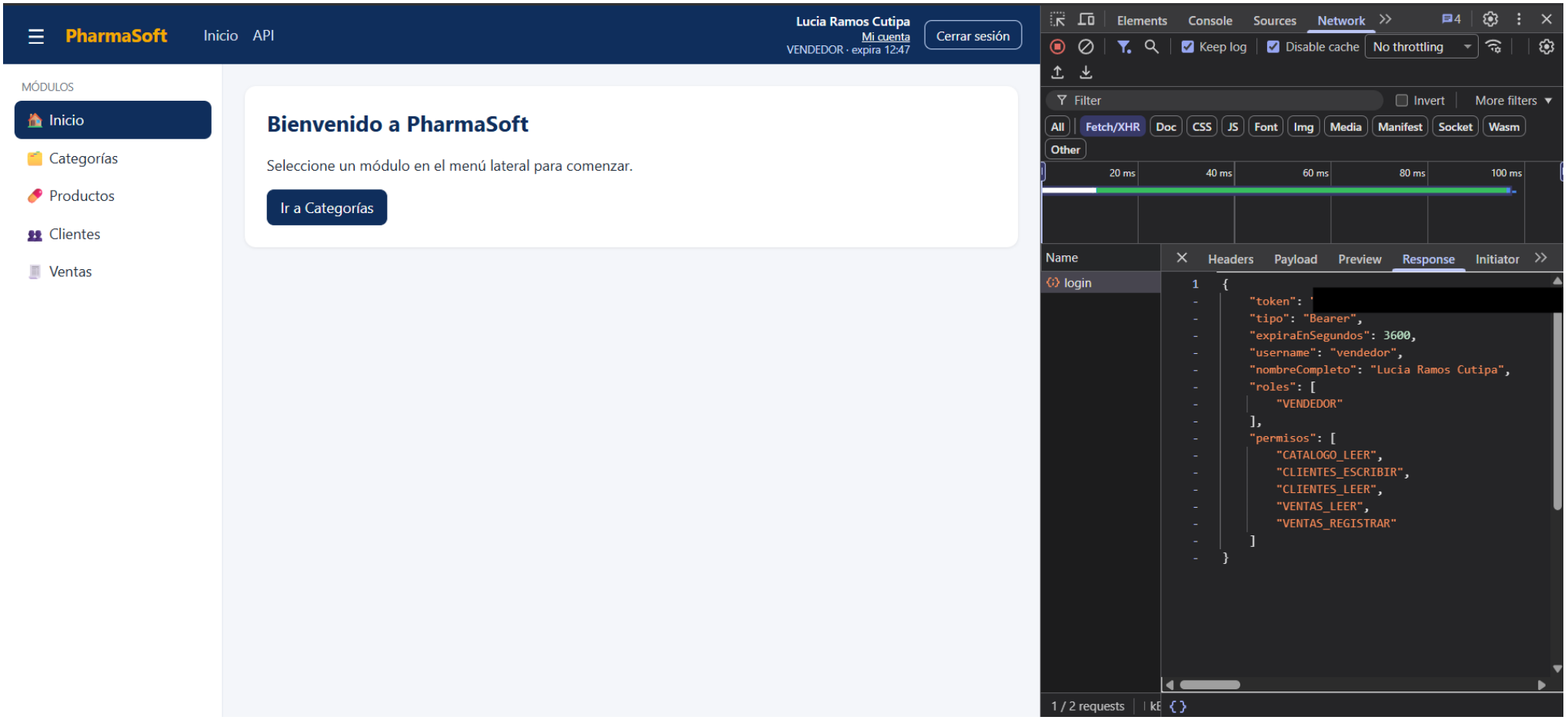
Se introduce vendedor con espacios al final; el cursor permite observar la separación.



Login y redirección segura

E017 · L-05 · Identidad canónica

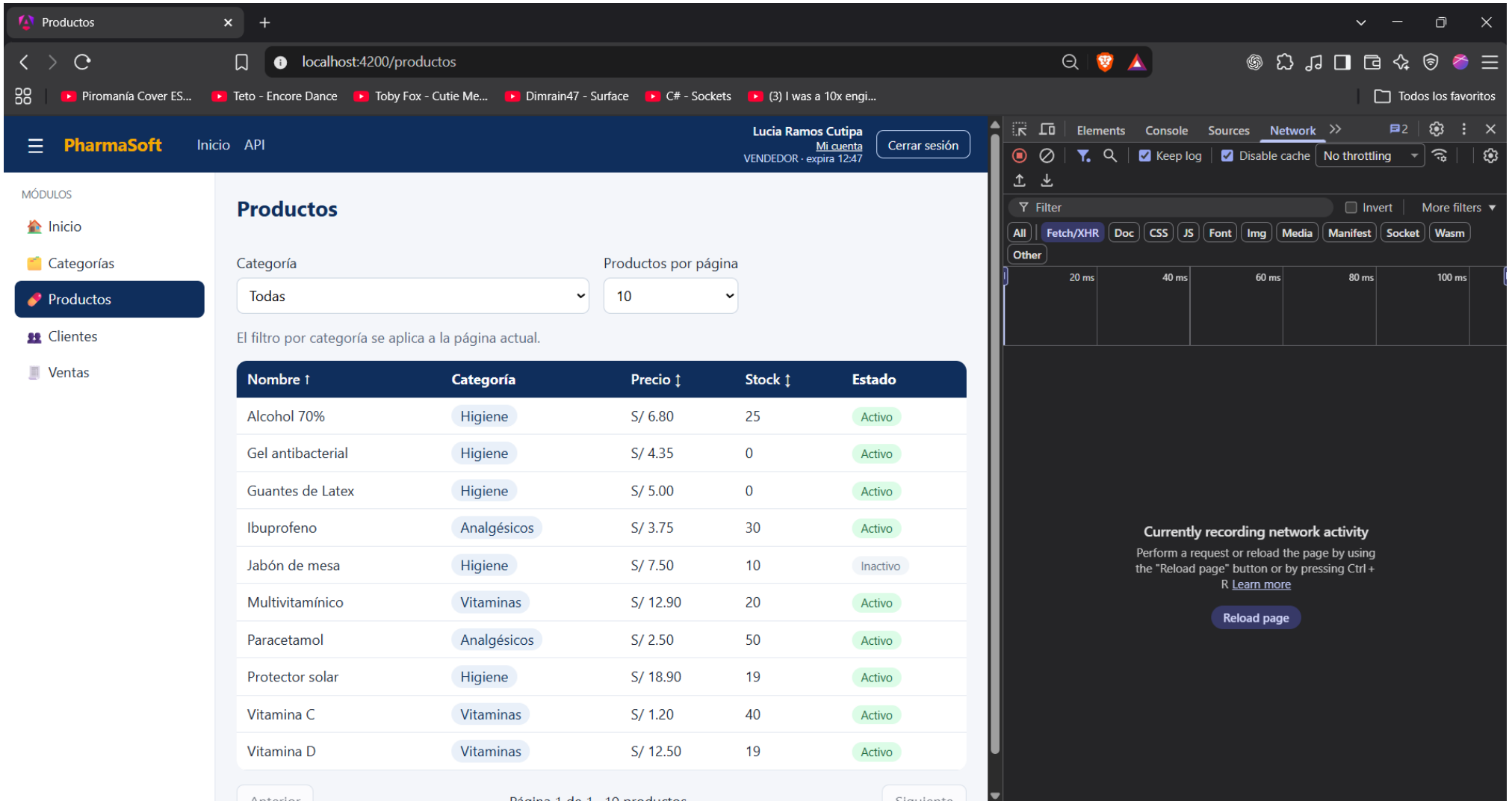
El login permite el acceso y devuelve username vendedor con duración normal de 3600 segundos.



Sesión y almacenamiento

E018 · S-01 · Catálogo con sesión

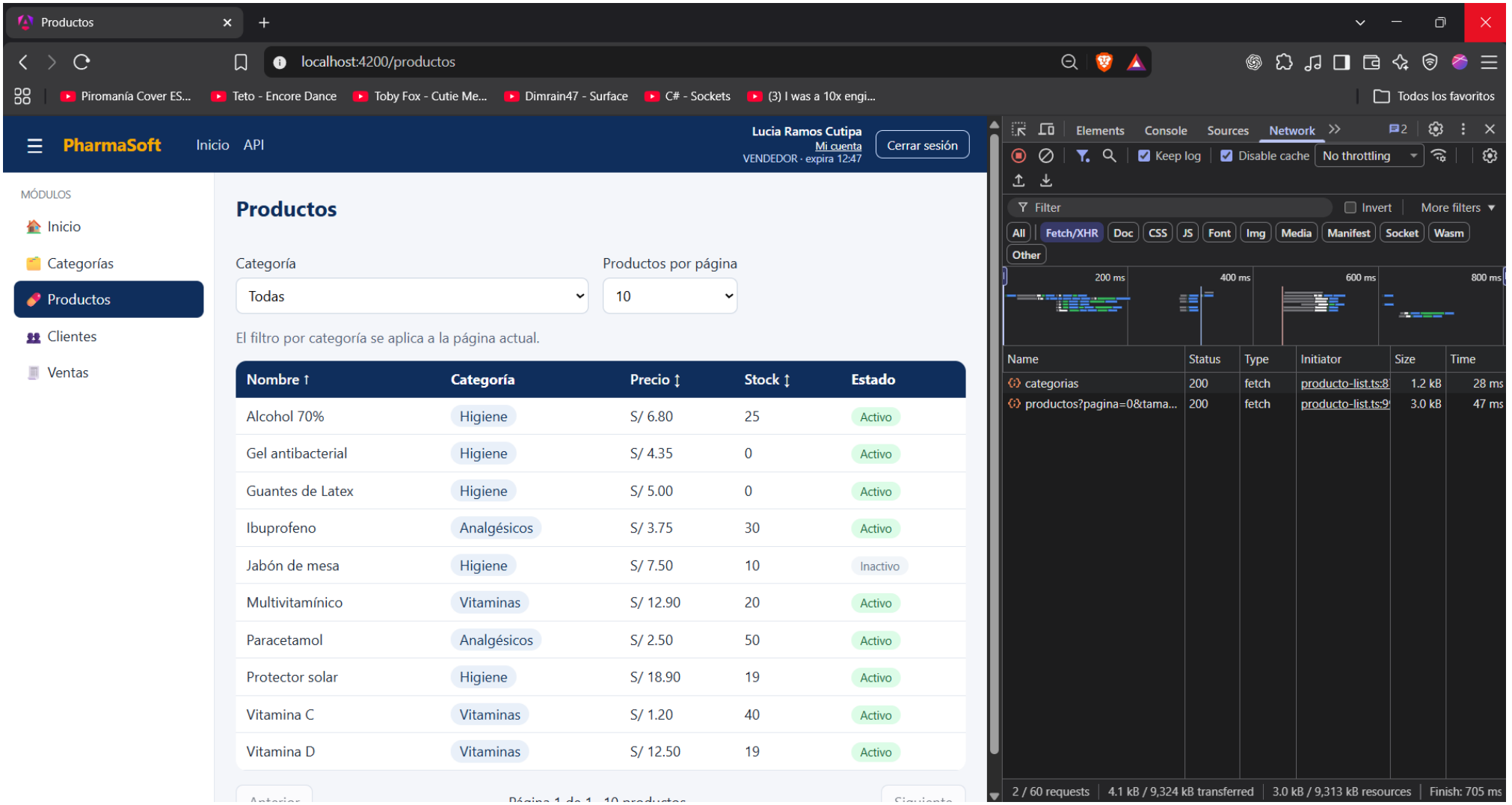
Productos se muestra con la identidad de vendedor antes de la recarga.



Sesión y almacenamiento

E019 · S-01 · Recarga de la aplicación

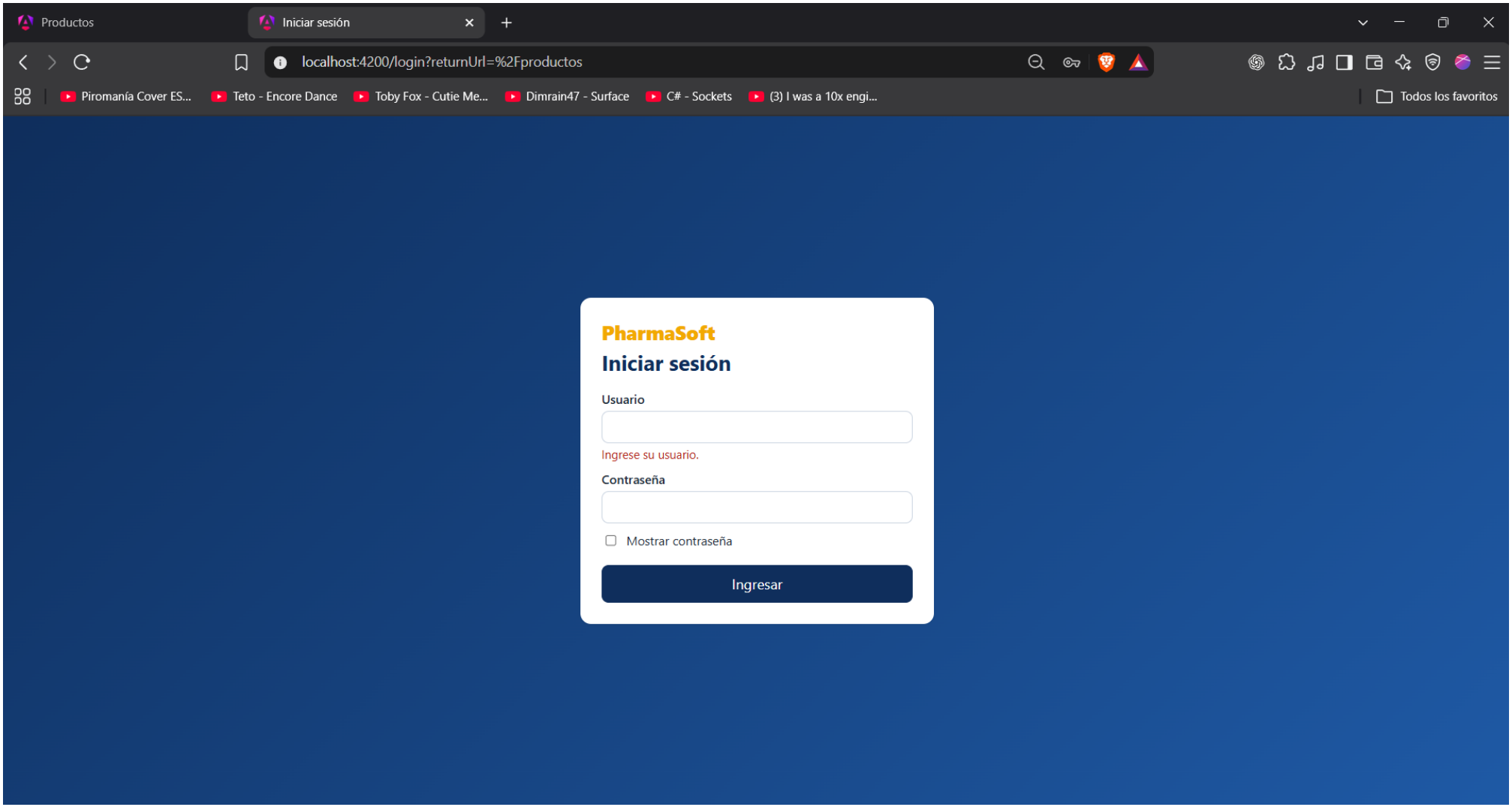
Después de F5 se conserva la identidad y las consultas vuelven a responder 200.



Sesión y almacenamiento

E020 · S-01 · Nueva ventana sin sesión

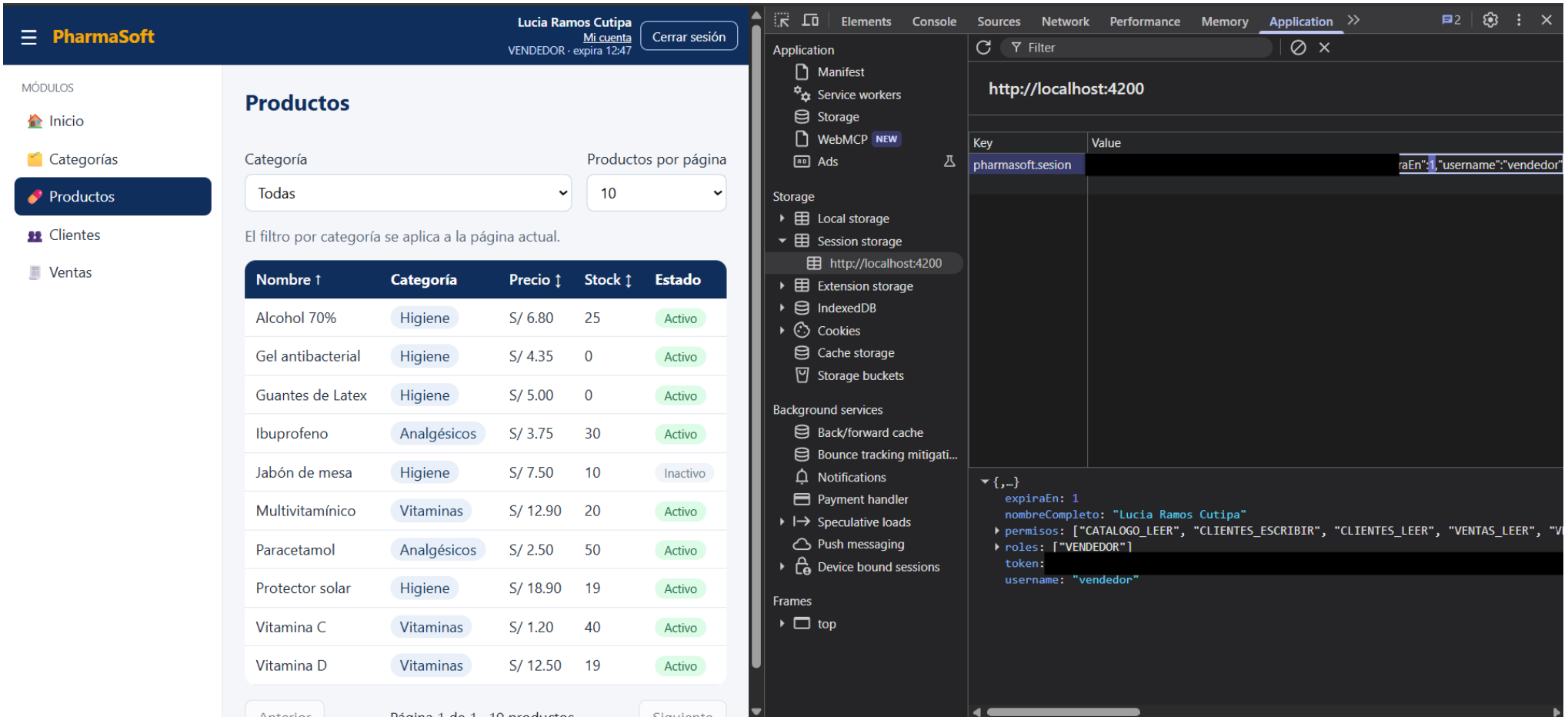
La nueva ventana de prueba presenta el login.



Sesión y almacenamiento

E021 · S-02 · Vencimiento local en el pasado

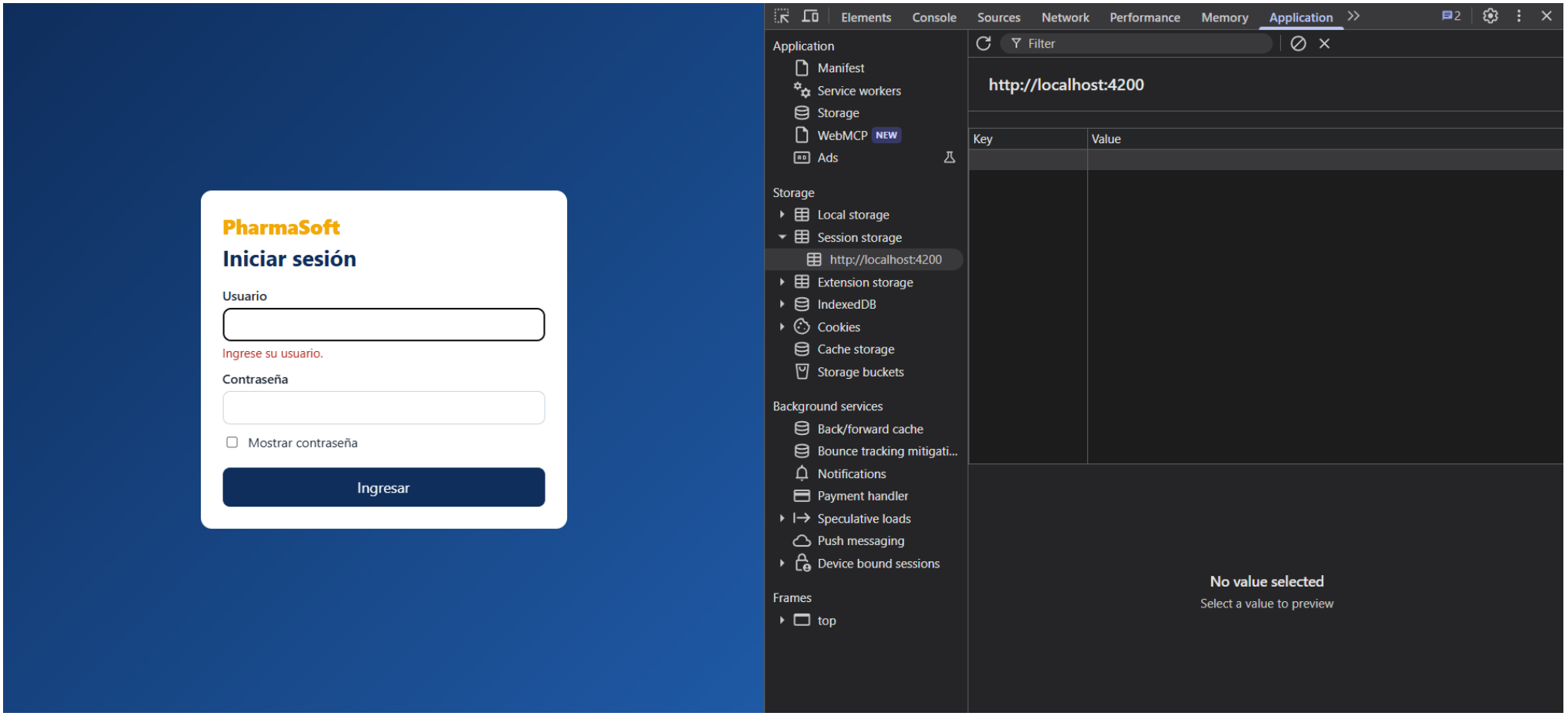
En sessionStorage se establece expiraEn: 1, manteniendo los demás datos de prueba.



Sesión y almacenamiento

E022 · S-02 · Sesión vencida descartada

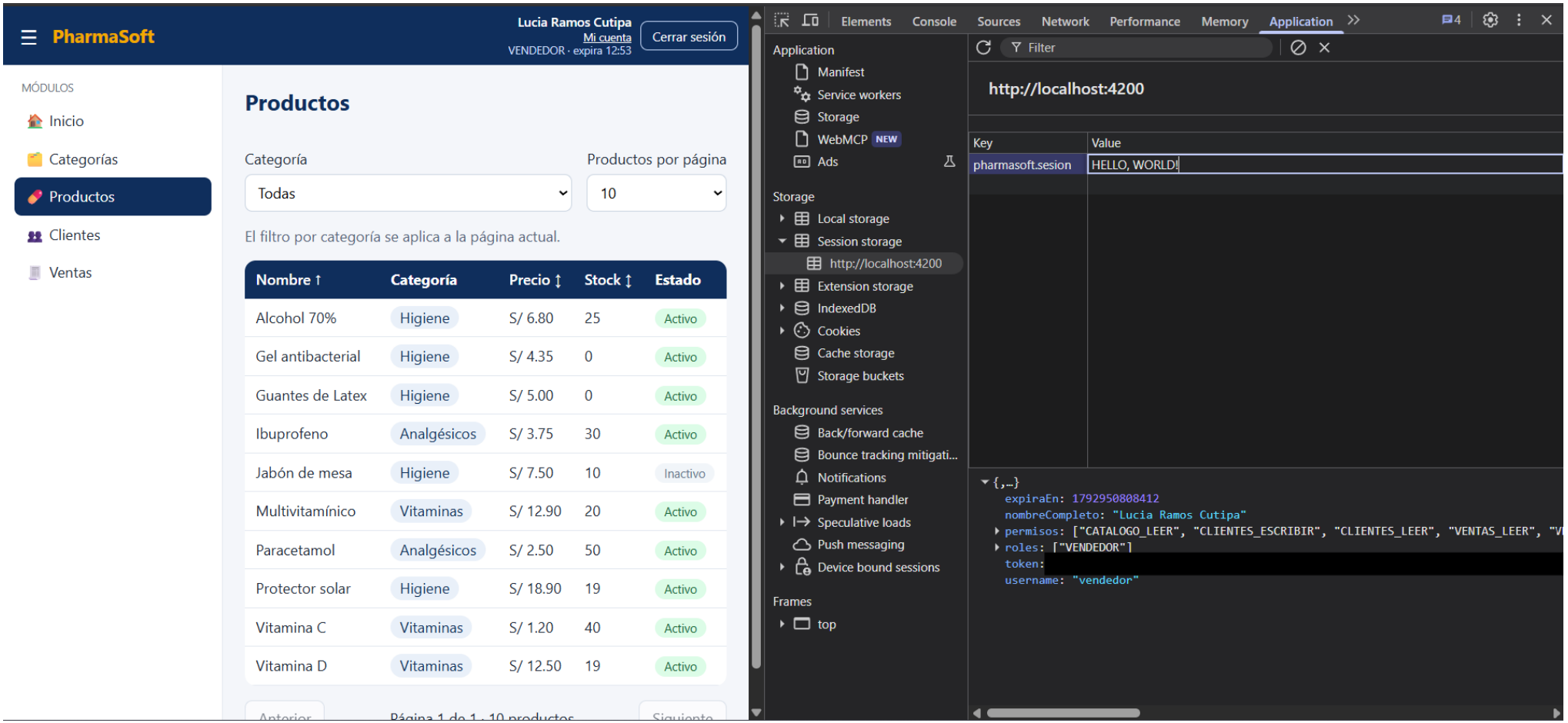
Tras recargar aparece login y desaparece pharmasoft.sesion.



Sesión y almacenamiento

E023 · S-03 · Contenido que no es JSON

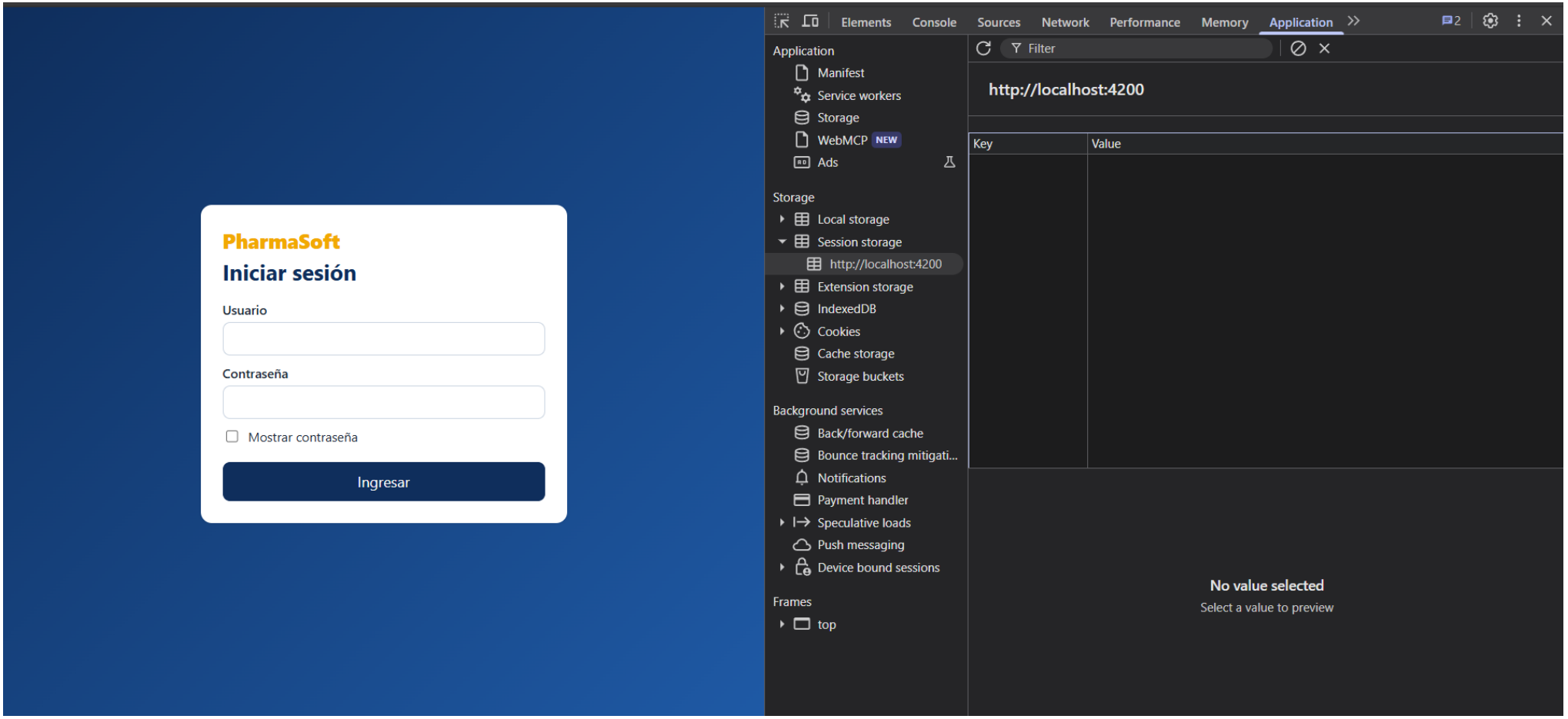
El valor de sesión se sustituye por HELLO, WORLD! para comprobar la recuperación ante datos dañados.



Sesión y almacenamiento

E024 · S-03 · Recuperación del almacenamiento inválido

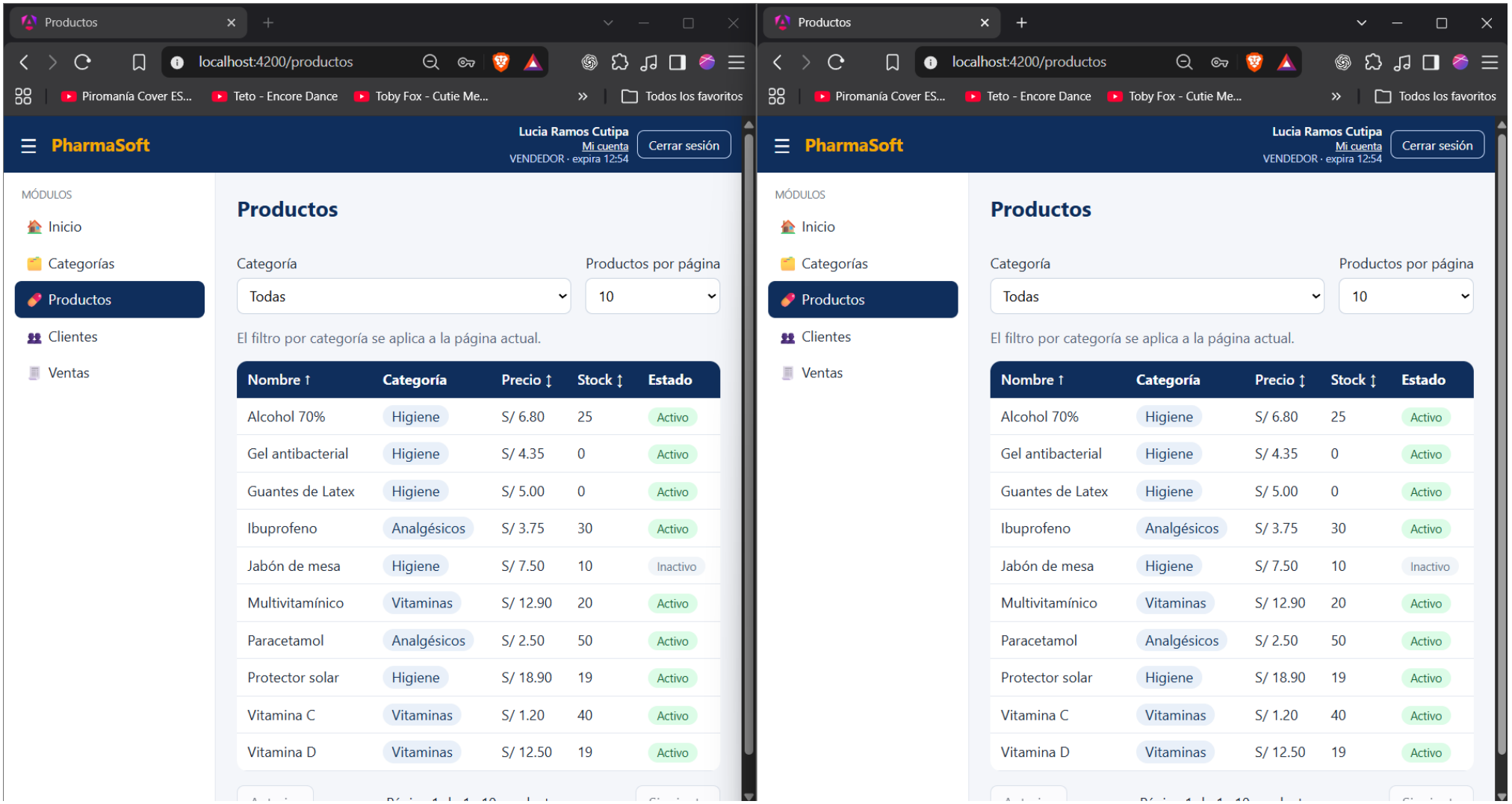
La SPA muestra login y elimina el valor que no puede interpretar.



Sesión y almacenamiento

E025 · S-04 · Dos contextos con sesión

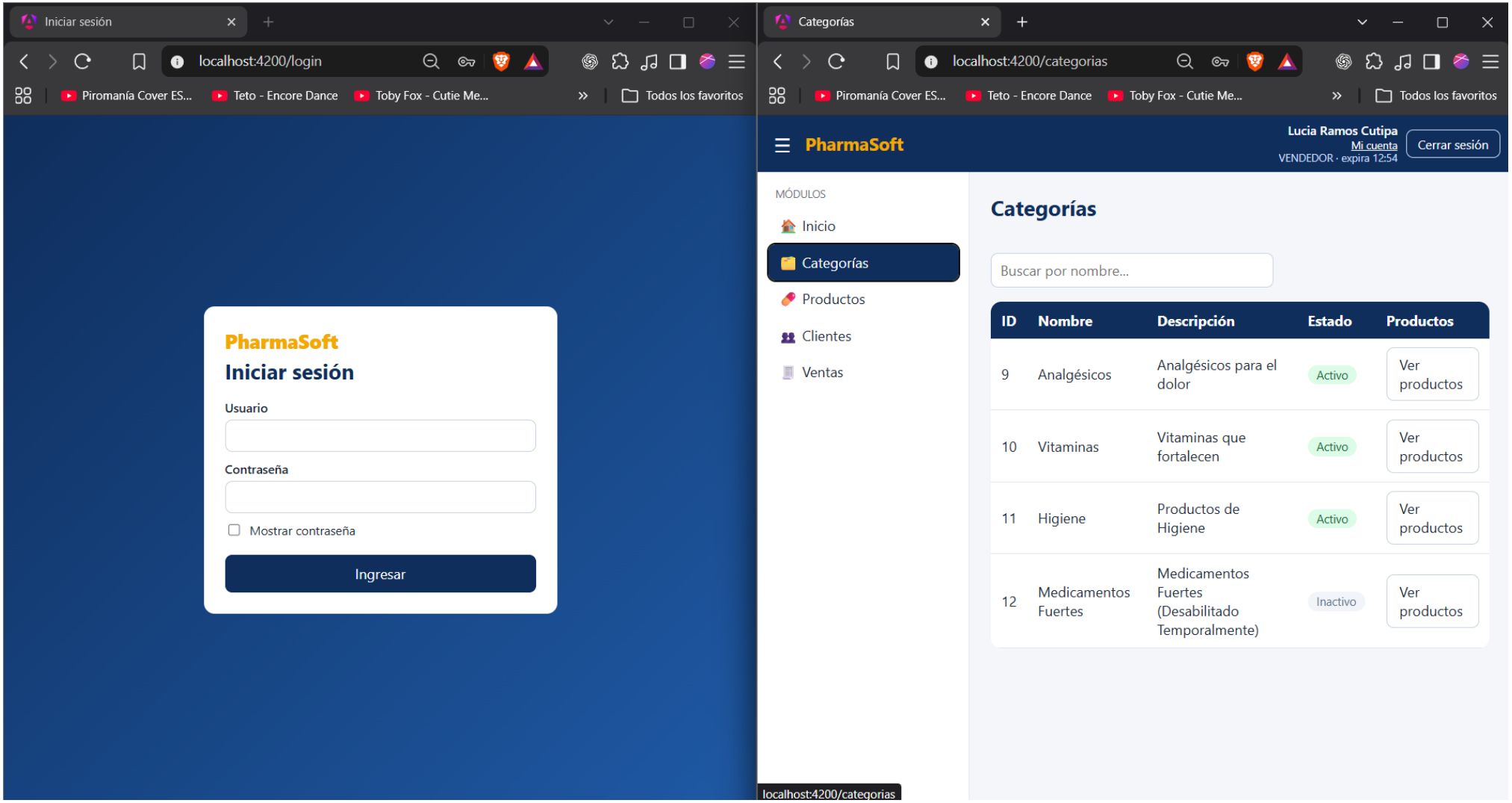
Ambas ventanas muestran Productos con vendedor autenticado.



Sesión y almacenamiento

E026 · S-04 · Logout independiente

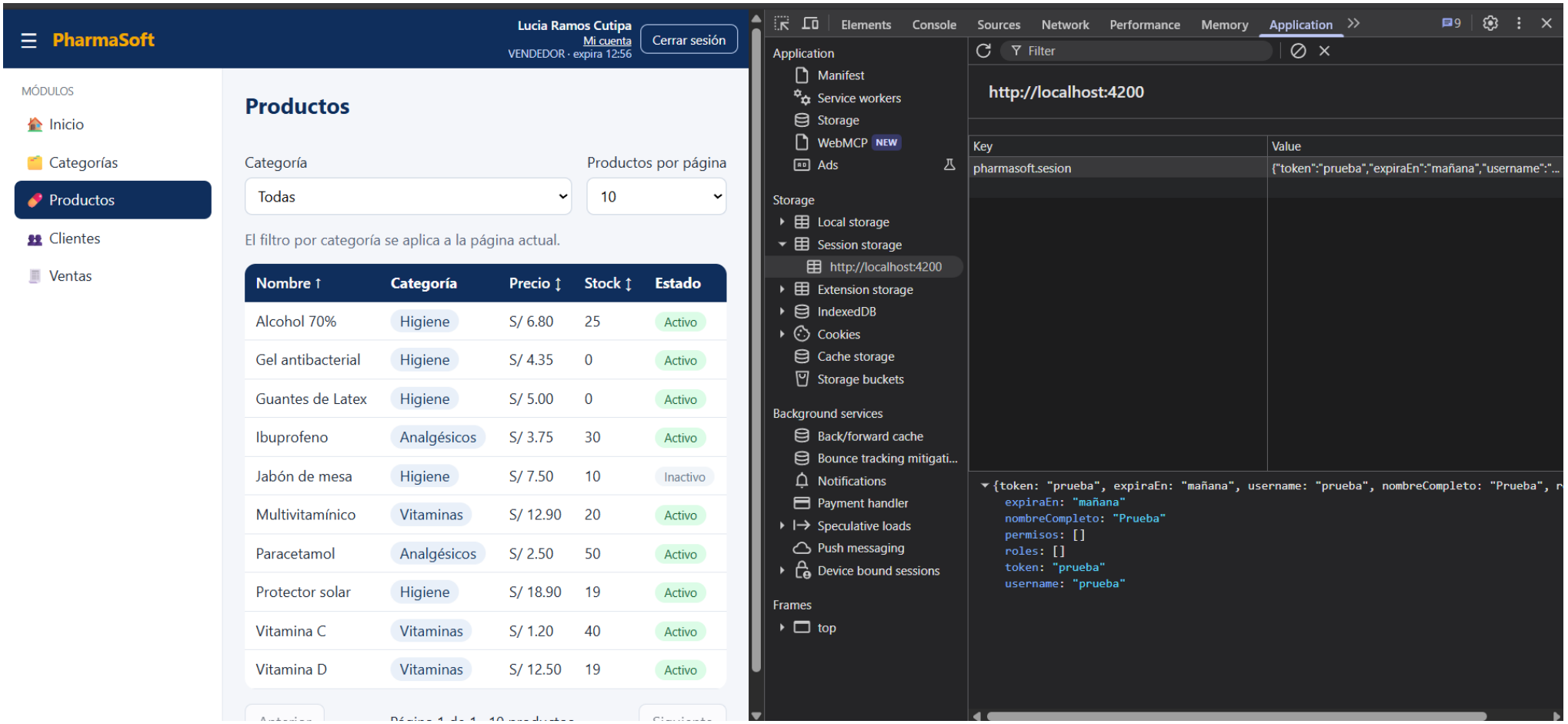
Una ventana queda en login; la otra continúa navegando por Categorías con su propia sesión.



Sesión y almacenamiento

E027 · S-05 · JSON con estructura incorrecta

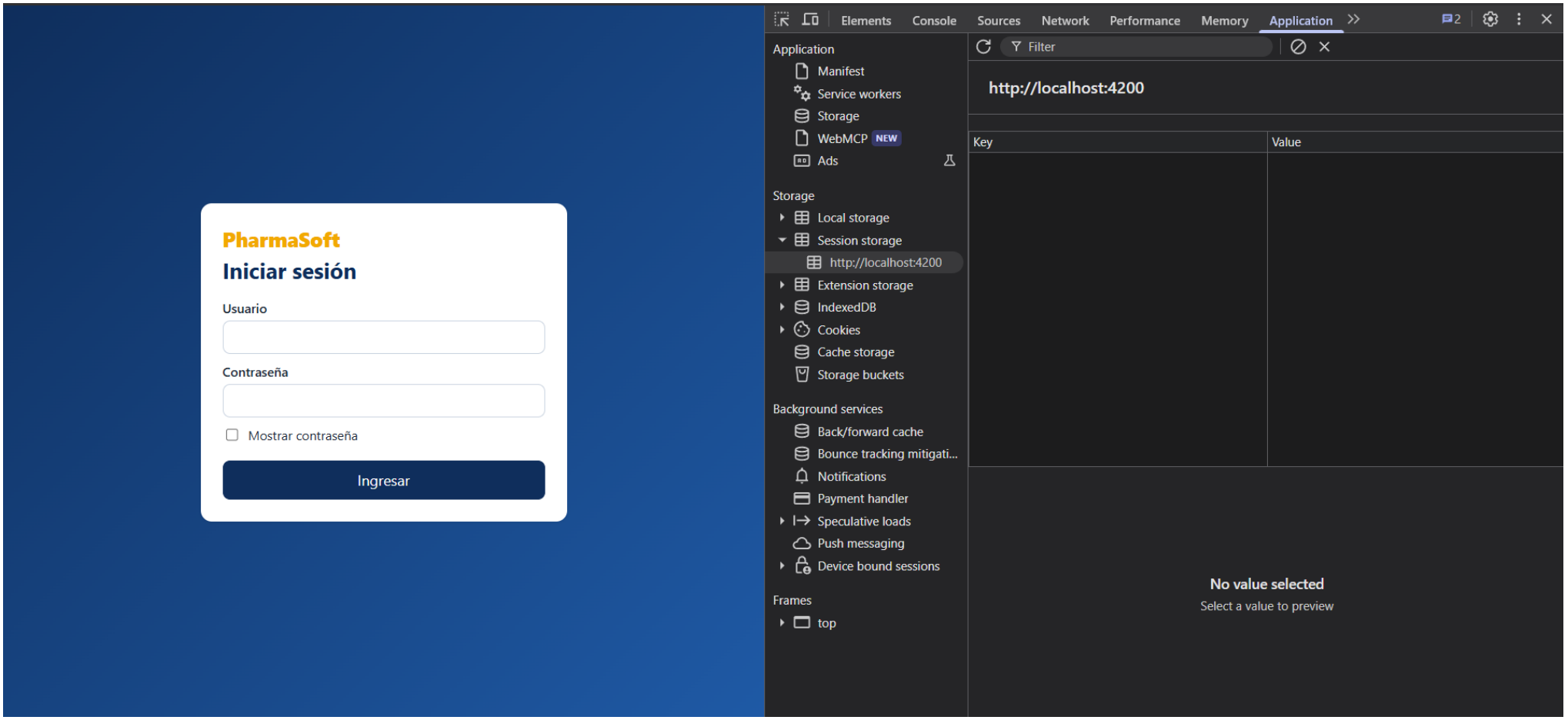
El JSON es válido, pero expiraEn contiene mañana en lugar de un número.



Sesión y almacenamiento

E028 · S-05 · Estructura inválida descartada

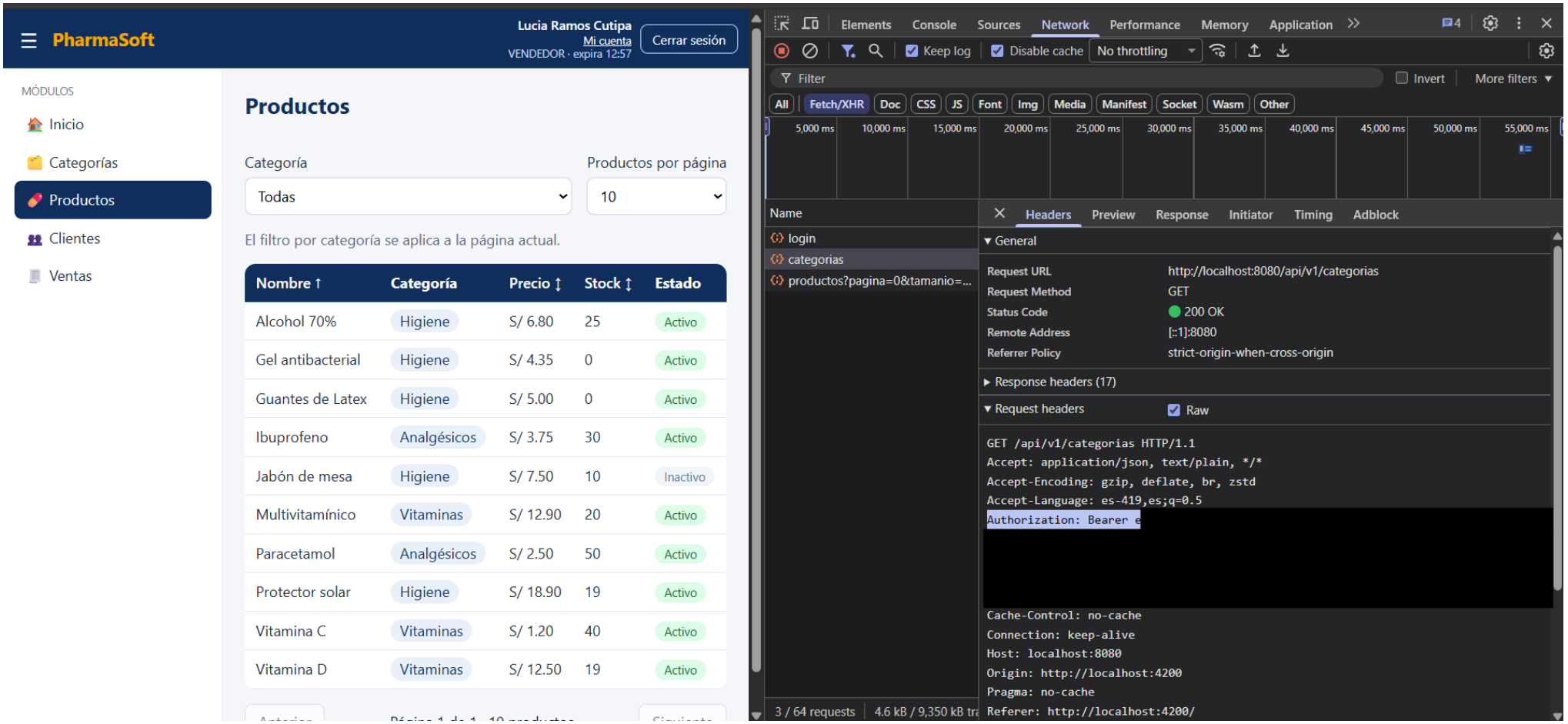
La recarga presenta login y limpia la entrada inválida de sessionStorage.



Interceptores y conexión

E029 · I-01 · Bearer en la API protegida

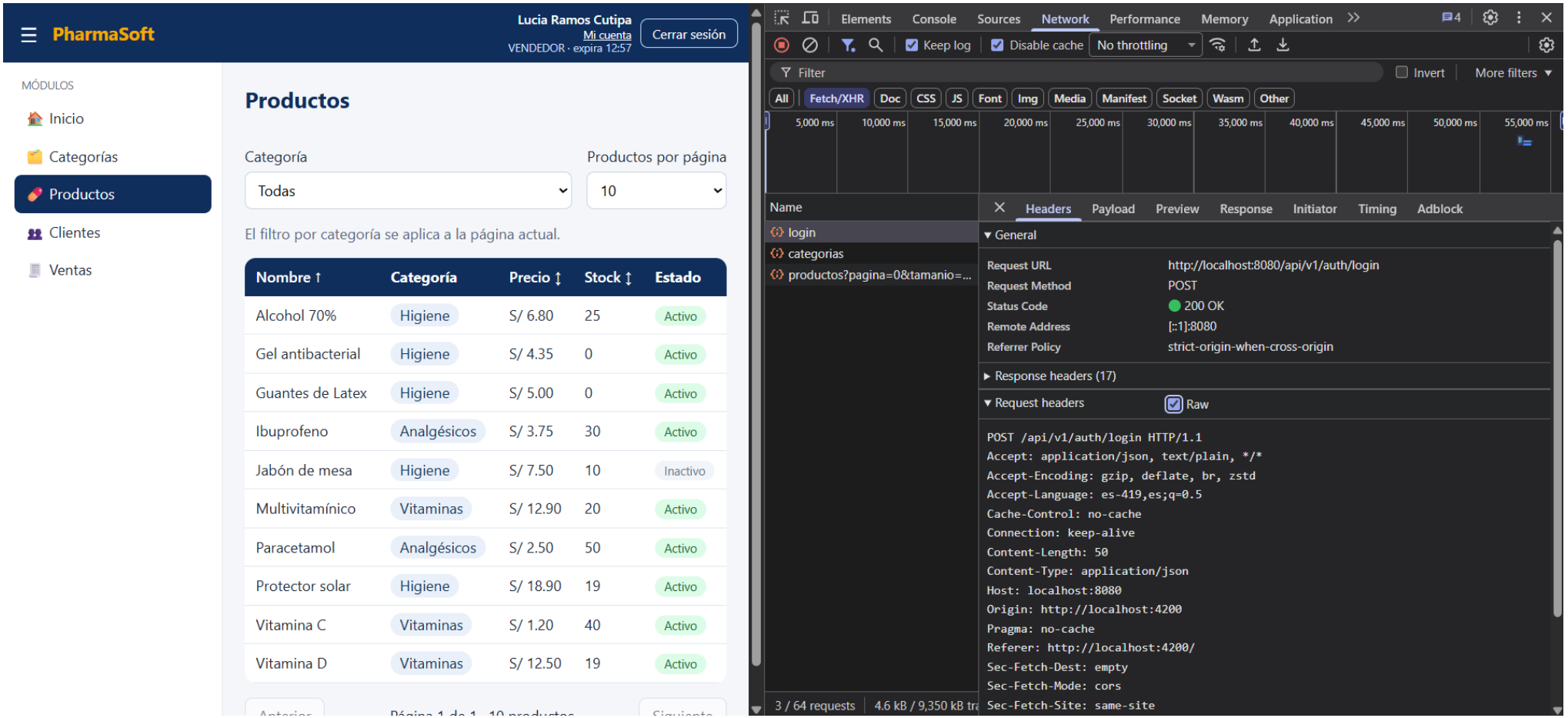
La consulta autenticada de Categorías contiene Authorization: Bearer y responde 200.



Interceptores y conexión

E030 · I-01 · Login sin Authorization

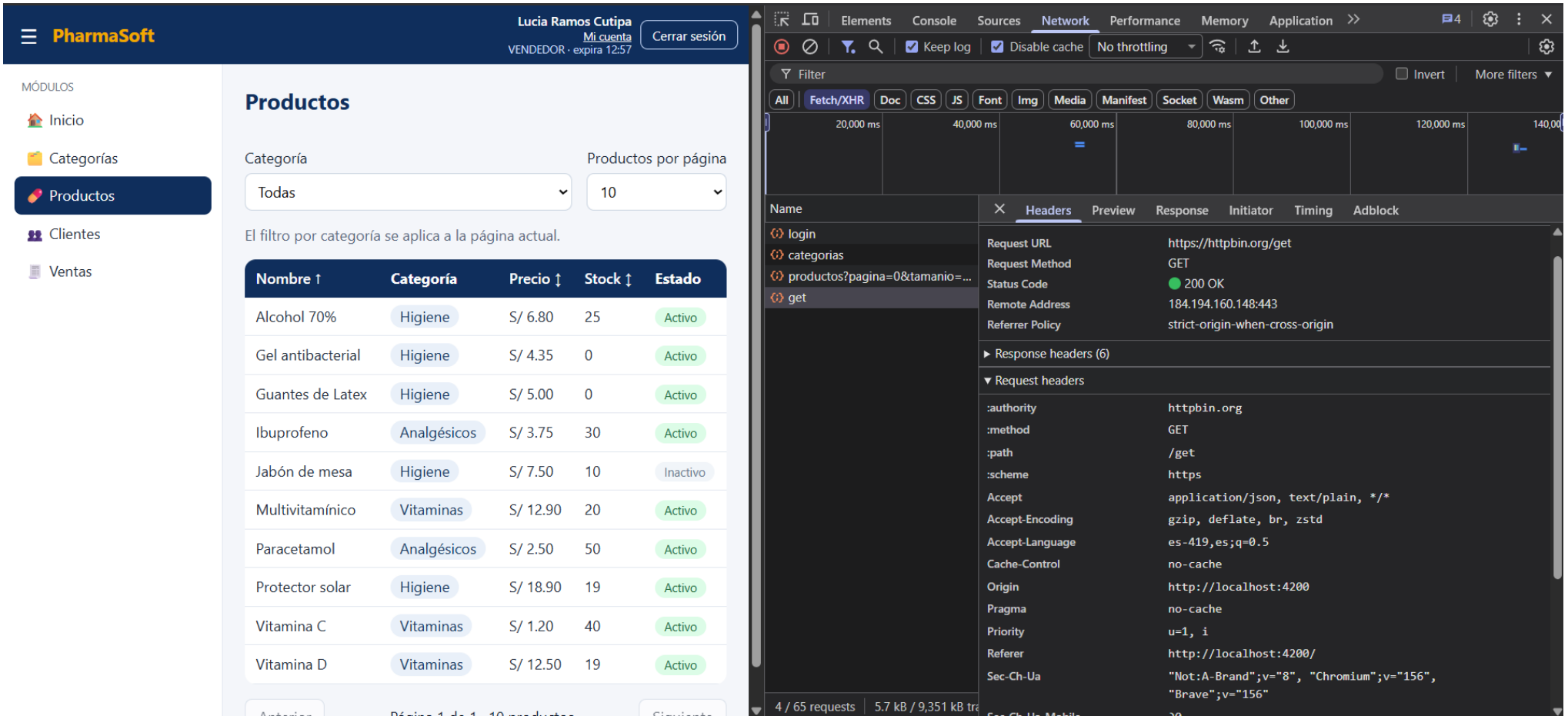
Los encabezados de POST auth/login no incluyen Authorization.



Interceptores y conexión

E031 · I-01 · Dominio externo sin Bearer

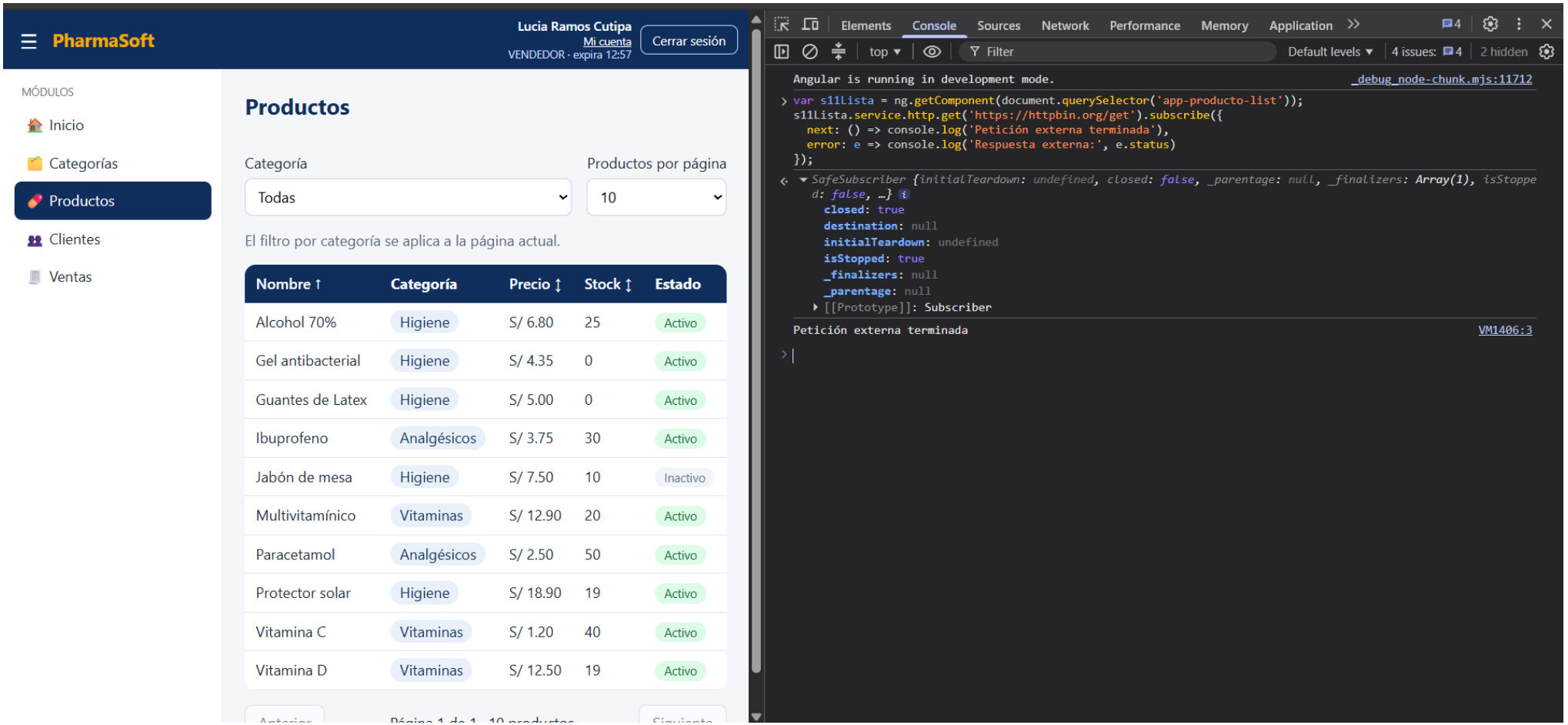
GET https://httpbin.org/get responde 200 sin Authorization entre los encabezados enviados.



Interceptores y conexión

E032 · I-01 · Petición externa desde Angular

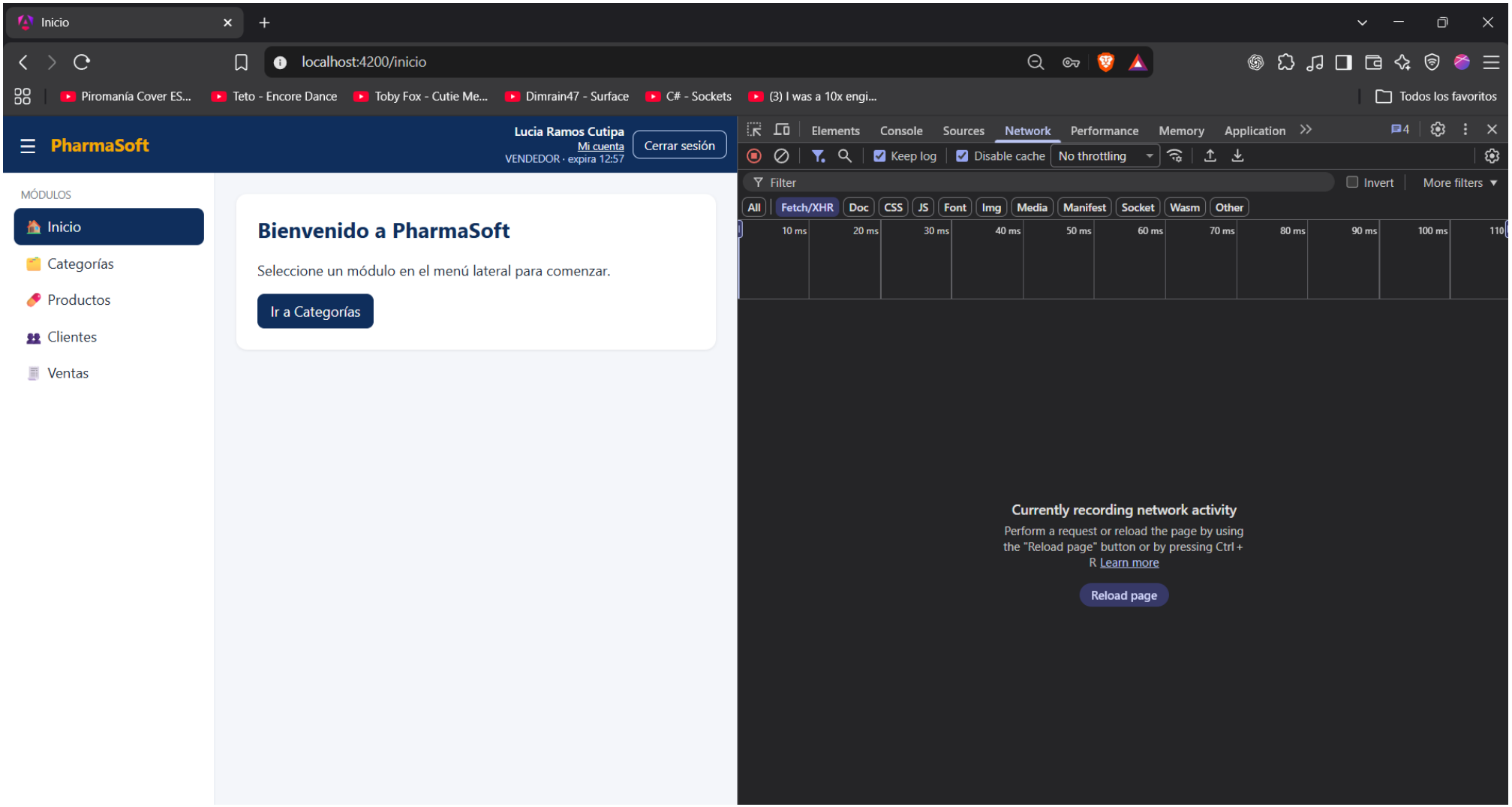
La consola ejecuta HttpClient desde el componente y confirma que la petición externa terminó.



Interceptores y conexión

E033 · I-02 · Sesión antes de la interrupción

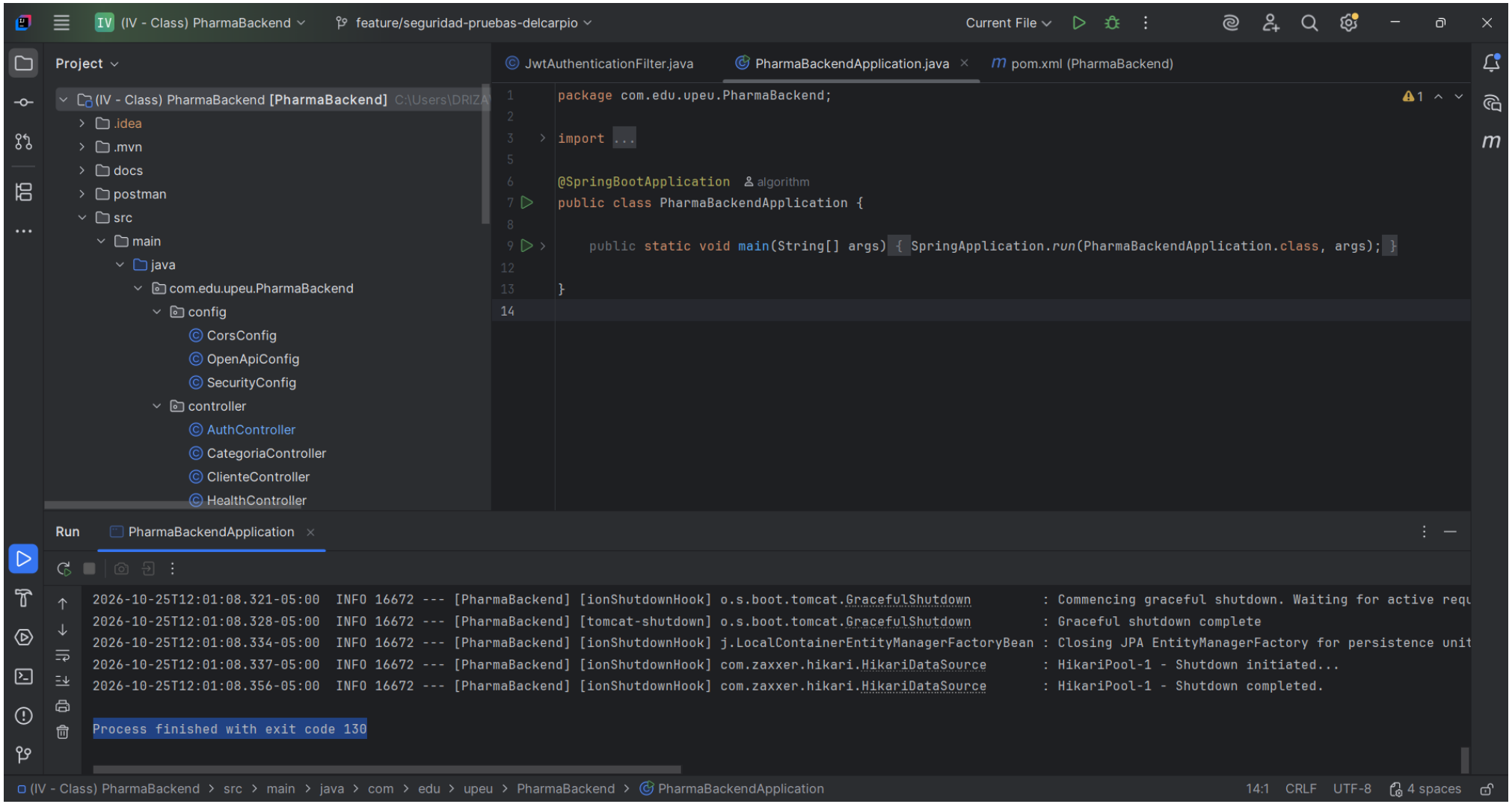
Inicio muestra al vendedor autenticado antes de detener el backend.



Interceptores y conexión

E034 · I-02 · Backend detenido

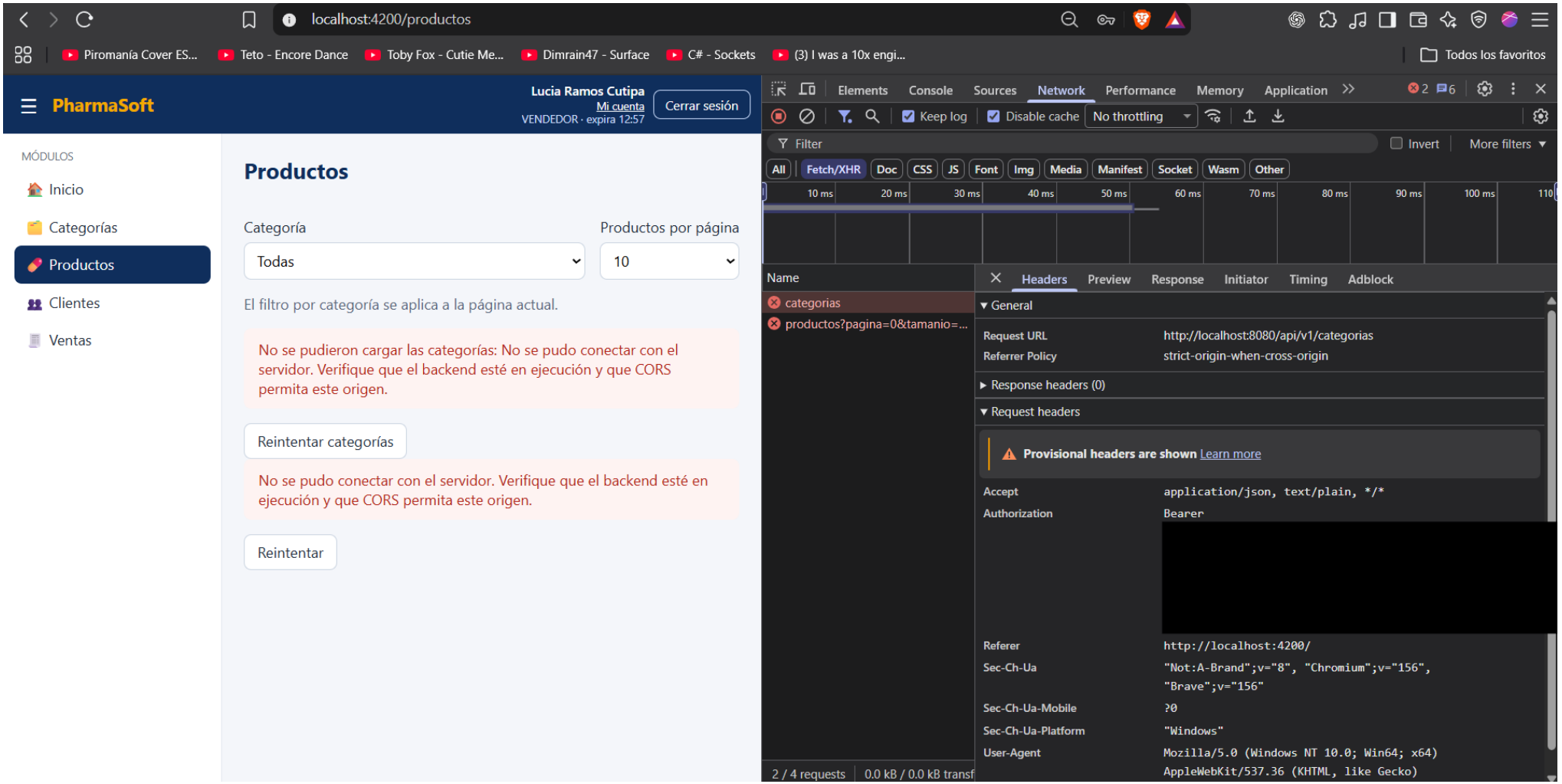
La consola del backend registra la detención de la aplicación.



Interceptores y conexión

E035 · I-02 · Error de conexión

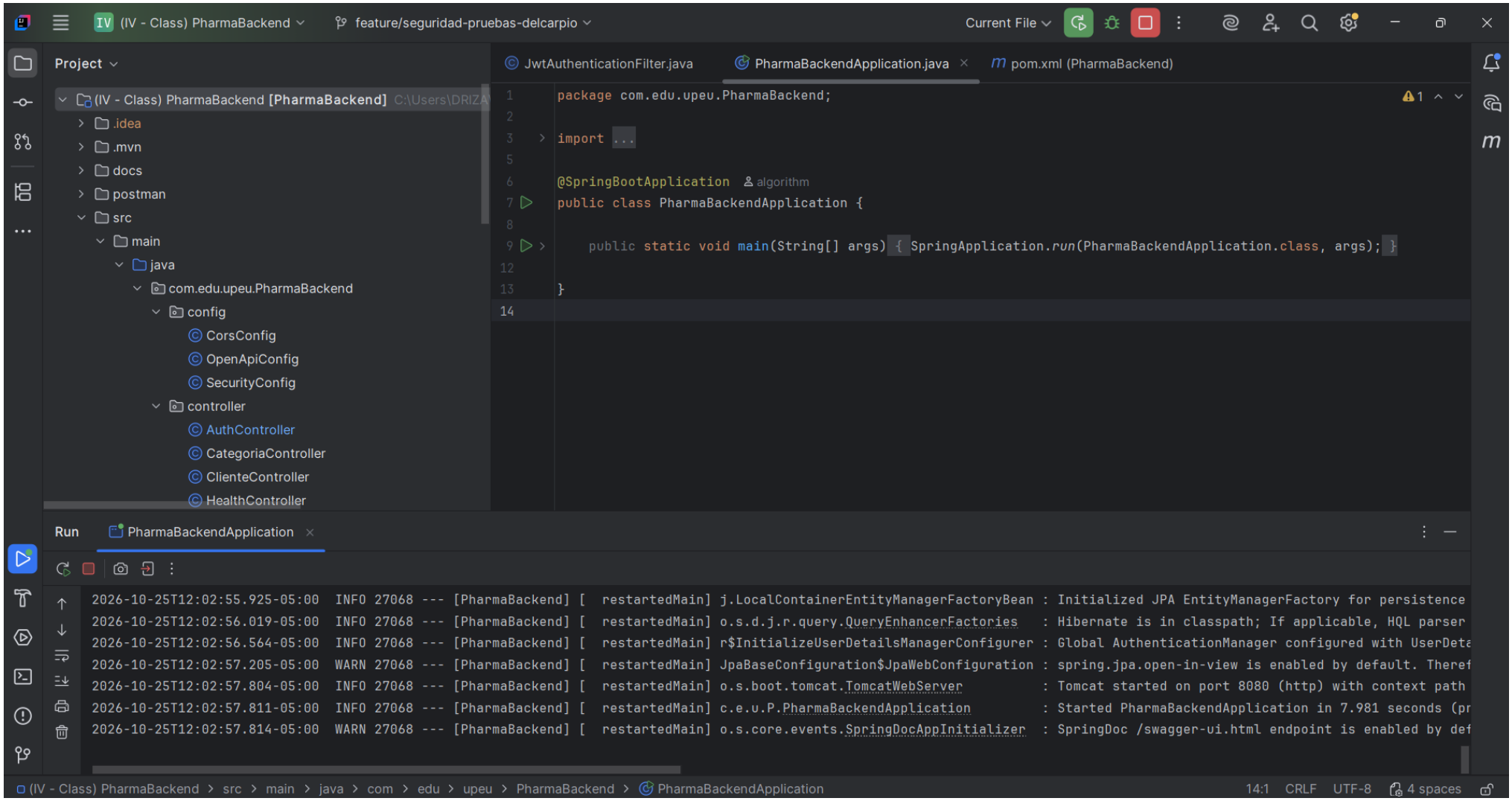
Productos comunica la imposibilidad de conectar con el servidor y conserva la identidad del vendedor.



Interceptores y conexión

E036 · I-02 · Backend reiniciado

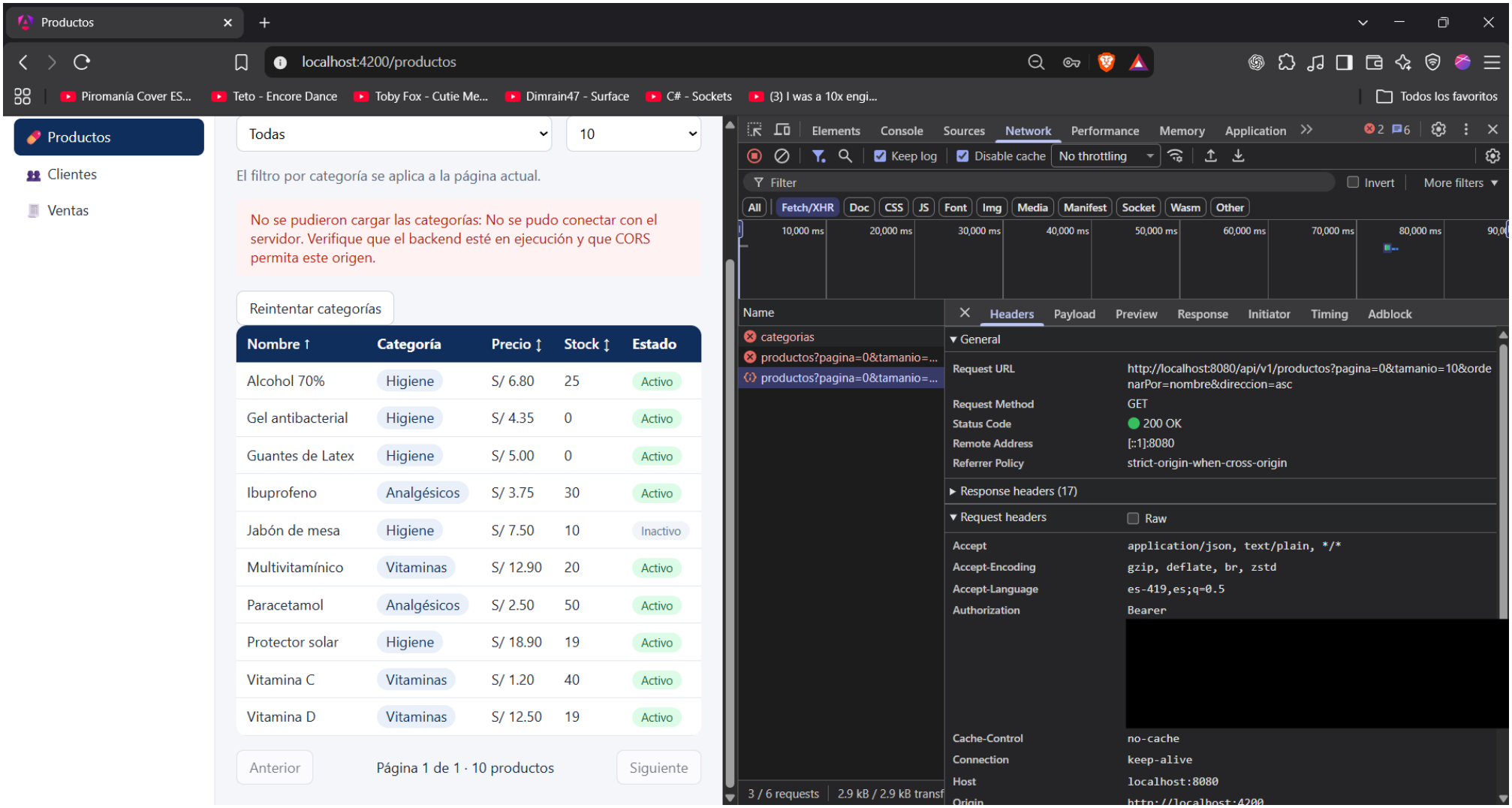
La aplicación backend vuelve a iniciar para recuperar las consultas.



Interceptores y conexión

E037 · I-02 · Recuperación de Productos

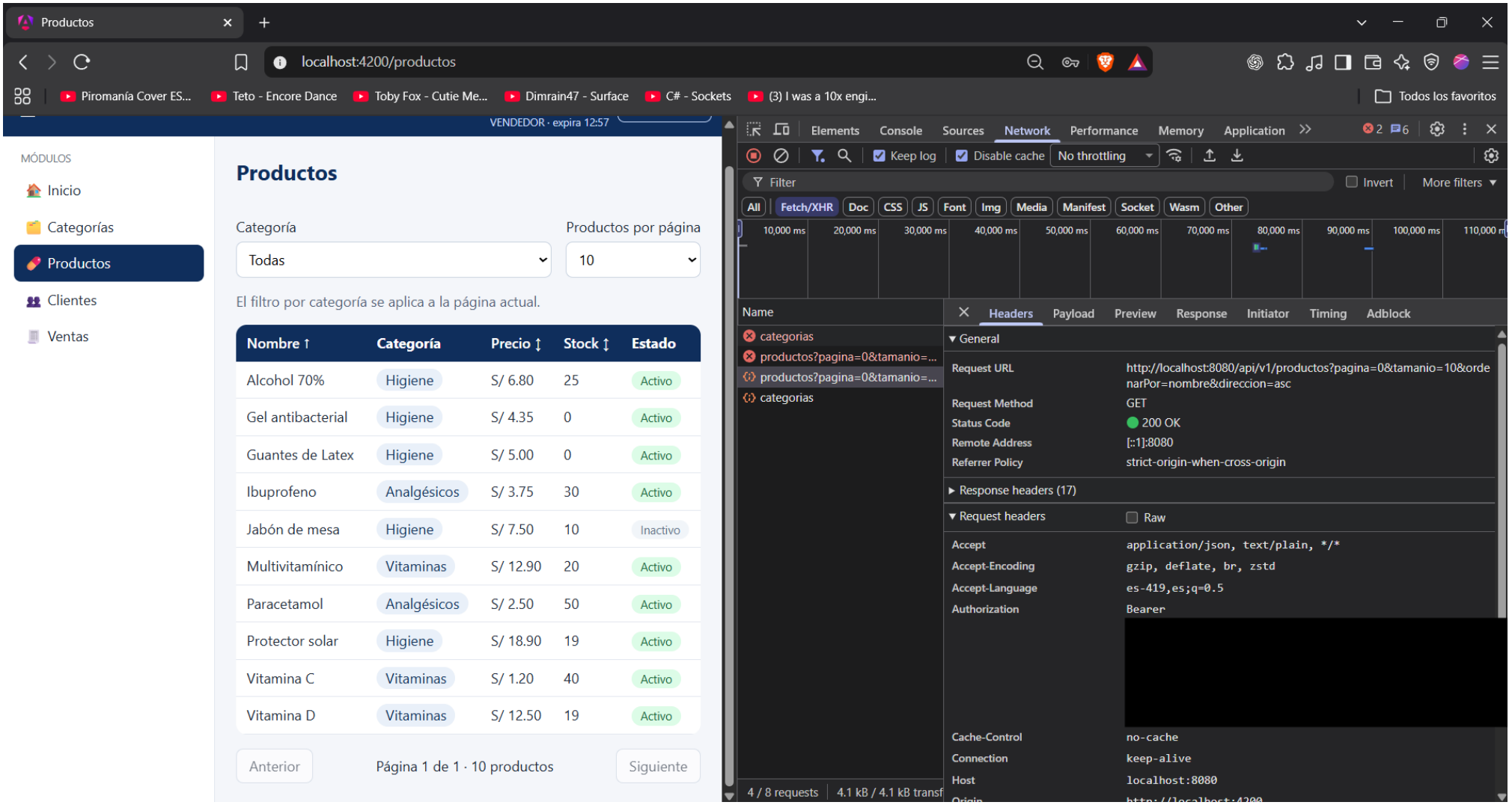
GET productos vuelve a responder 200; el catálogo está disponible y permanece el aviso independiente de Categorías.



Interceptores y conexión

E038 · I-02 · Recuperación completa del catálogo

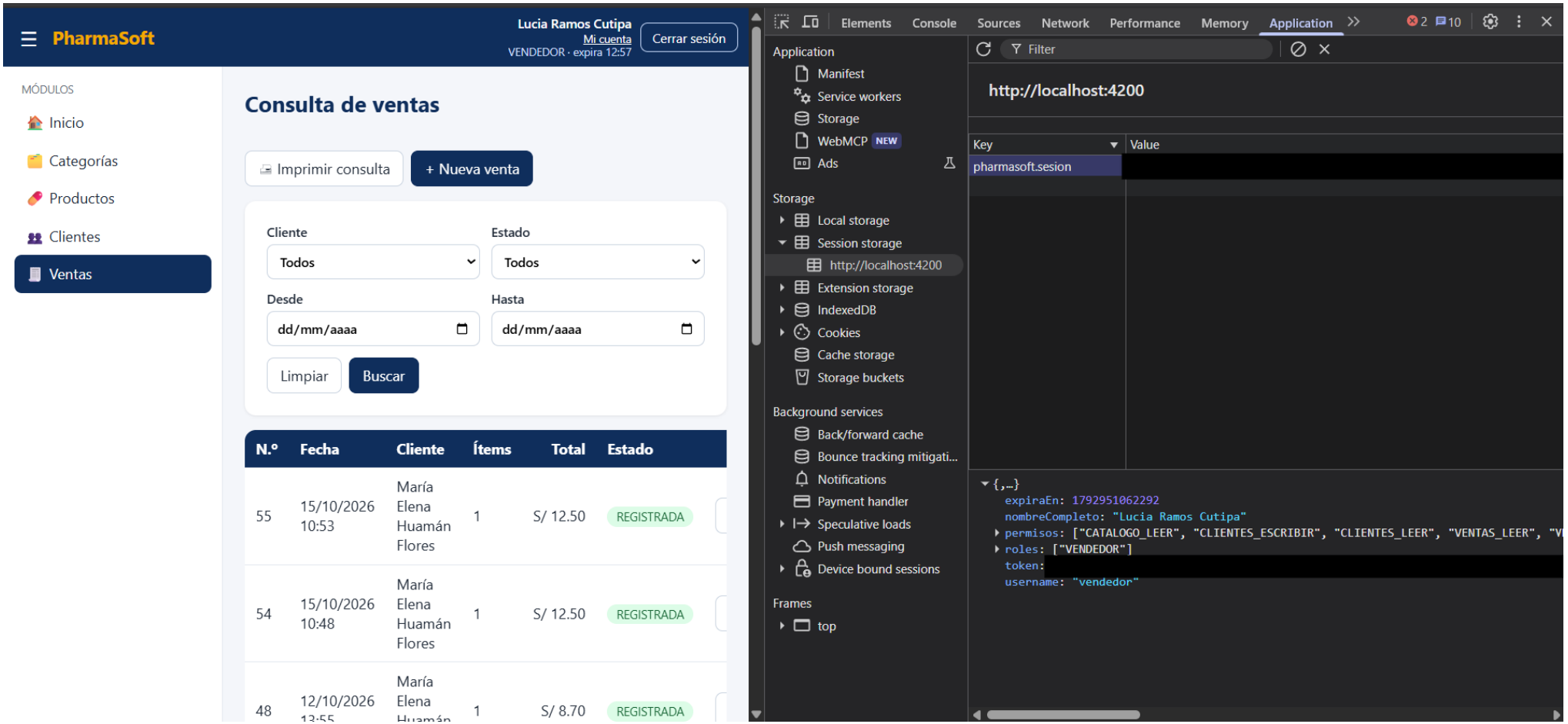
Después de recuperar también Categorías, el listado queda sin avisos de conexión y conserva la sesión.



Interceptores y conexión

E039 · I-03 · Alteración del token

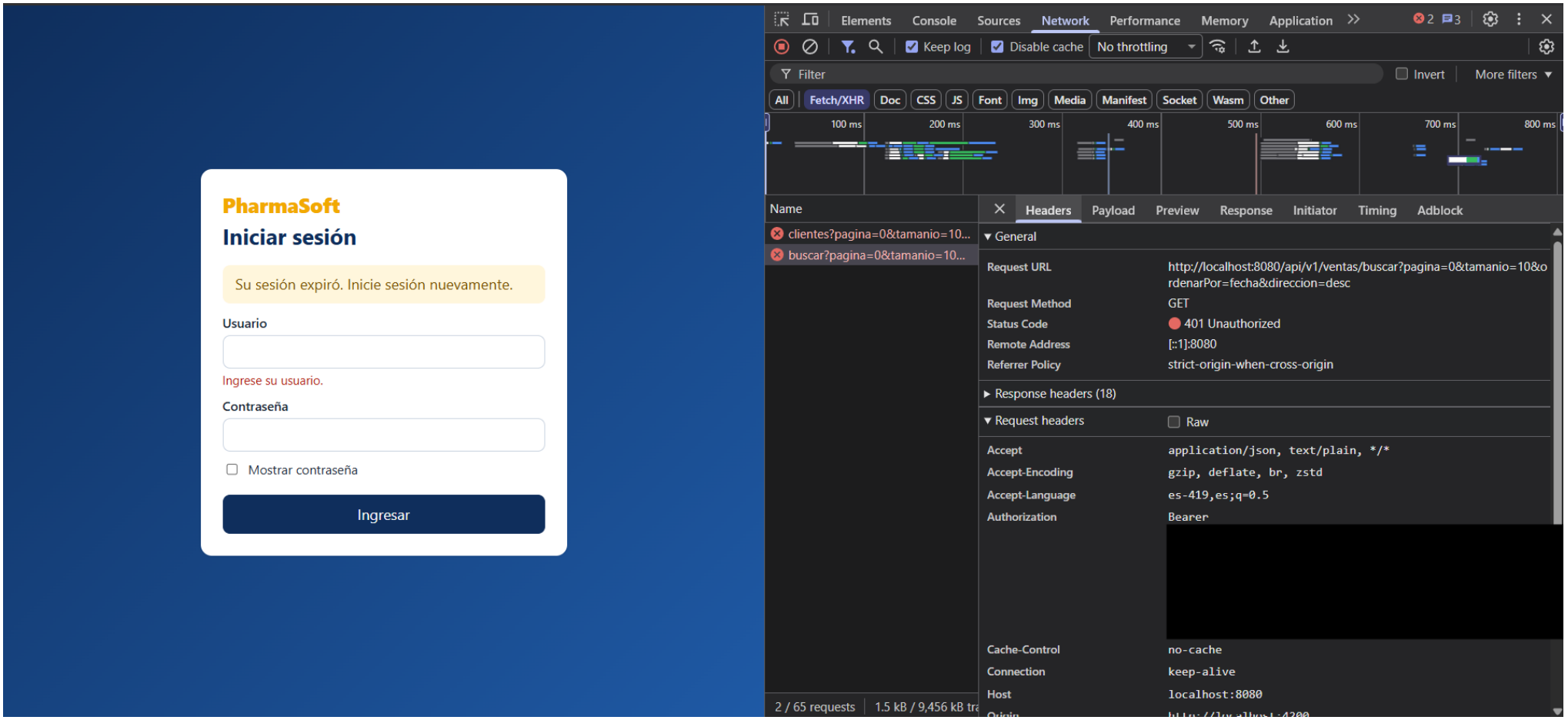
Se modifica la firma dentro de la sesión conservando el JSON y el vencimiento.



Interceptores y conexión

E040 · I-03 · Ventas rechaza el token

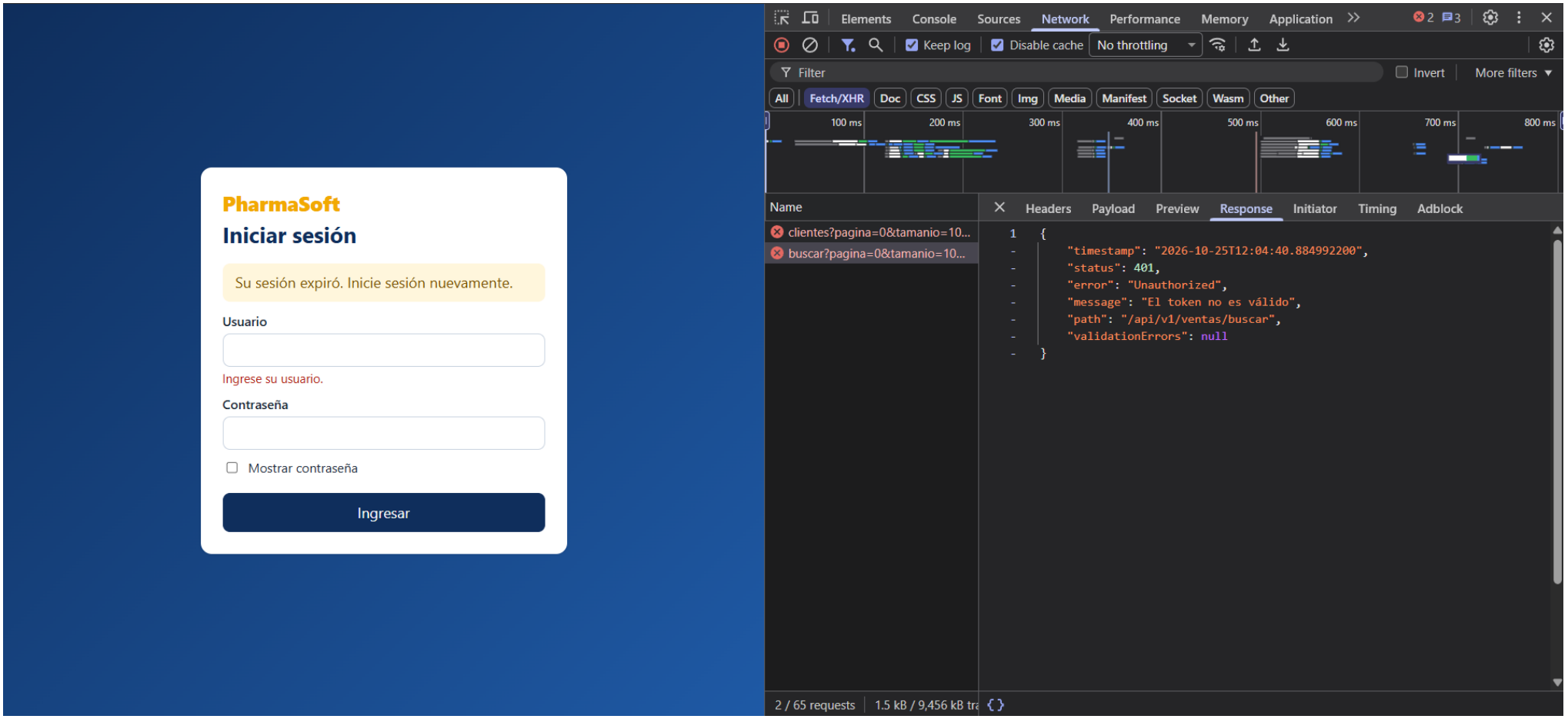
GET ventas/buscar responde 401 y la aplicación muestra Su sesión expiró.



Interceptores y conexión

E041 · I-03 · Respuesta de token inválido

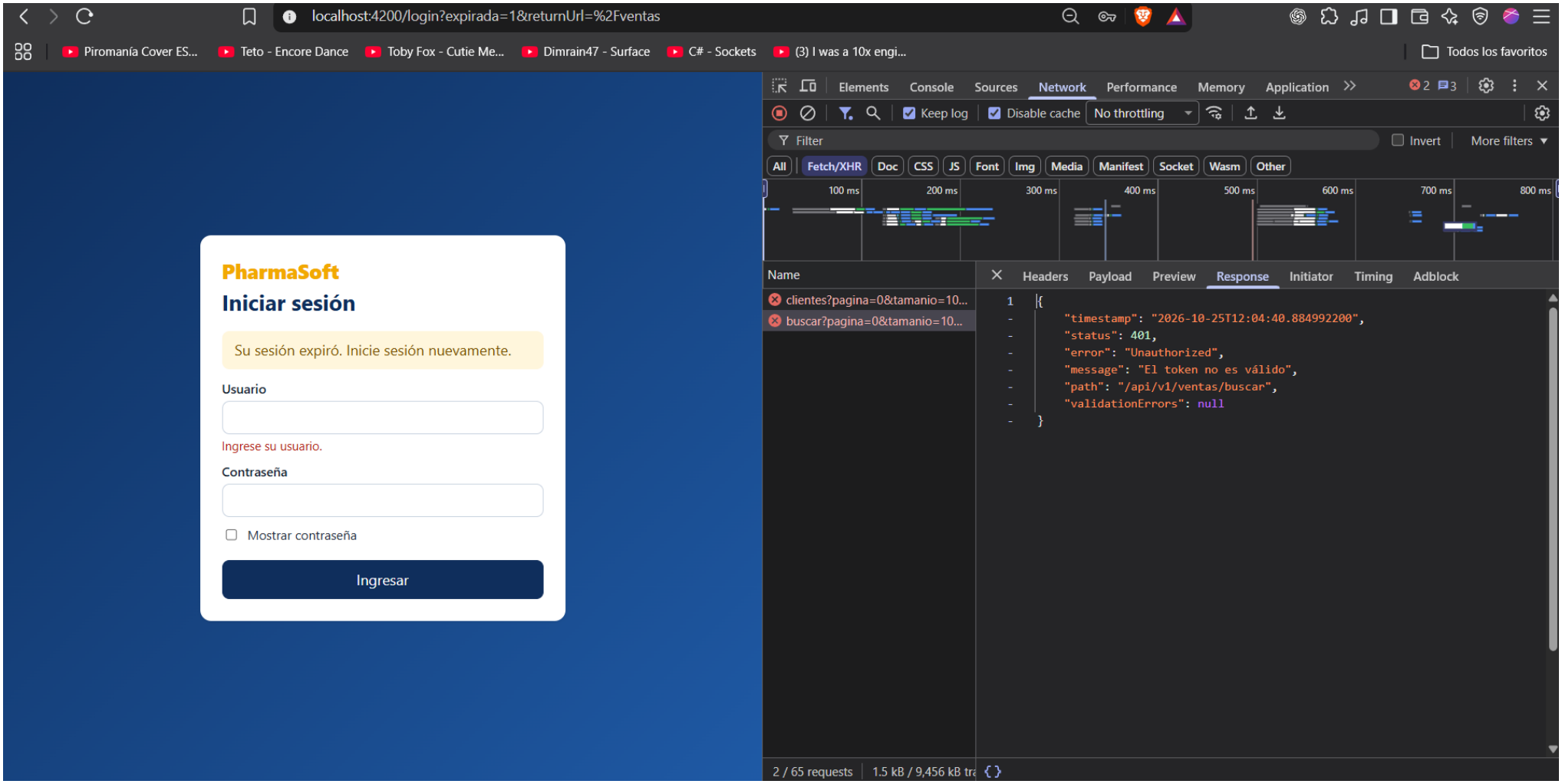
El cuerpo del 401 identifica El token no es válido en /api/v1/ventas/buscar.



Interceptores y conexión

E042 · I-03 · Retorno a Ventas conservado

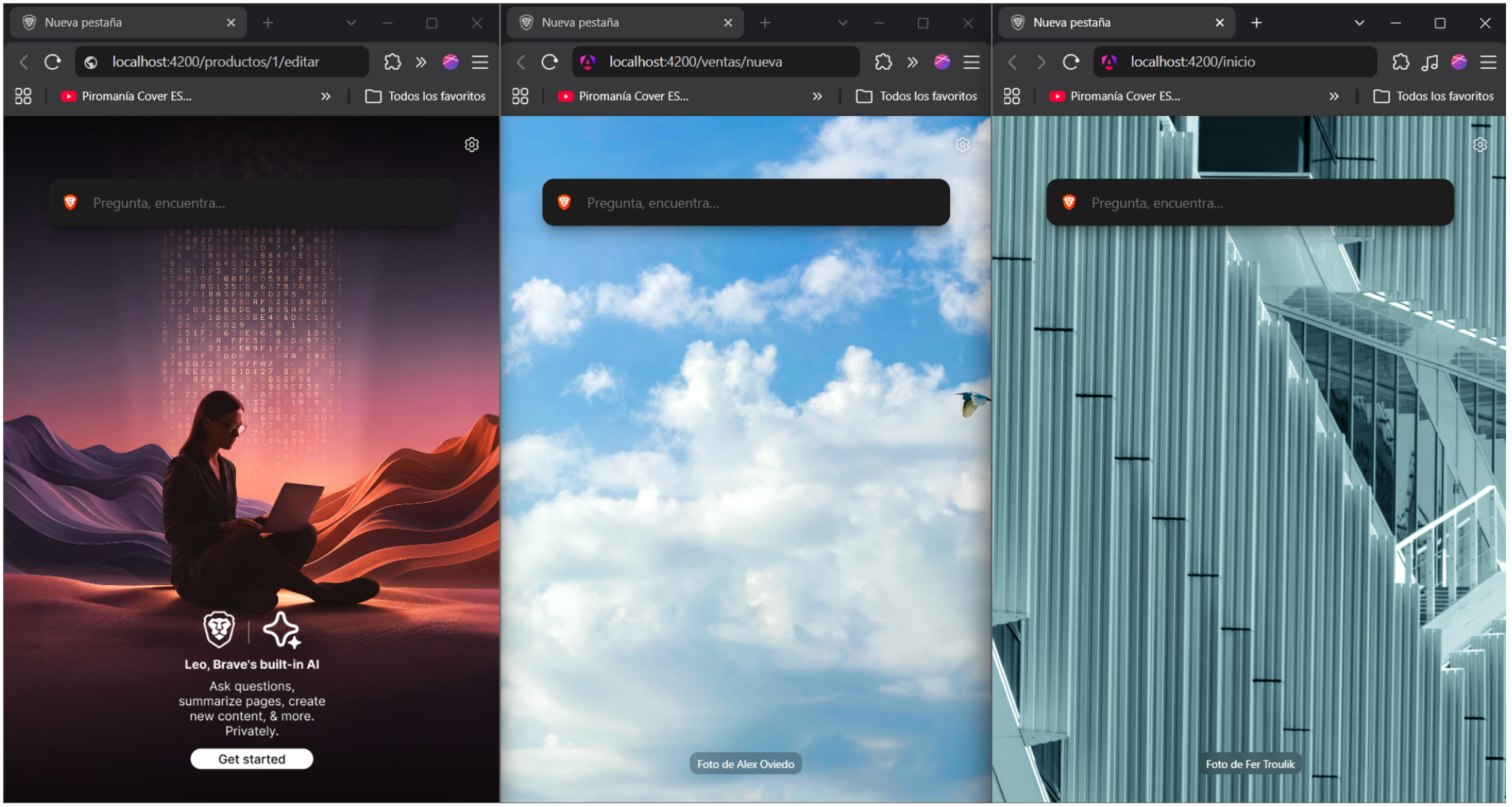
La URL del login conserva expirada=1 y returnUrl=%2Fventas.



Rutas protegidas

E043 · G-01 · Preparación de rutas anónimas

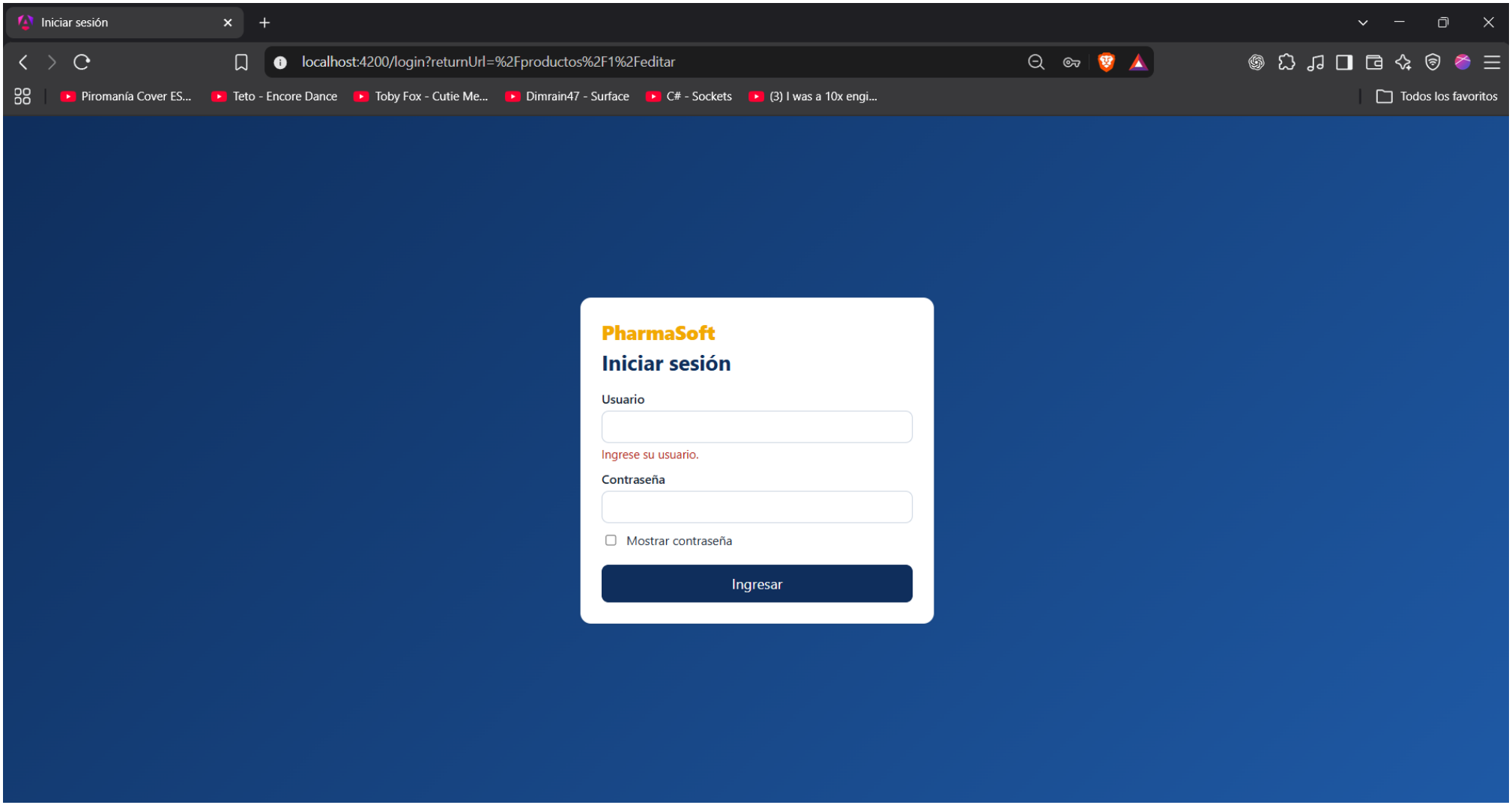
Se preparan las tres rutas directas en ventanas privadas antes de observar las redirecciones.



Rutas protegidas

E044 · G-01 · Edición requiere autenticación

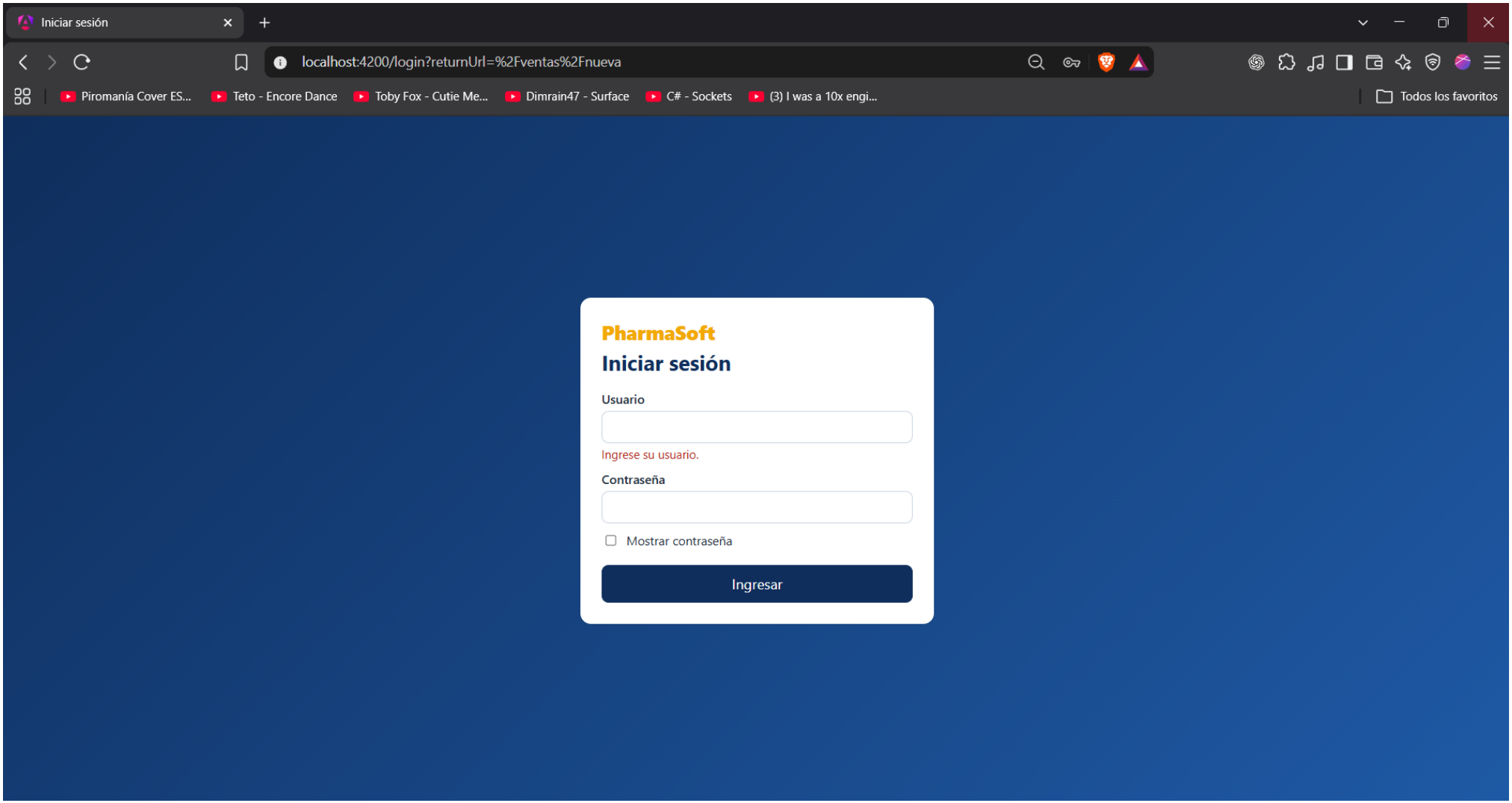
La ruta de edición sin sesión redirige al login con su returnUrl.



Rutas protegidas

E045 · G-01 · Nueva venta requiere autenticación

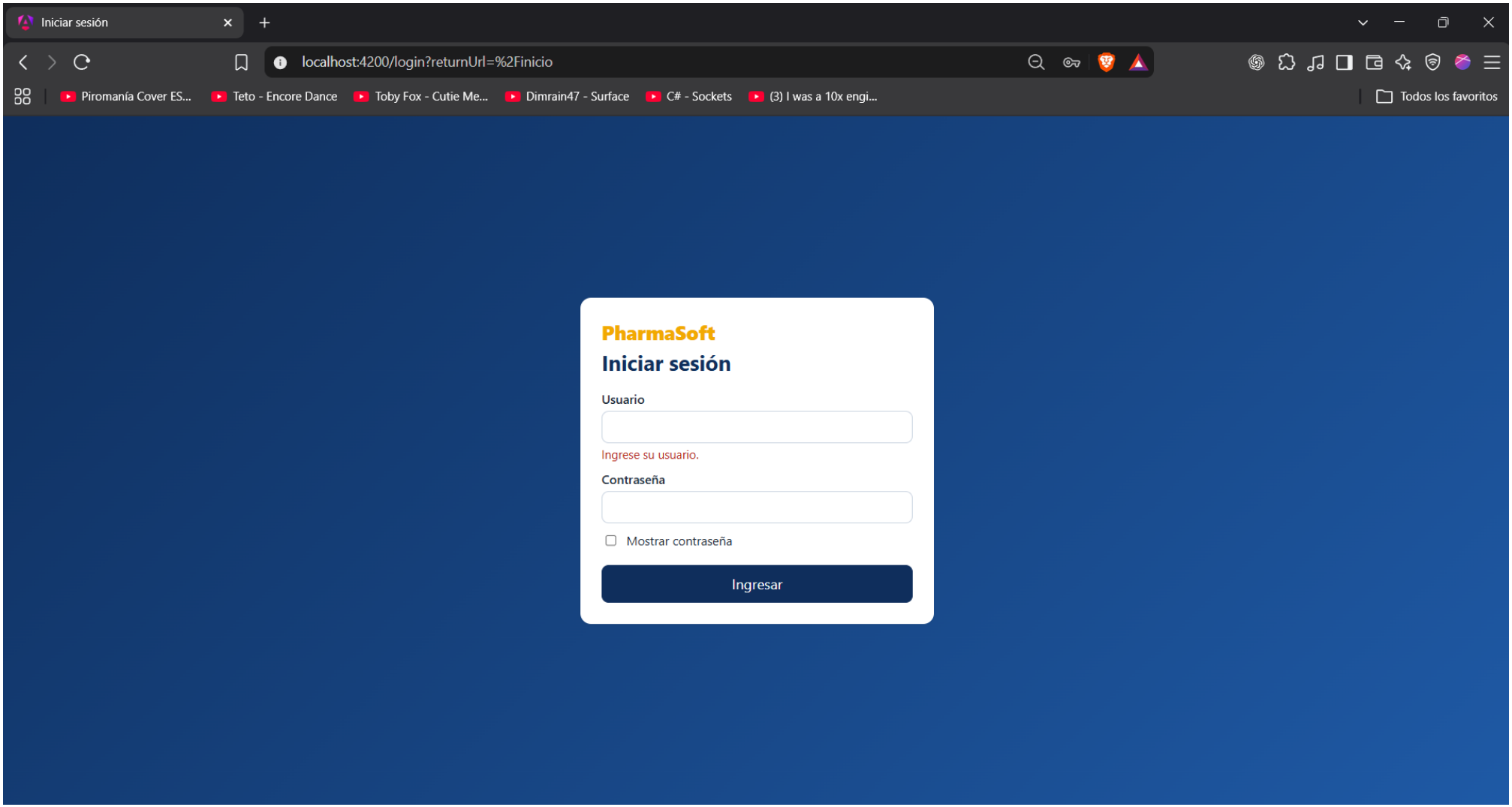
La ruta /ventas/nueva sin sesión redirige al login conservando el destino.



Rutas protegidas

E046 · G-01 · Inicio requiere autenticación

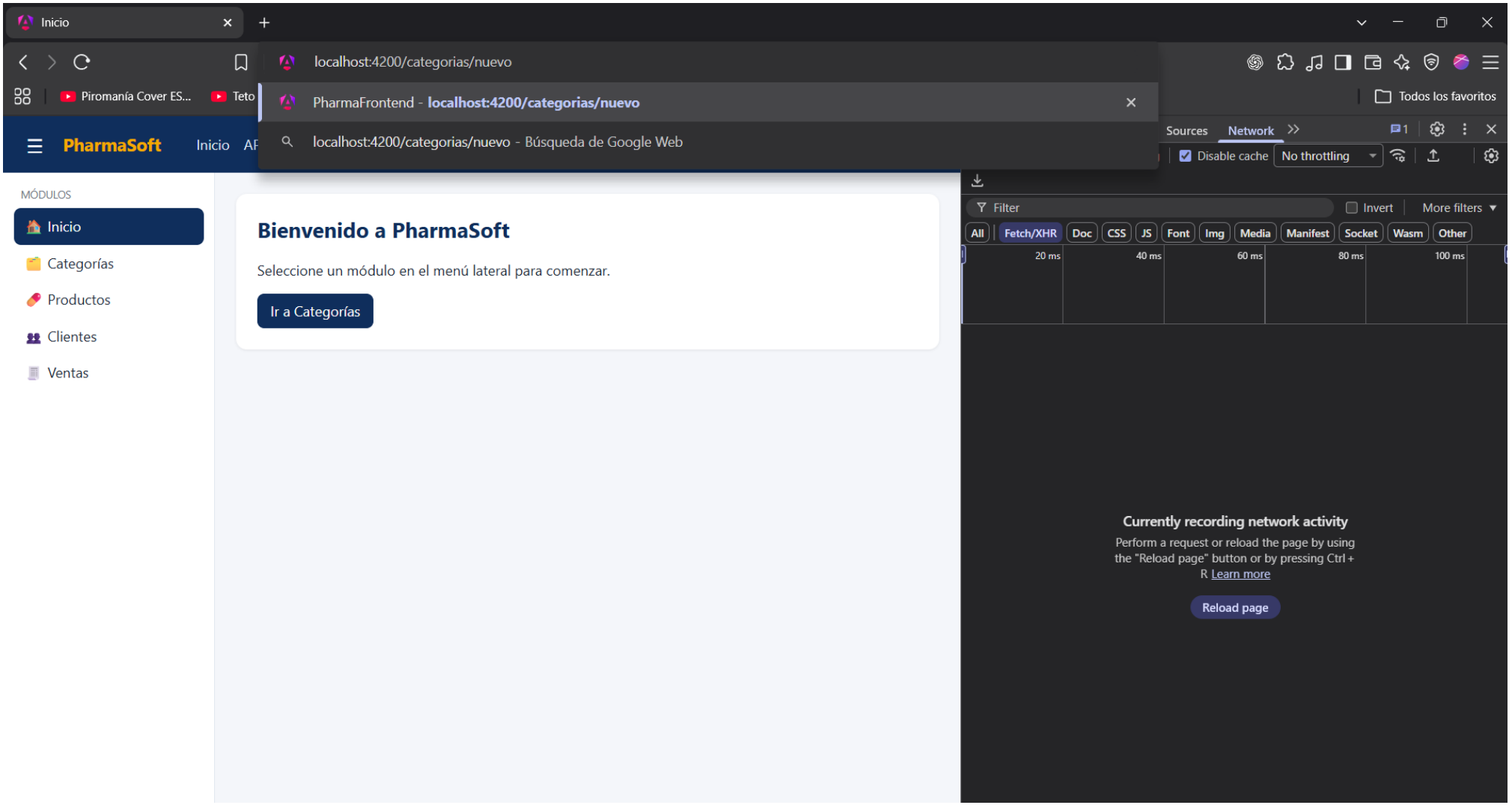
La ruta /inicio sin sesión redirige al login con returnUrl correspondiente.



Rutas protegidas

E047 · G-02 · Alta de categoría como vendedor

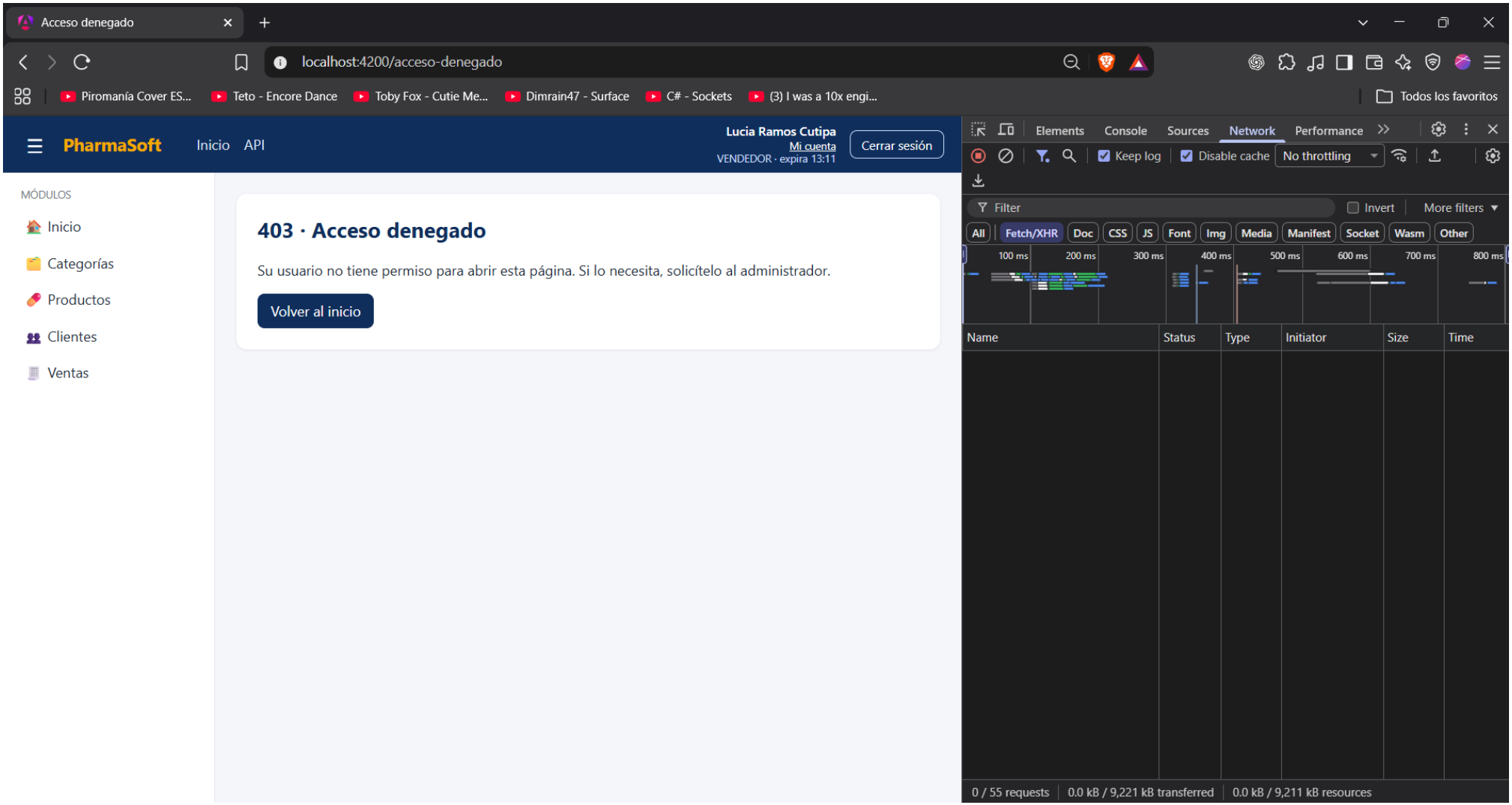
Se solicita /categorias/nuevo con una cuenta sin CATALOGO_ESCRIBIR.



Rutas protegidas

E048 · G-02 · Categoría protegida por permiso

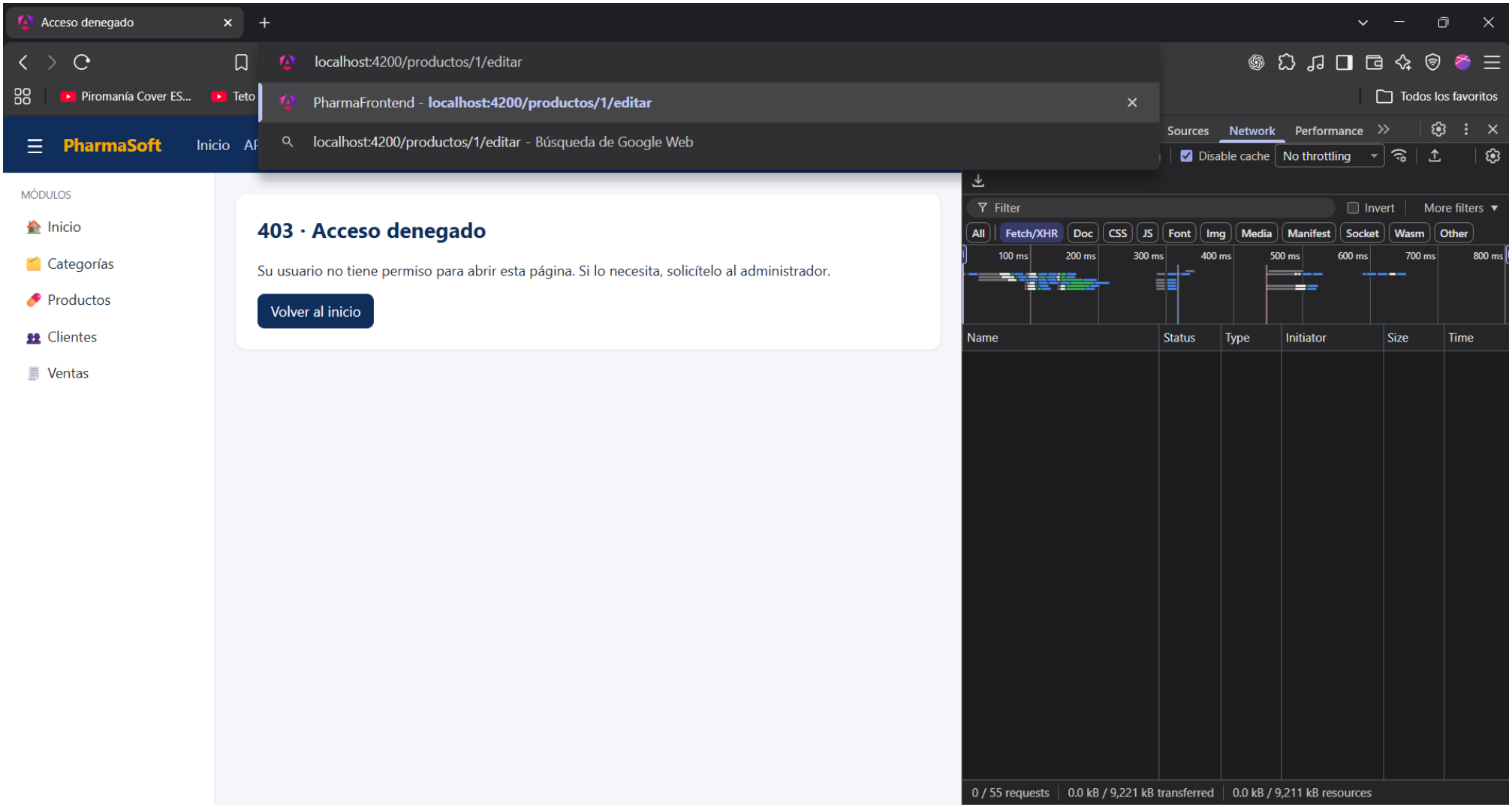
El guard muestra 403 · Acceso denegado dentro del layout del vendedor.



Rutas protegidas

E049 · G-02 · Edición de producto como vendedor

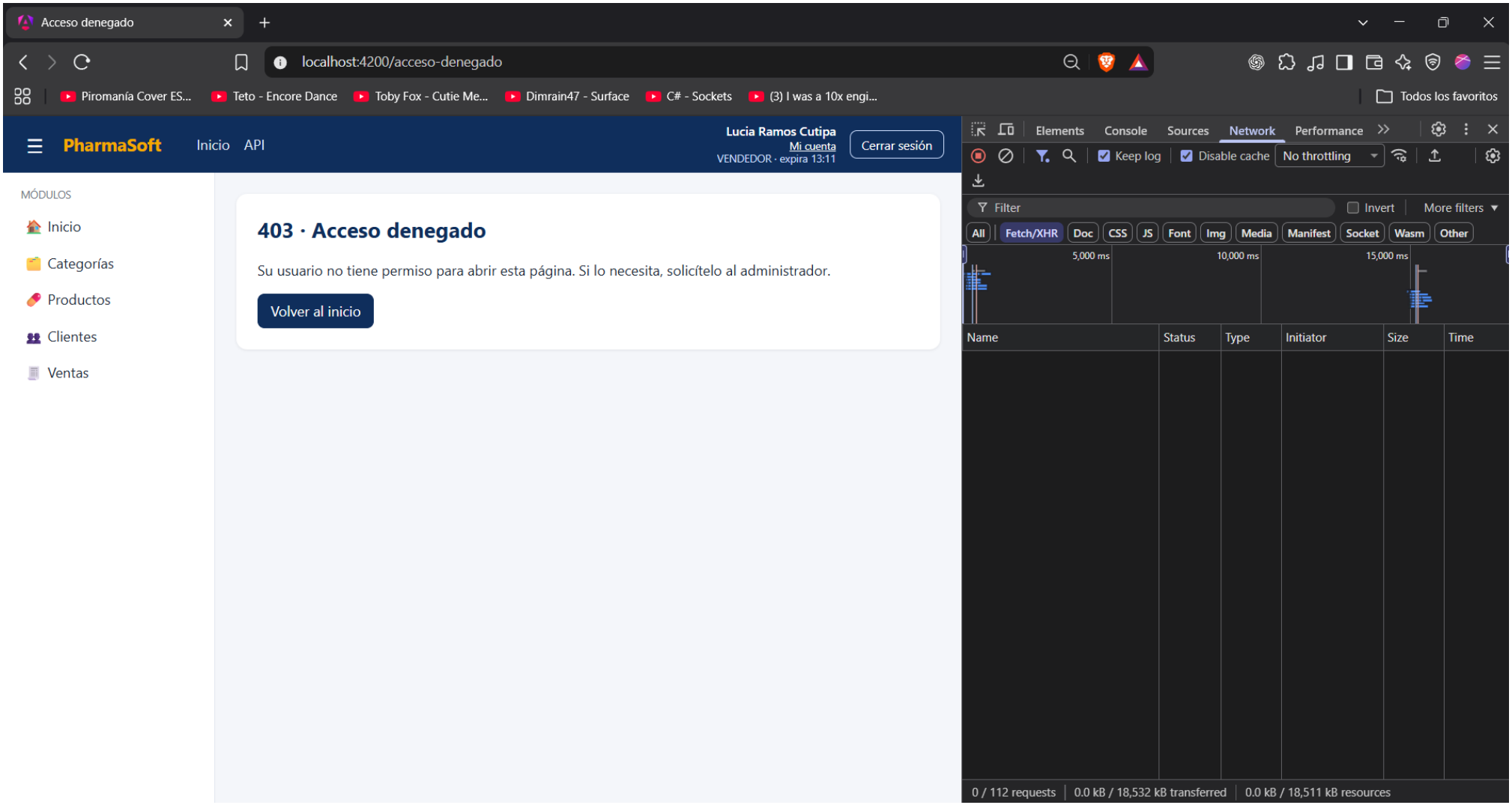
Se solicita /productos/1/editar con la misma cuenta de lectura.



Rutas protegidas

E050 · G-02 · Edición protegida por permiso

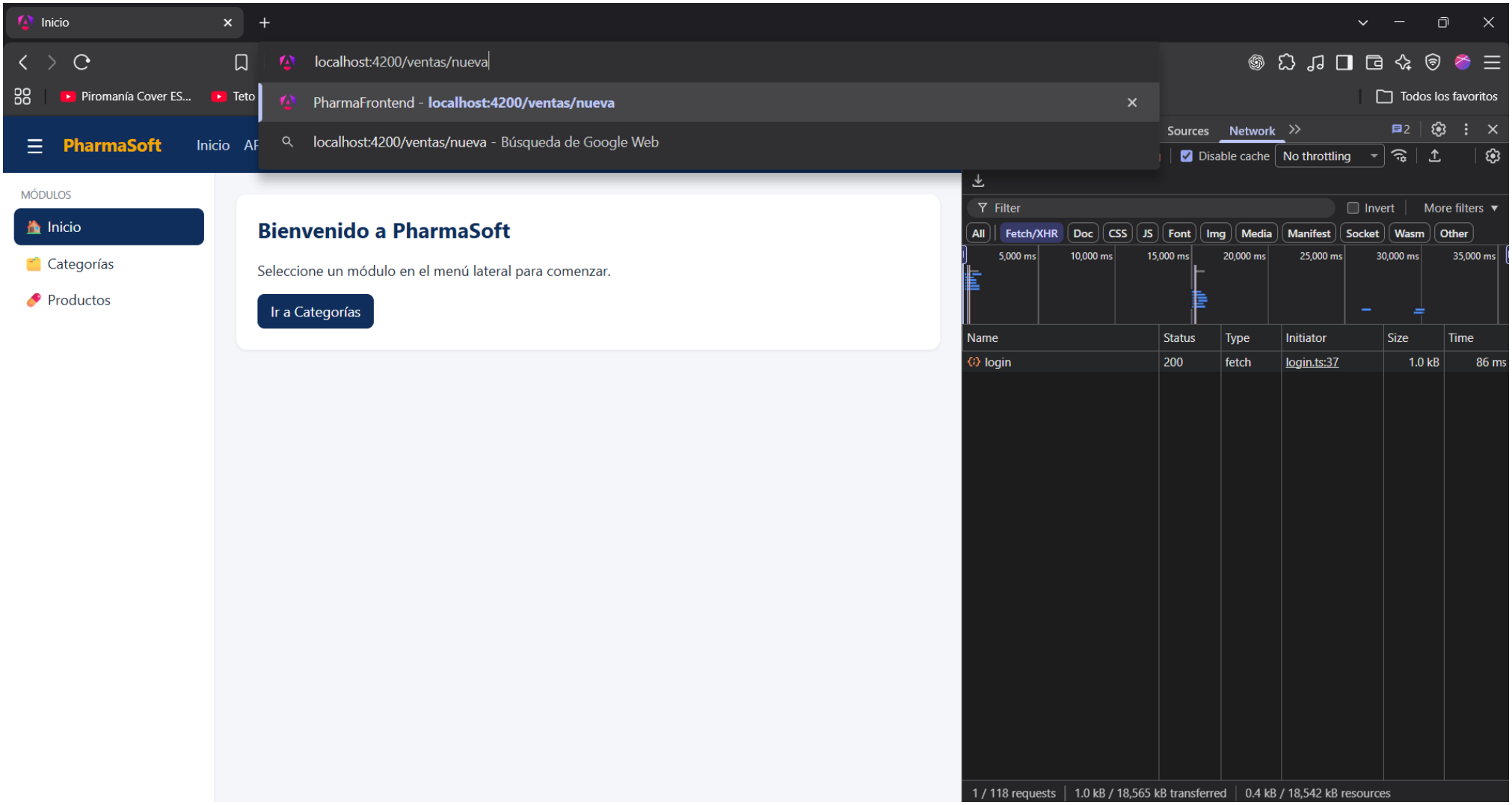
La navegación termina en Acceso denegado y conserva la sesión.



Rutas protegidas

E051 · G-02 · Nueva venta como almacén

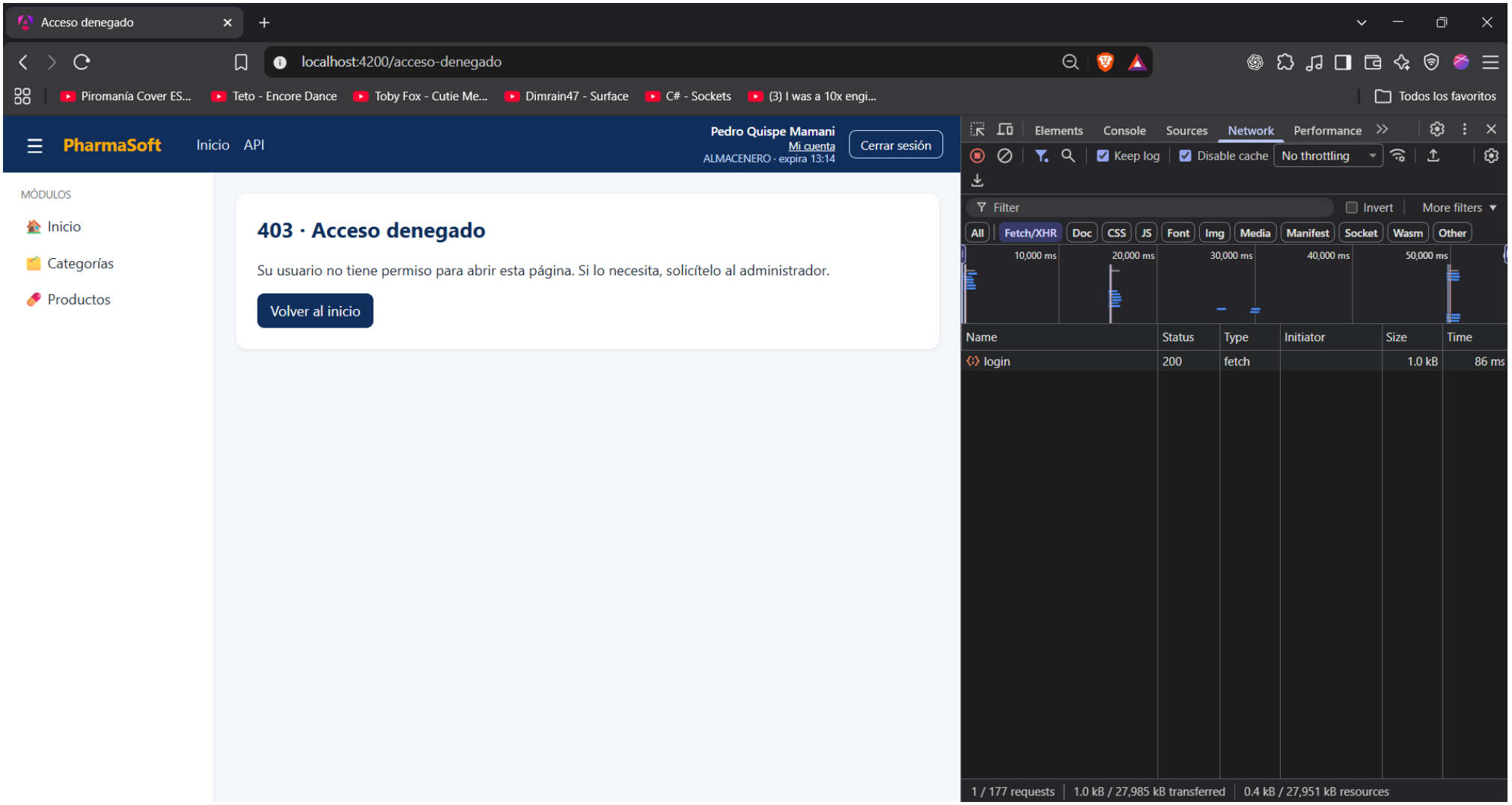
Se solicita /ventas/nueva con ALMACENERO, que no tiene VENTAS_REGISTRAR.



Rutas protegidas

E052 · G-02 · Ventas protegida por permiso

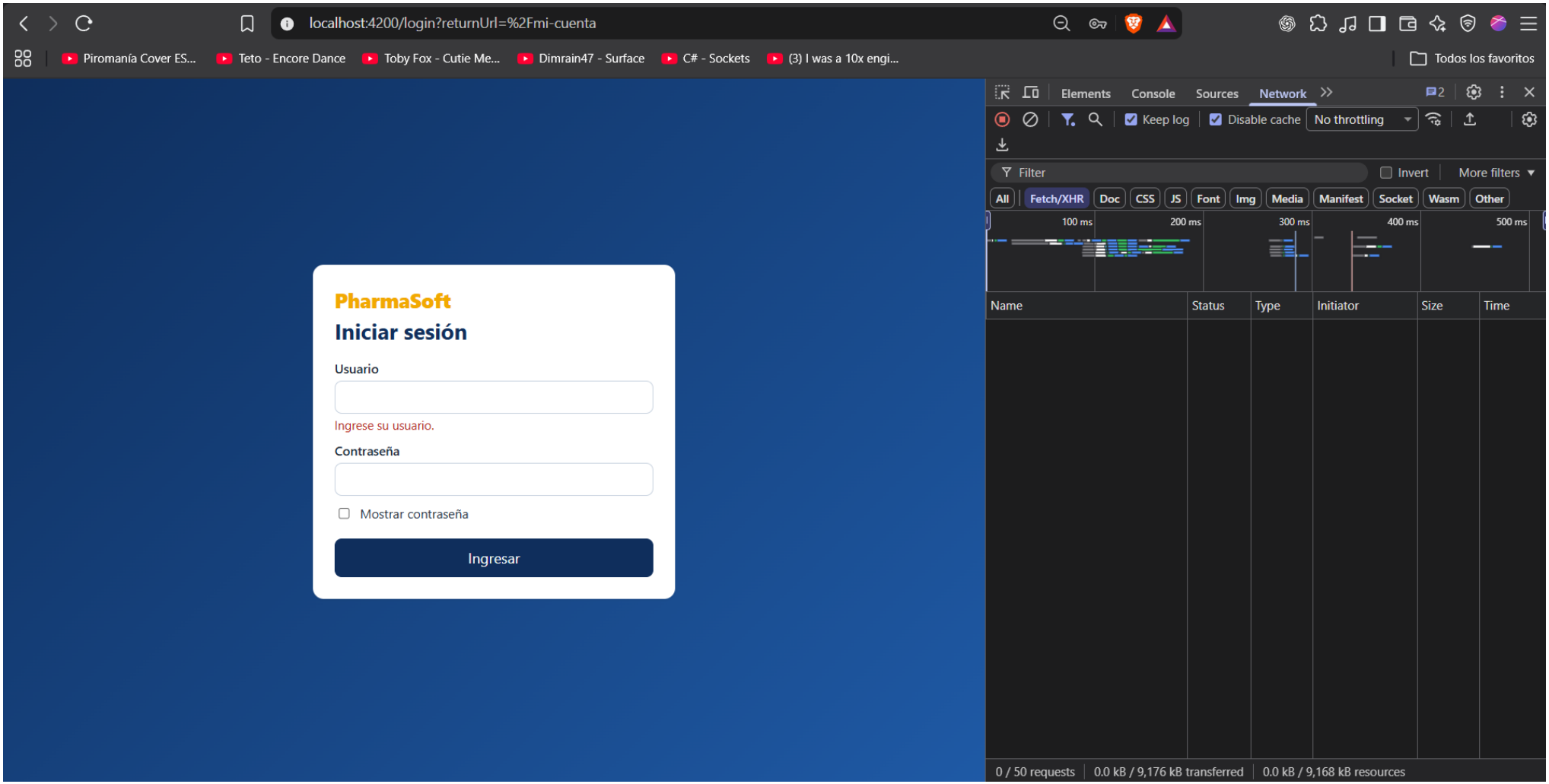
Almacén recibe Acceso denegado y conserva su menú de catálogo.



Rutas protegidas

E069 · G-03 · Mi cuenta sin sesión

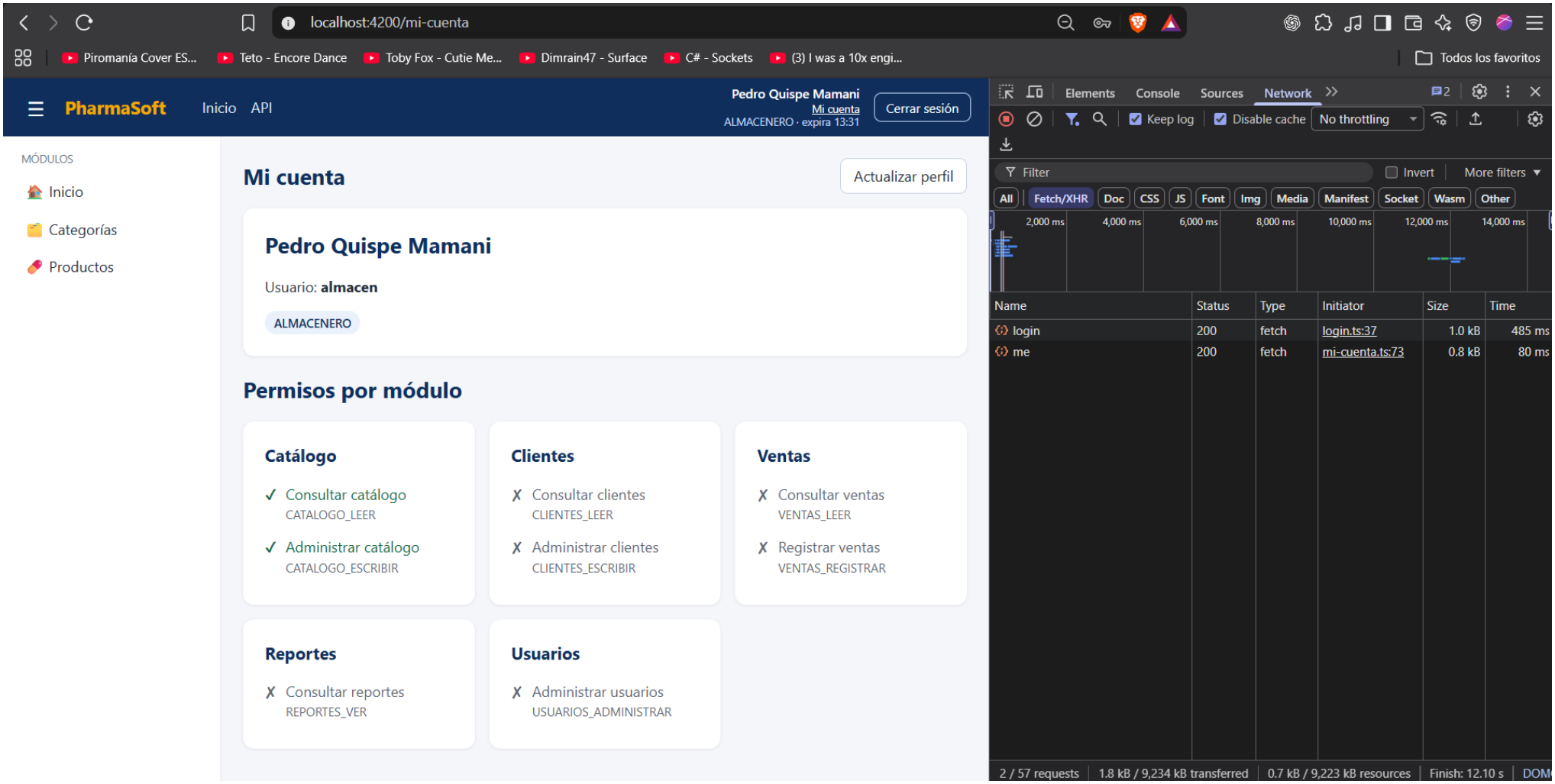
La navegación anónima redirige al login con returnUrl=%2Fmi-cuenta.



Rutas protegidas

E070 · G-03 · Mi cuenta para almacén

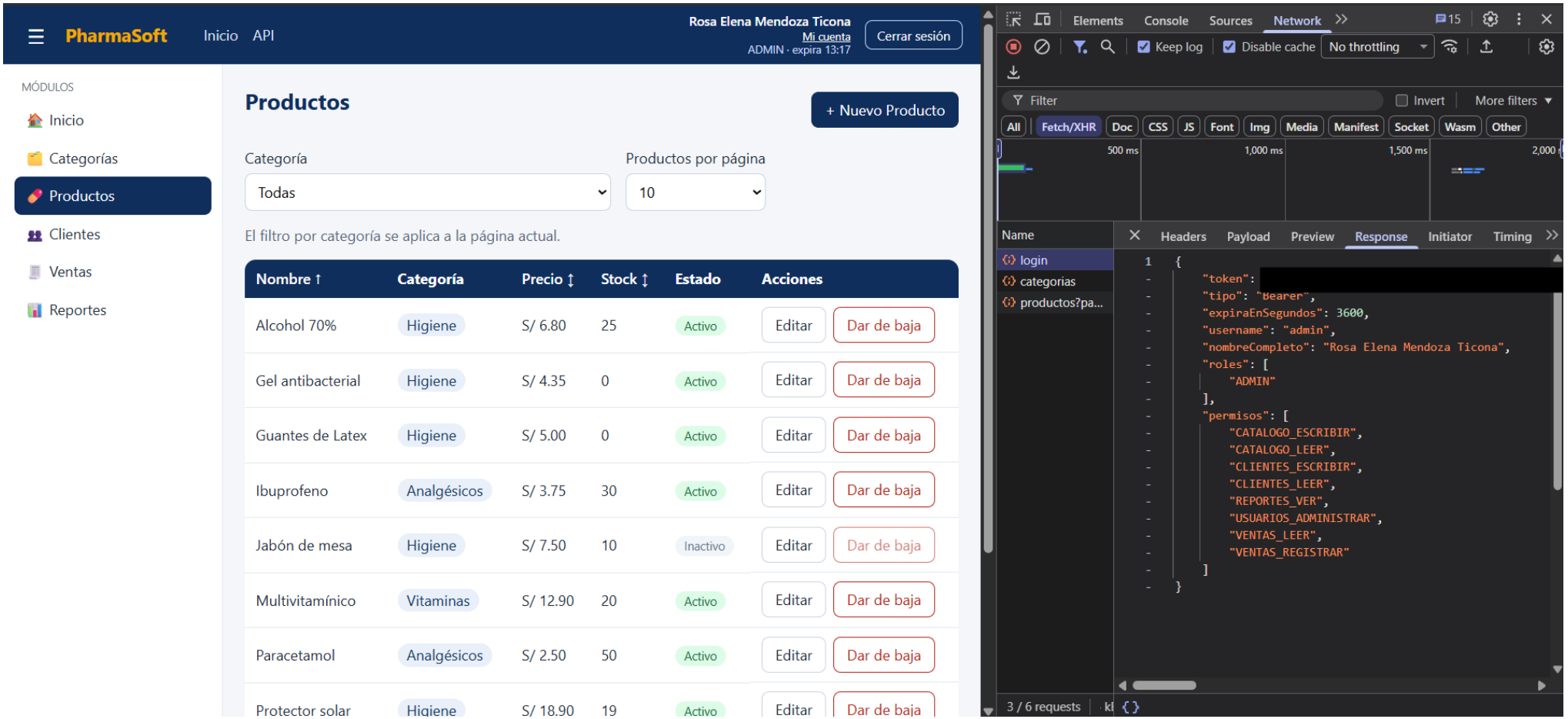
ALMACENERO accede a /mi-cuenta; GET auth/me responde 200 sin exigir permisos adicionales de módulo.



Menú, roles y cambios de permisos

E053 · M-01 · Menú y acciones de ADMIN

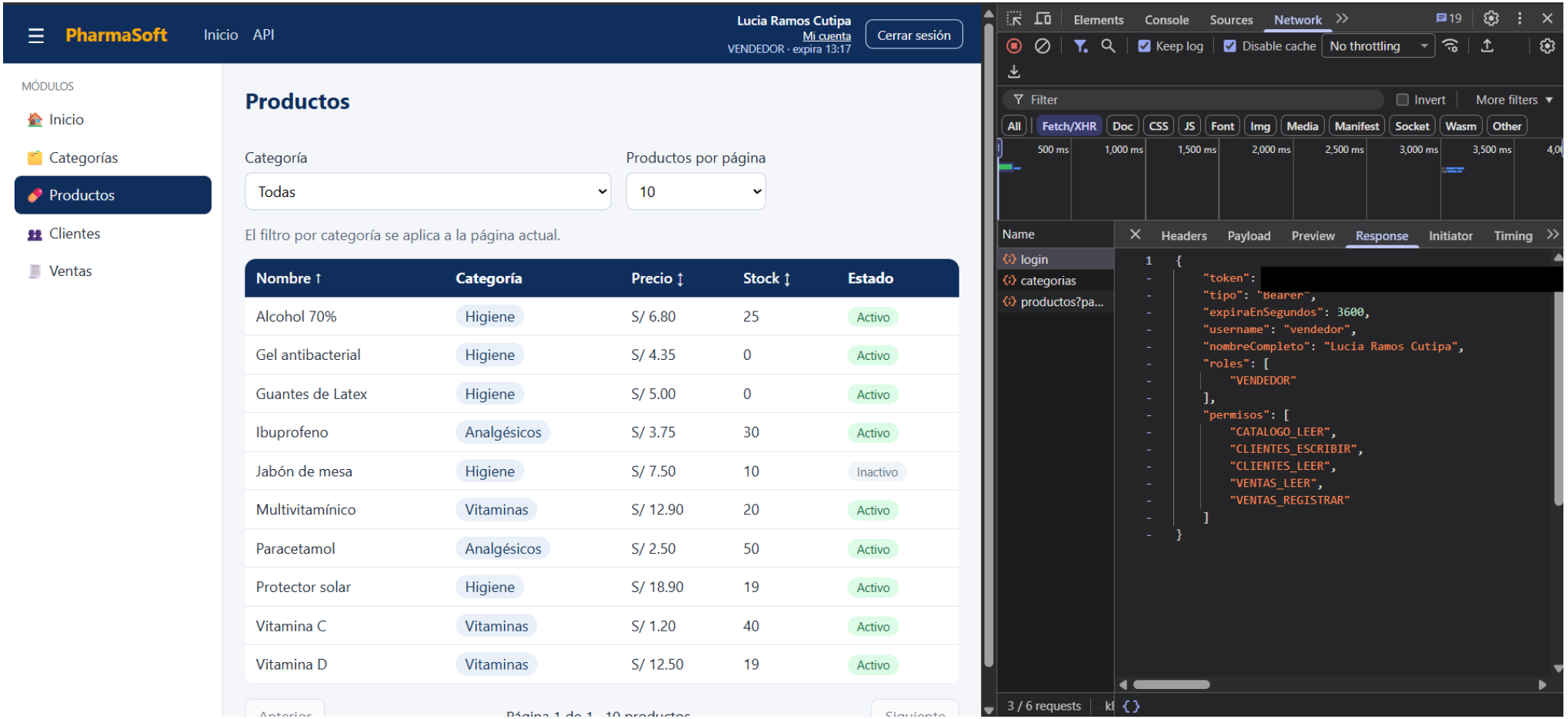
Menú completo, Reportes y controles de escritura del catálogo.



Menú, roles y cambios de permisos

E054 · M-01 · Menú y acciones de VENDEDOR

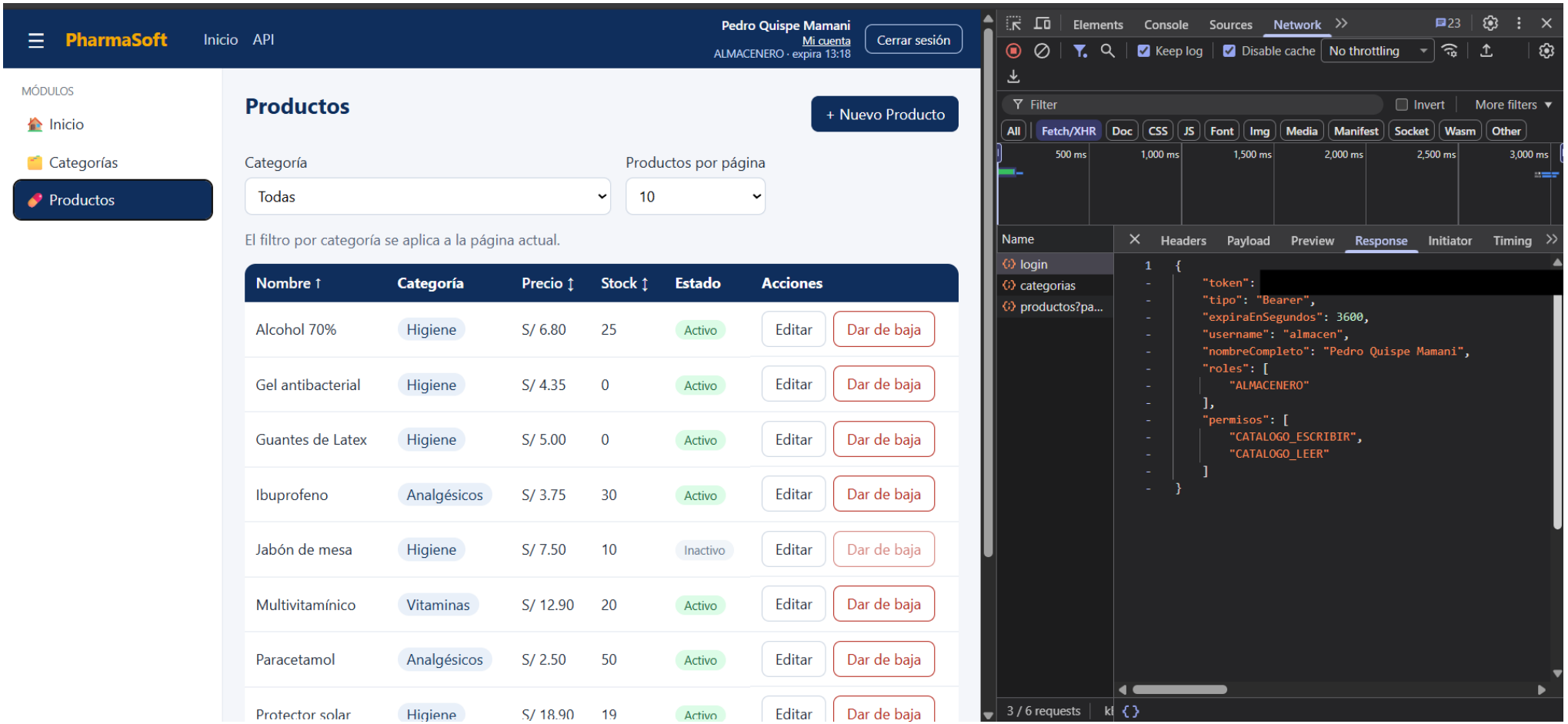
Catálogo de lectura, Clientes y Ventas; sin acciones de escritura de productos.



Menú, roles y cambios de permisos

E055 · M-01 · Menú y acciones de ALMACENERO

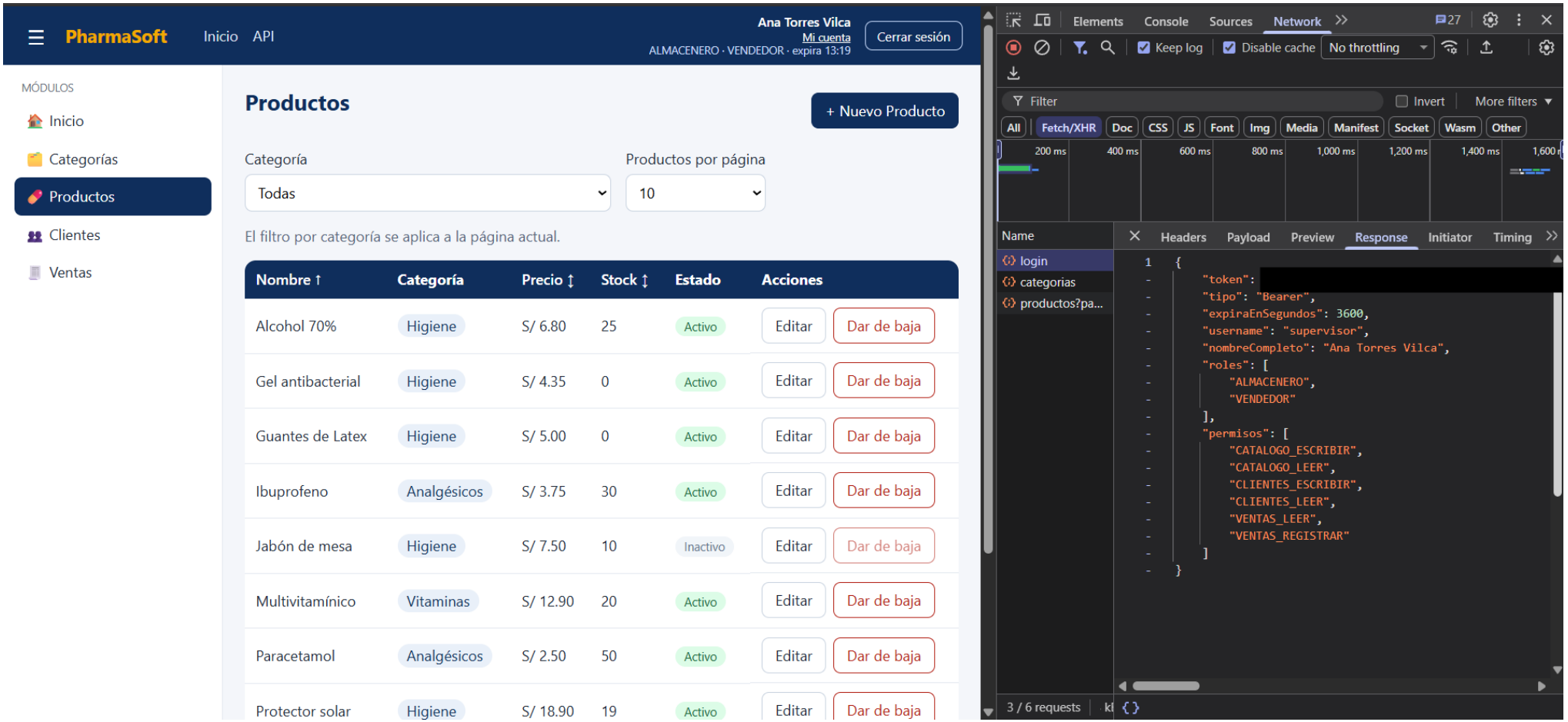
Inicio y catálogo editable; no aparecen Clientes, Ventas ni Reportes.



Menú, roles y cambios de permisos

E056 · M-01 · Menú y acciones de supervisor

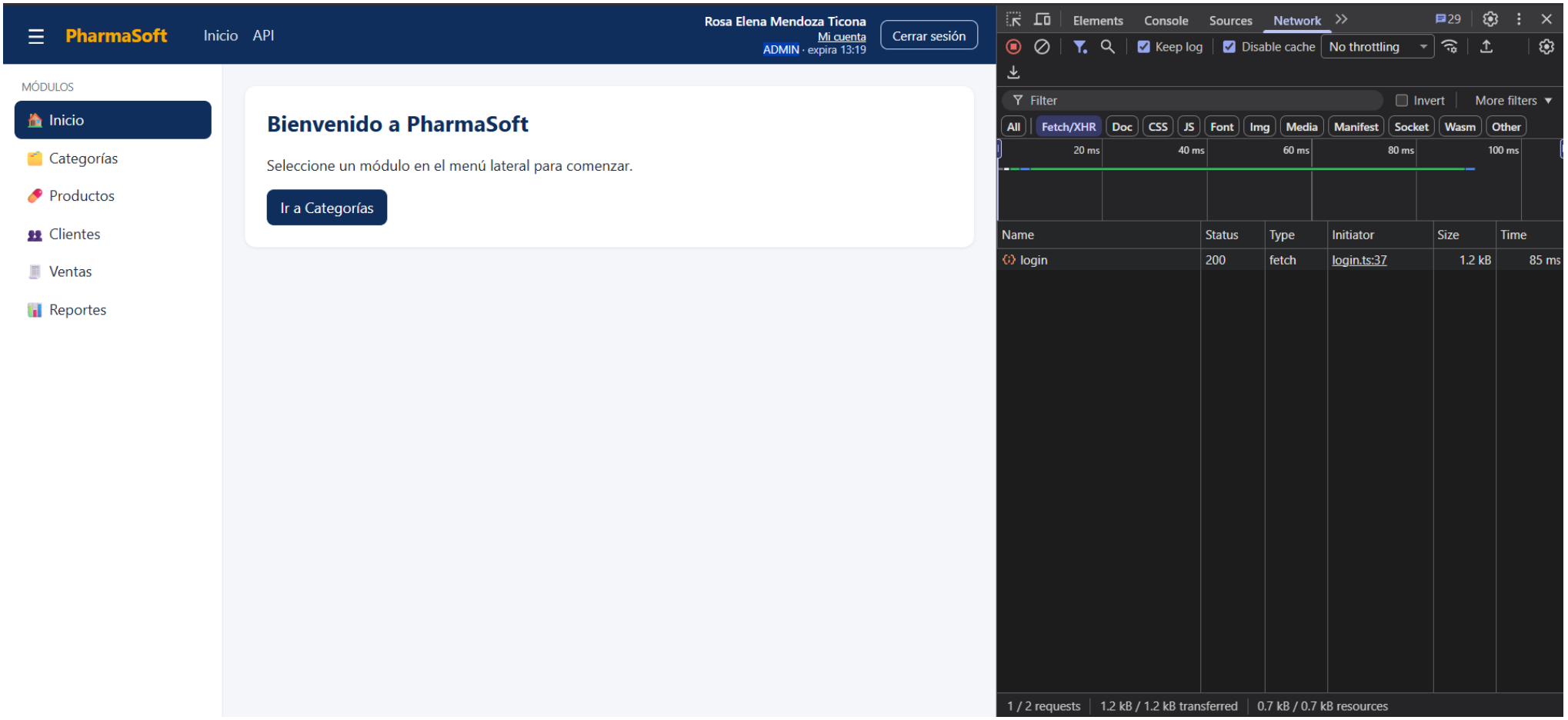
La unión ALMACENERO y VENDEDOR permite editar catálogo y acceder a Ventas, sin Reportes.



Menú, roles y cambios de permisos

E057 · M-02 · Estado inicial ADMIN

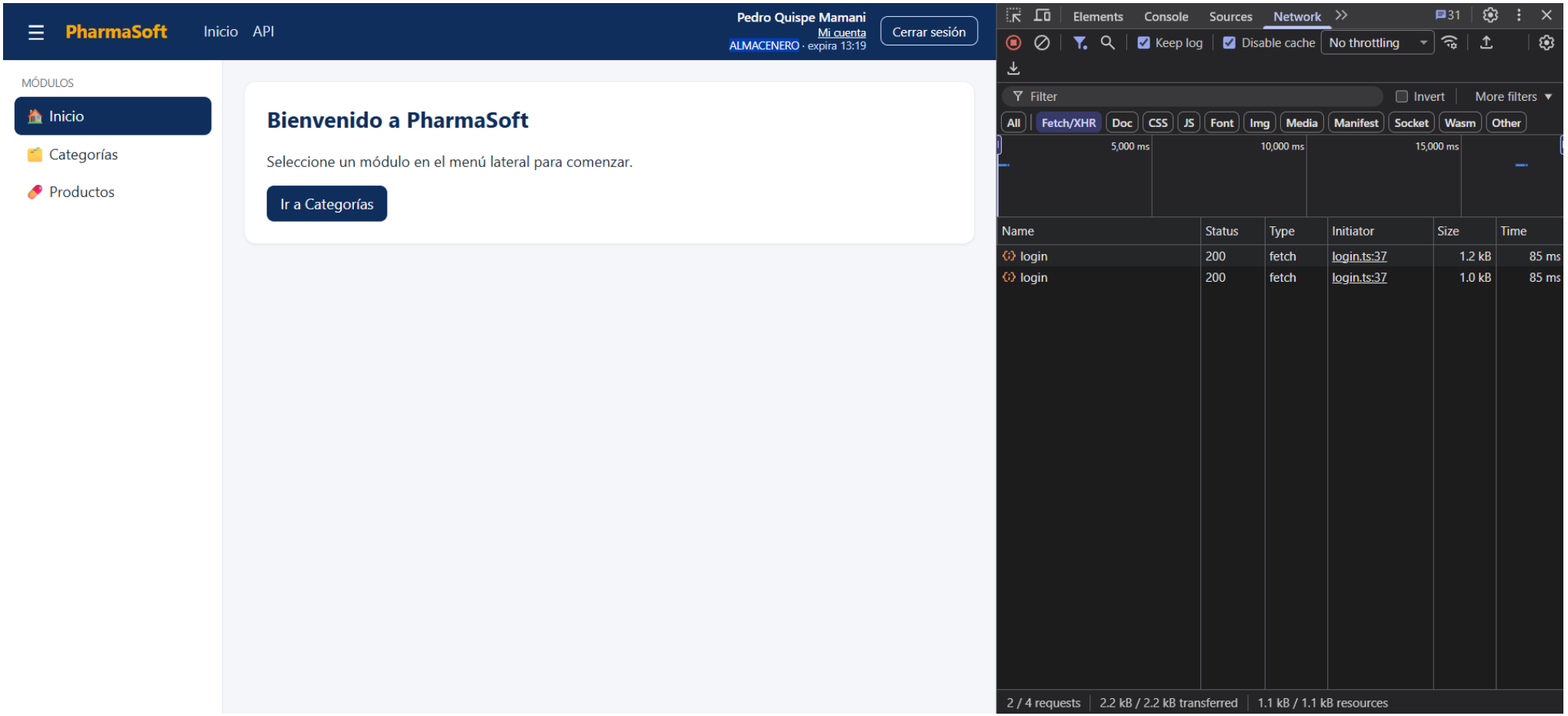
La misma pestaña muestra el menú administrativo antes de cerrar la sesión.



Menú, roles y cambios de permisos

E058 · M-02 · Cambio a ALMACENERO

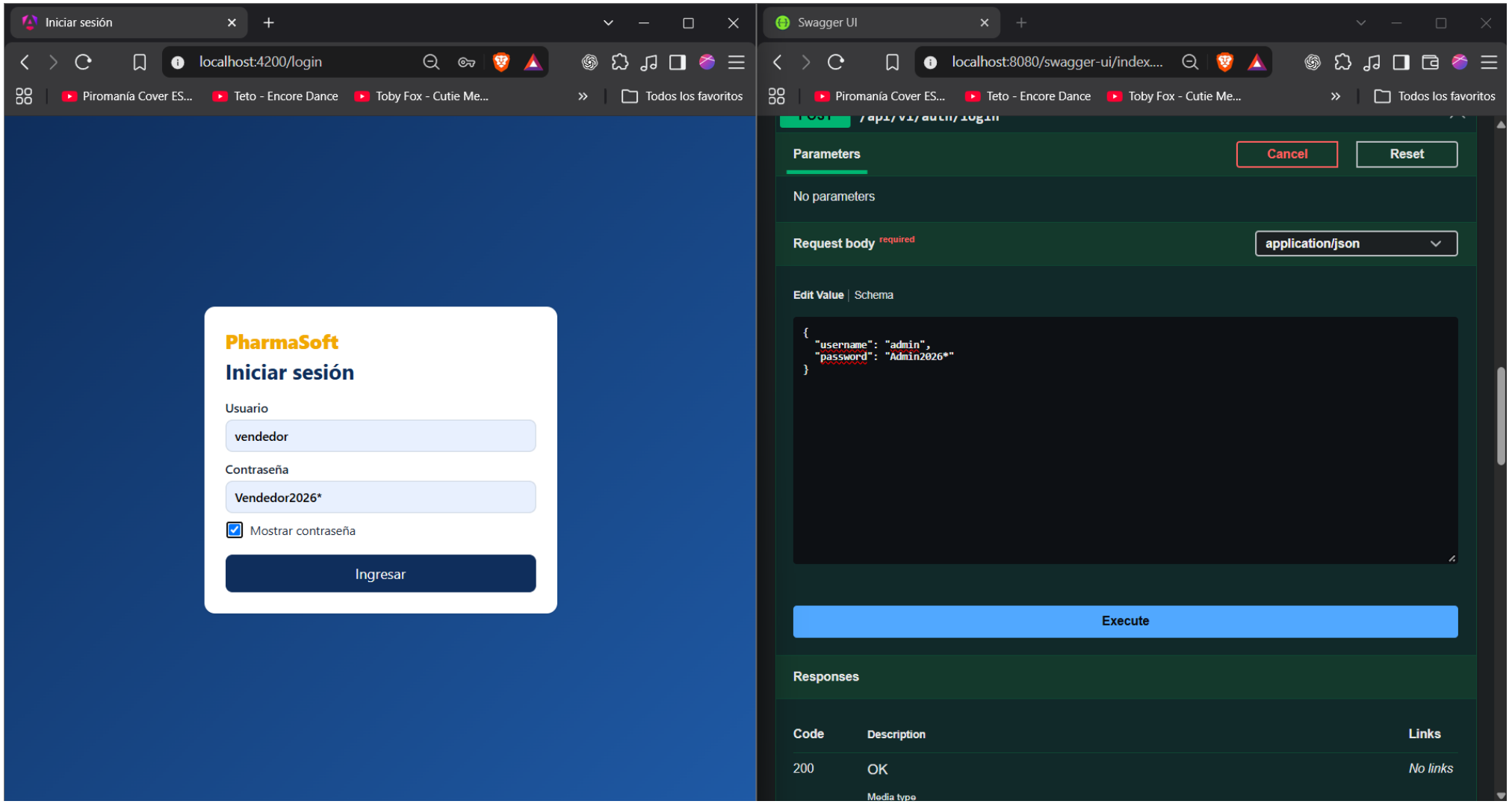
Al entrar como almacén se retiran los módulos no permitidos y cambia la identidad sin F5.



Menú, roles y cambios de permisos

E076 · M-03 · Preparación de cuentas separadas

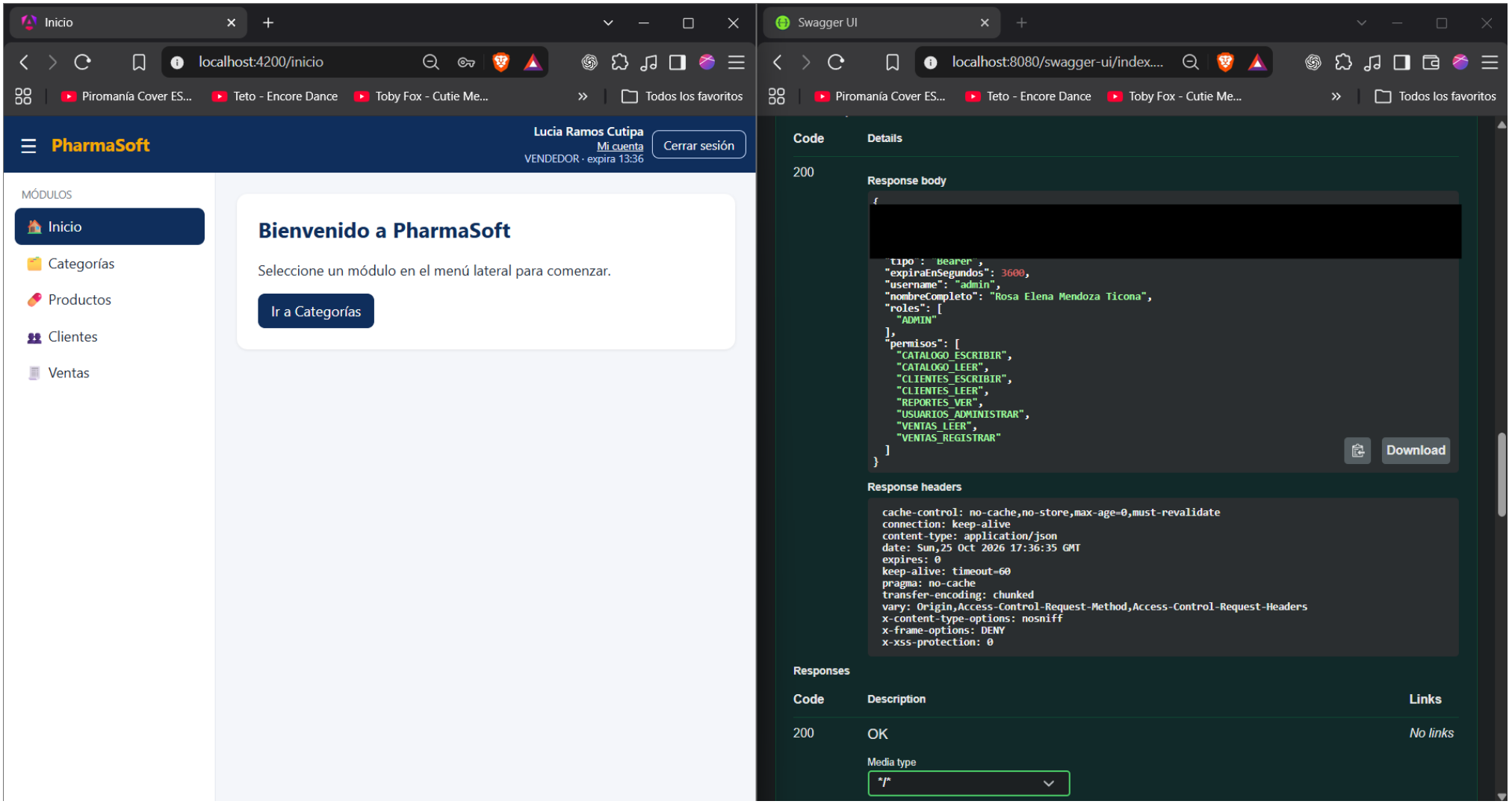
Se prepara la sesión vendedor y el acceso administrativo de Swagger en ventanas independientes.



Menú, roles y cambios de permisos

E077 · M-03 · Estado inicial de la prueba

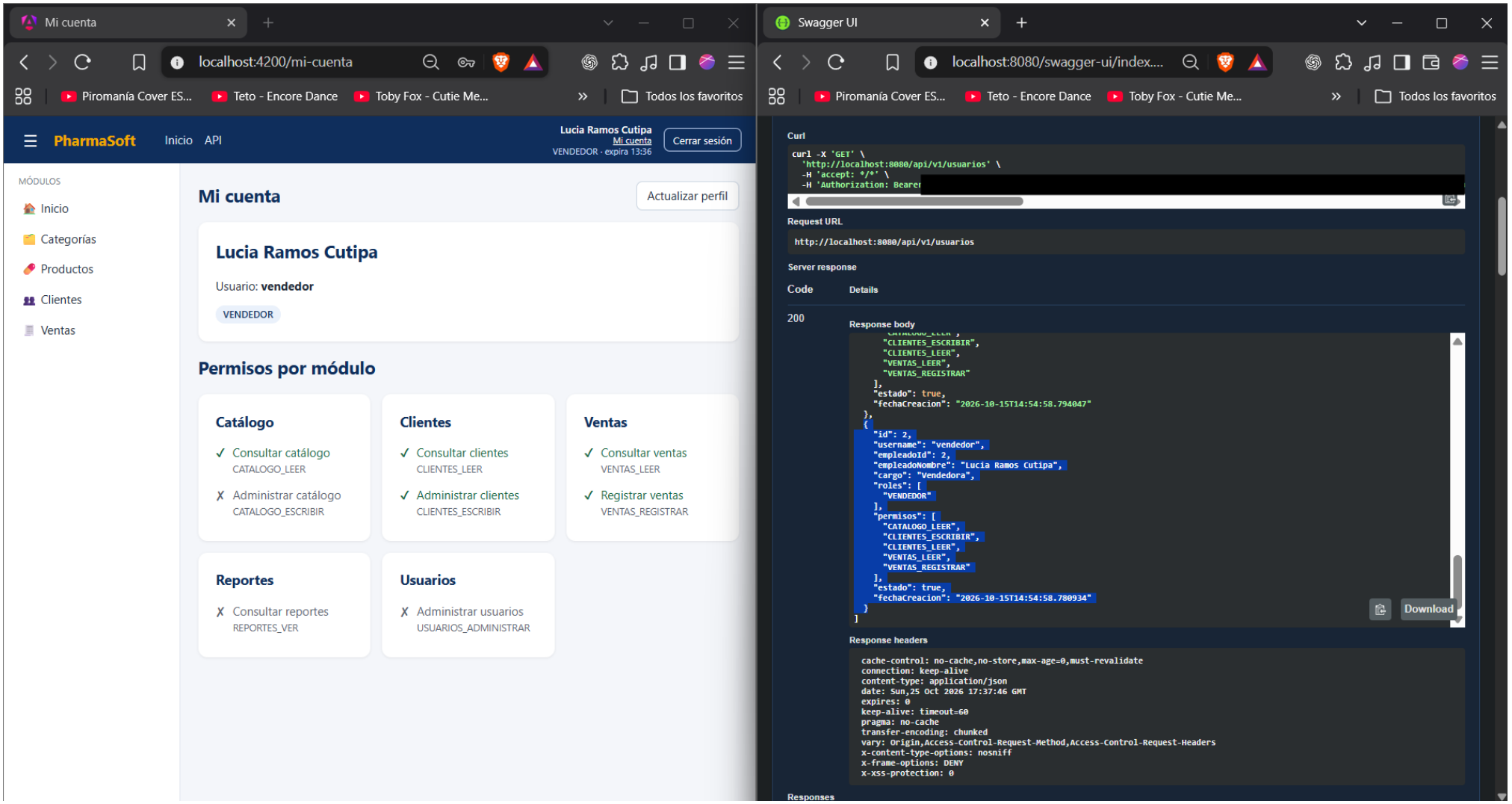
La SPA conserva vendedor; Swagger autentica al administrador para modificar roles en el servidor.



Menú, roles y cambios de permisos

E078 · M-03 · Identificación del usuario

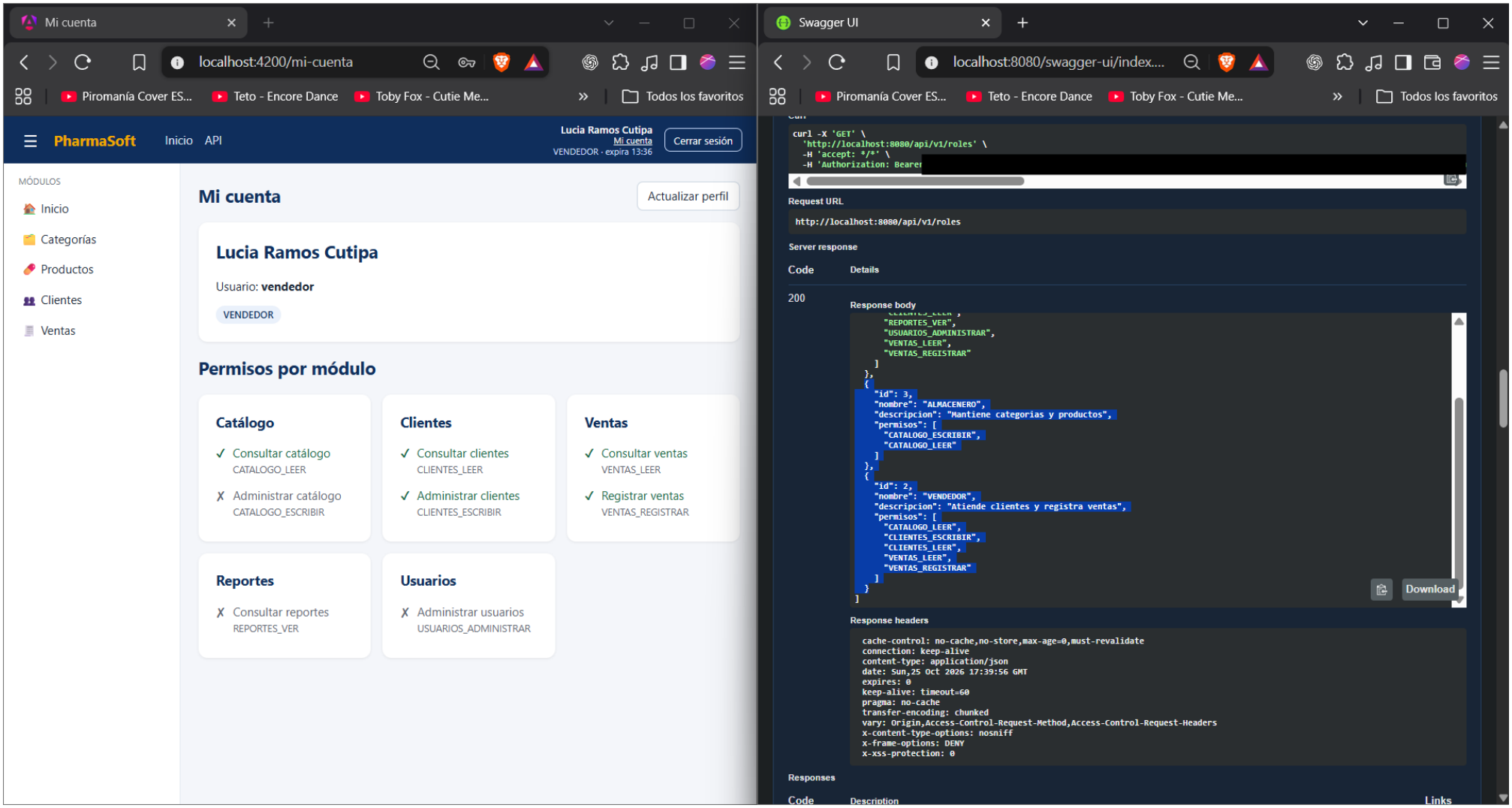
GET usuarios confirma vendedor con id 2 y su rol original VENDEDOR.



Menú, roles y cambios de permisos

E079 · M-03 · Identificación de roles

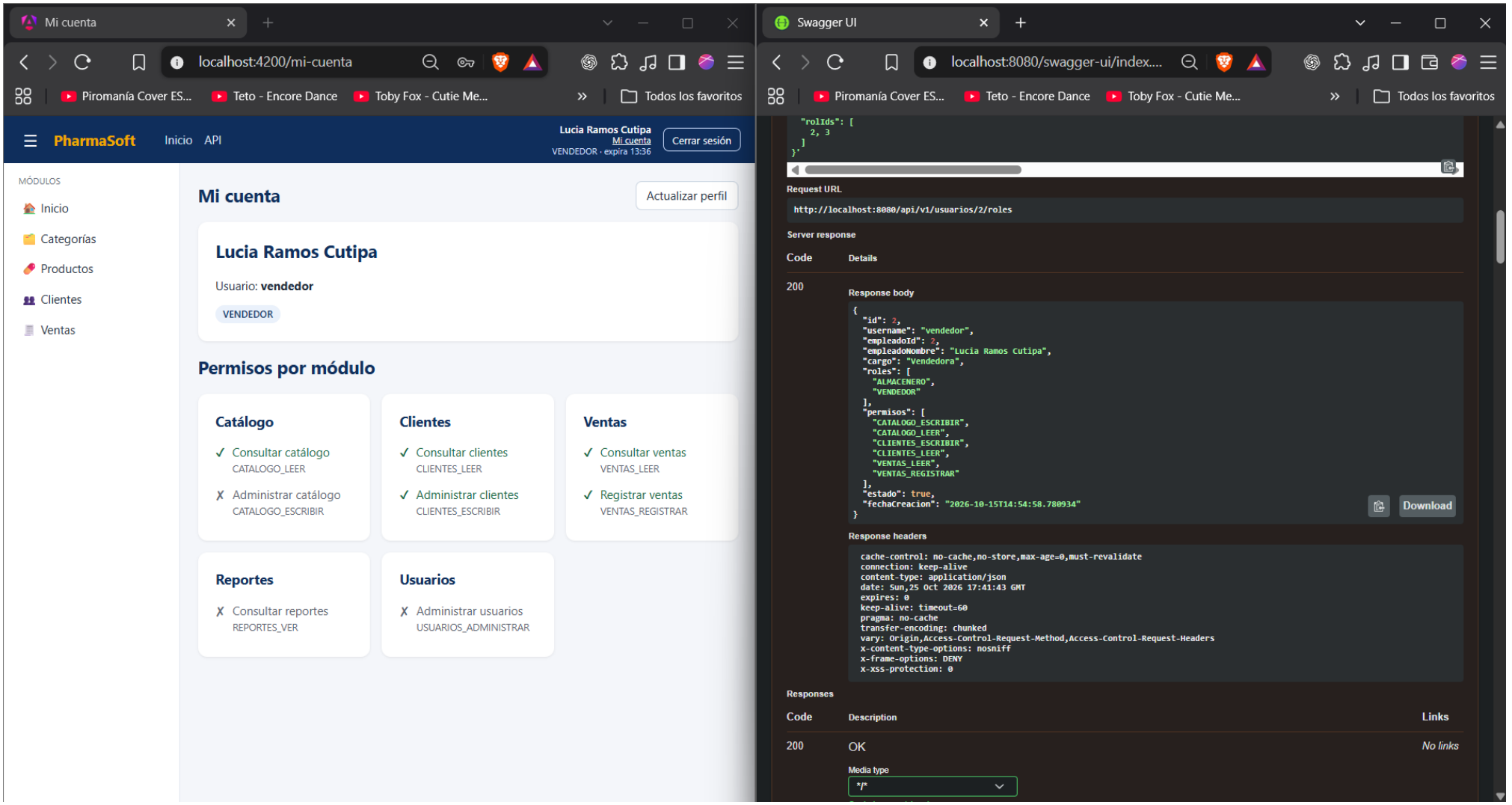
GET roles identifica VENDEDOR id 2 y ALMACENERO id 3.



Menú, roles y cambios de permisos

E080 · M-03 · Roles adicionales en el servidor

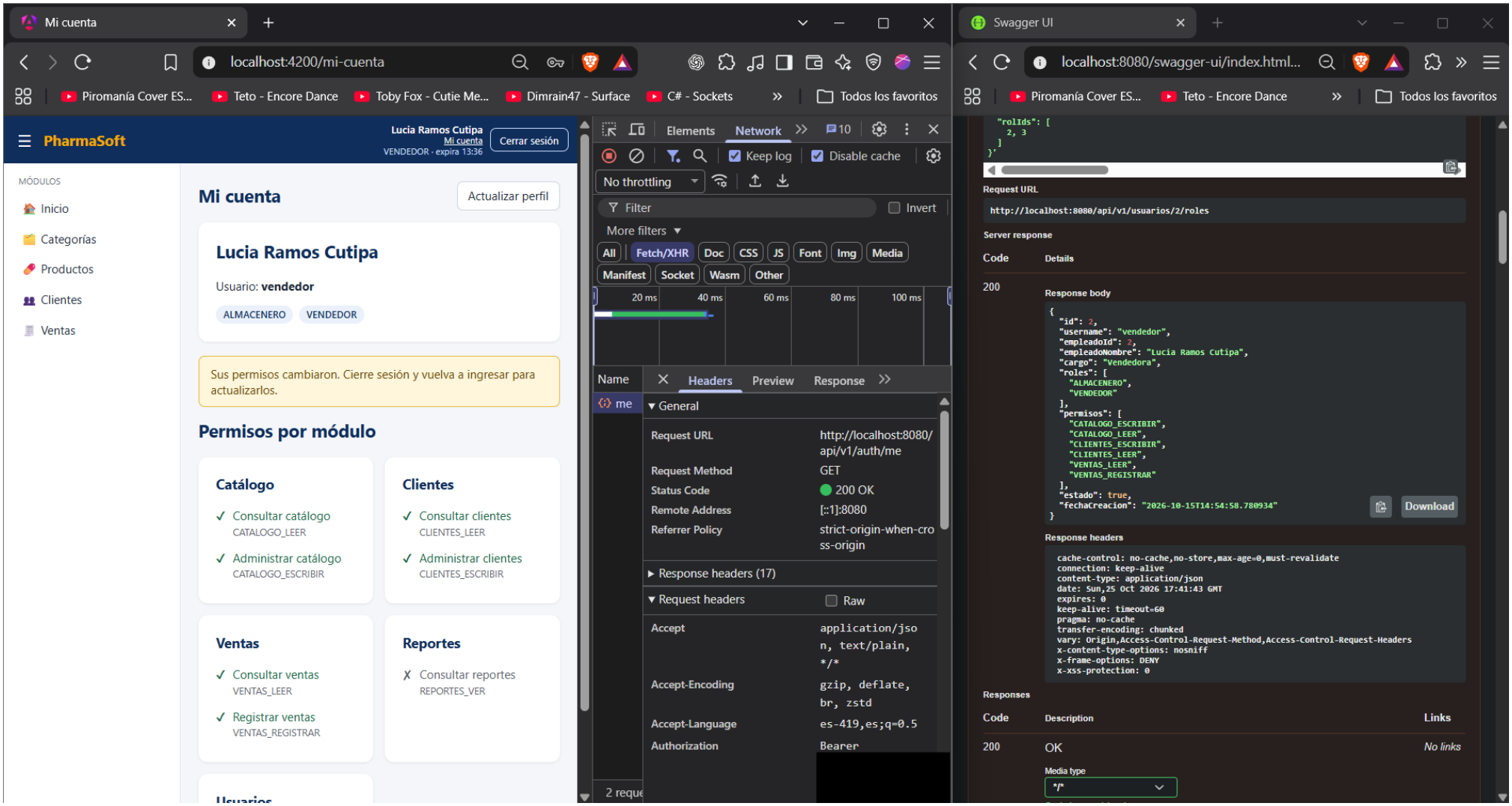
PUT usuarios/2/roles devuelve 200 con ambos roles; el perfil de la SPA todavía muestra su consulta anterior.



Menú, roles y cambios de permisos

E081 · M-03 · Diferencia de permisos detectada

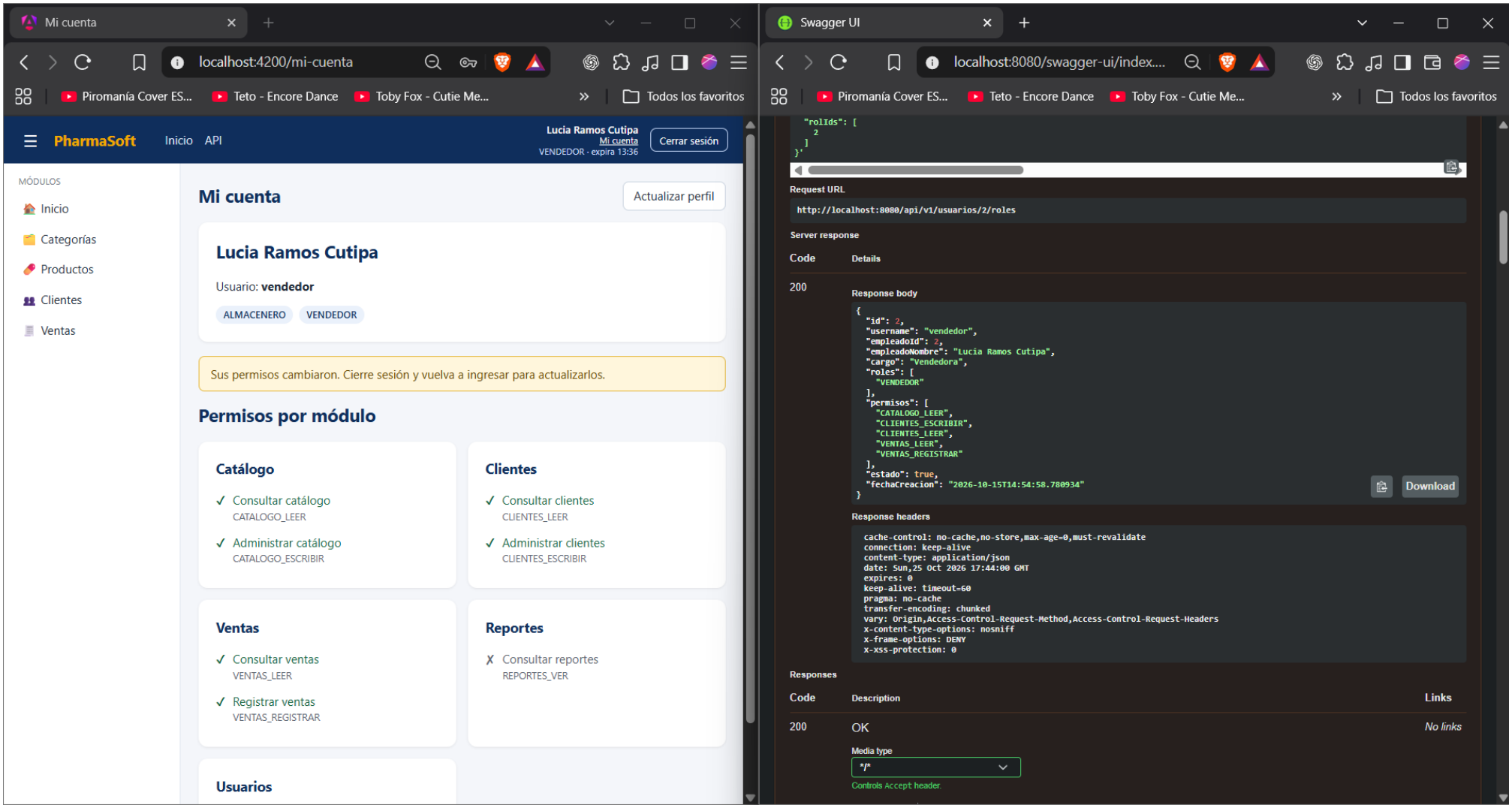
Actualizar perfil consulta auth/me con 200, muestra ambos roles y advierte que deben actualizarse mediante un nuevo ingreso; el encabezado conserva VENDEDOR.



Menú, roles y cambios de permisos

E082 · M-03 · Roles originales restaurados

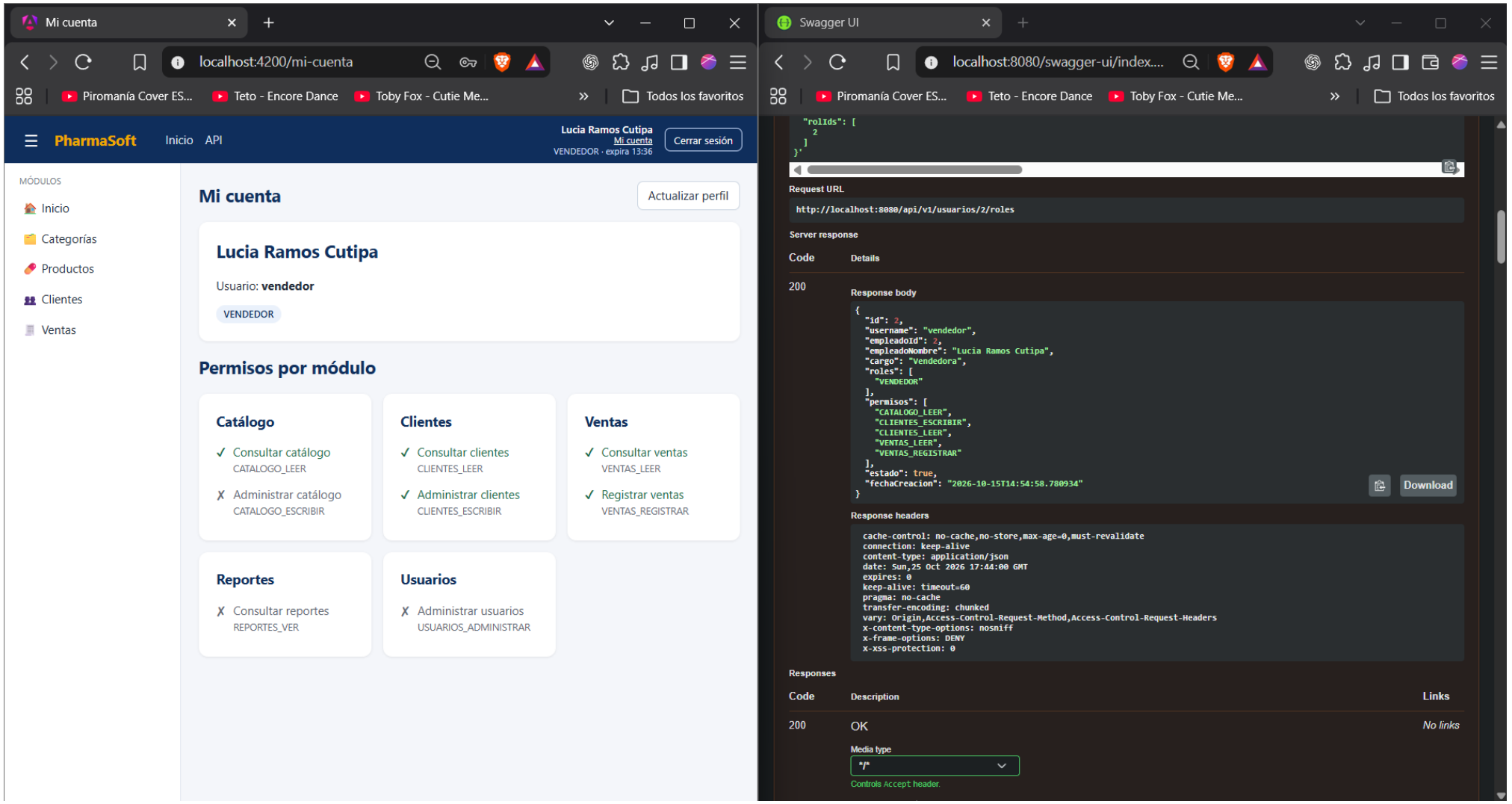
PUT usuarios/2/roles con [2] restaura VENDEDOR; el perfil aún conserva la respuesta previa hasta actualizar.



Menú, roles y cambios de permisos

E083 · M-03 · Perfil sincronizado con la restauración

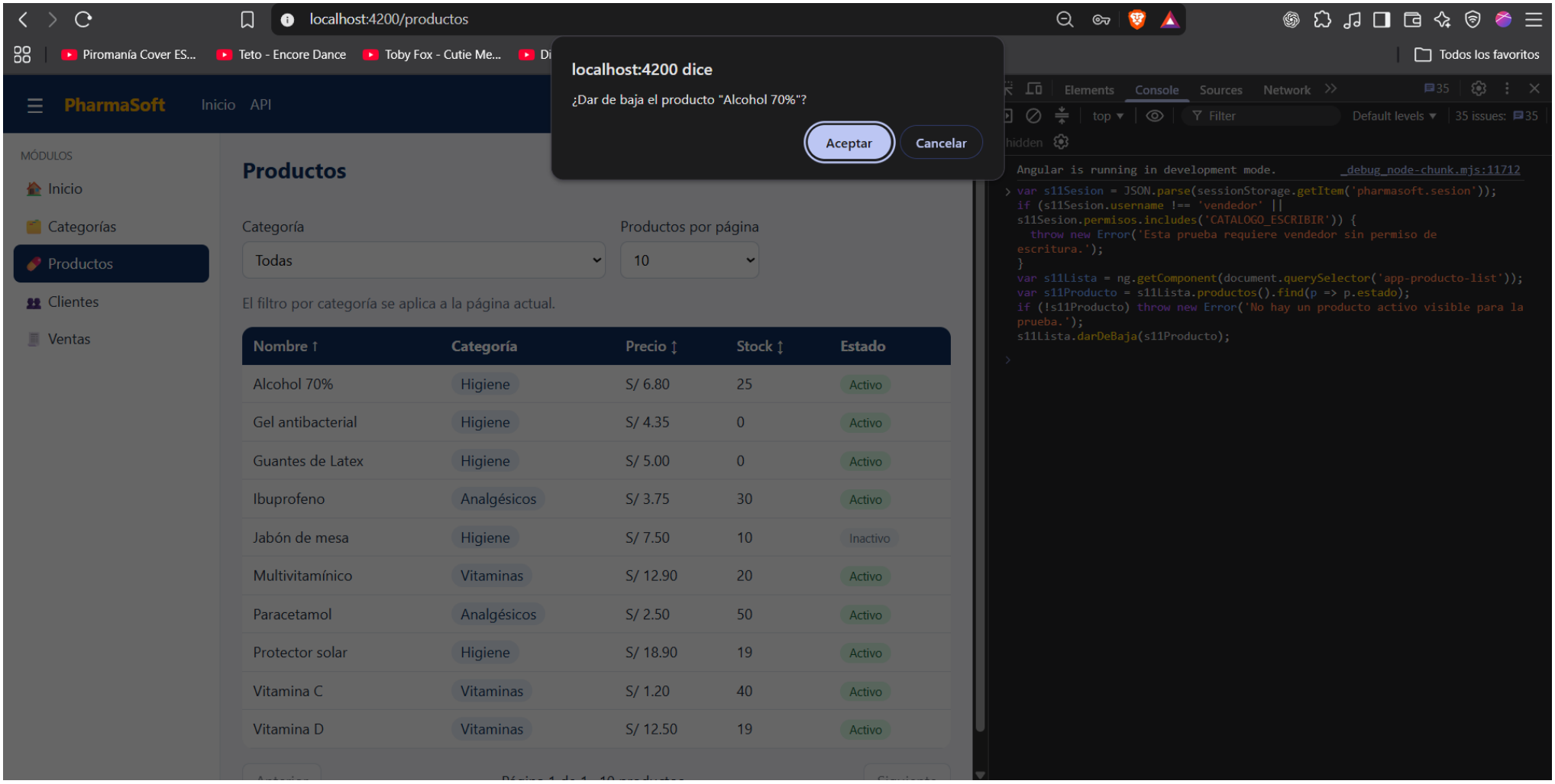
Después de actualizar, Mi cuenta vuelve a VENDEDOR y desaparece la advertencia de permisos cambiados.



Autorización HTTP y conservación de sesión

E059 · E-01 · Acción Angular forzada

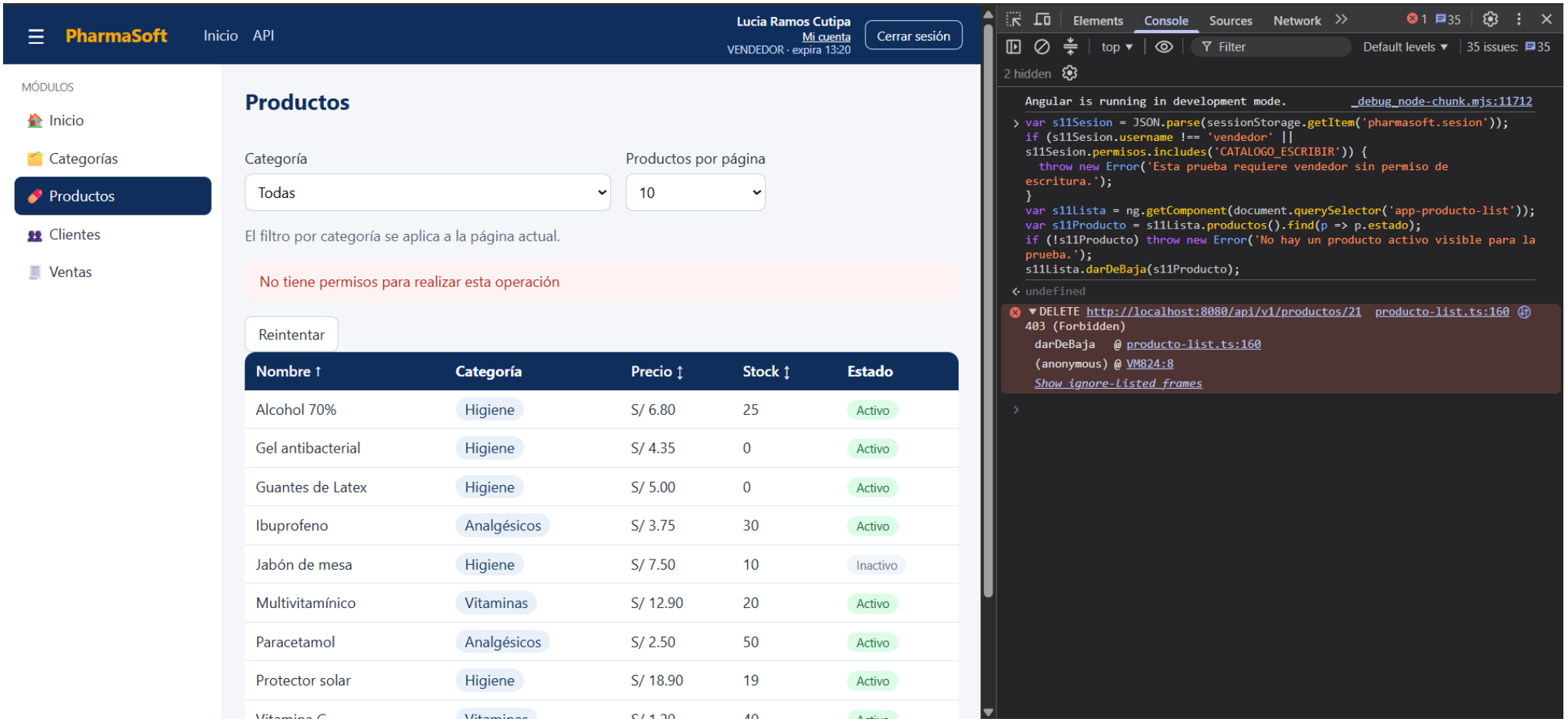
La consola invoca darDeBaja del componente y abre la confirmación sobre Alcohol 70%.



Autorización HTTP y conservación de sesión

E060 · E-01 · 403 comunicado en la SPA

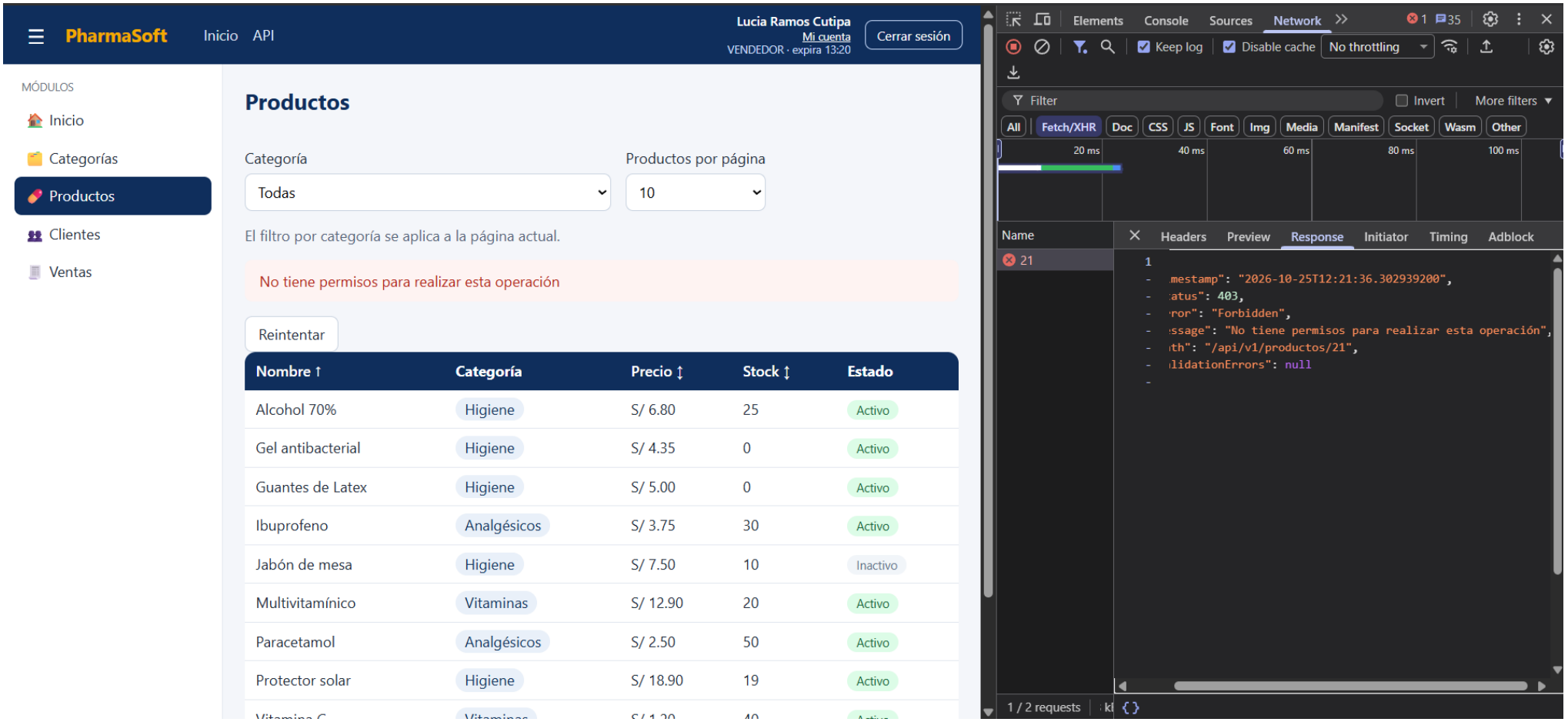
El componente muestra No tienes permisos para realizar esta operación; el usuario continúa autenticado.



Autorización HTTP y conservación de sesión

E061 · E-01 · Producto conservado y respuesta 403

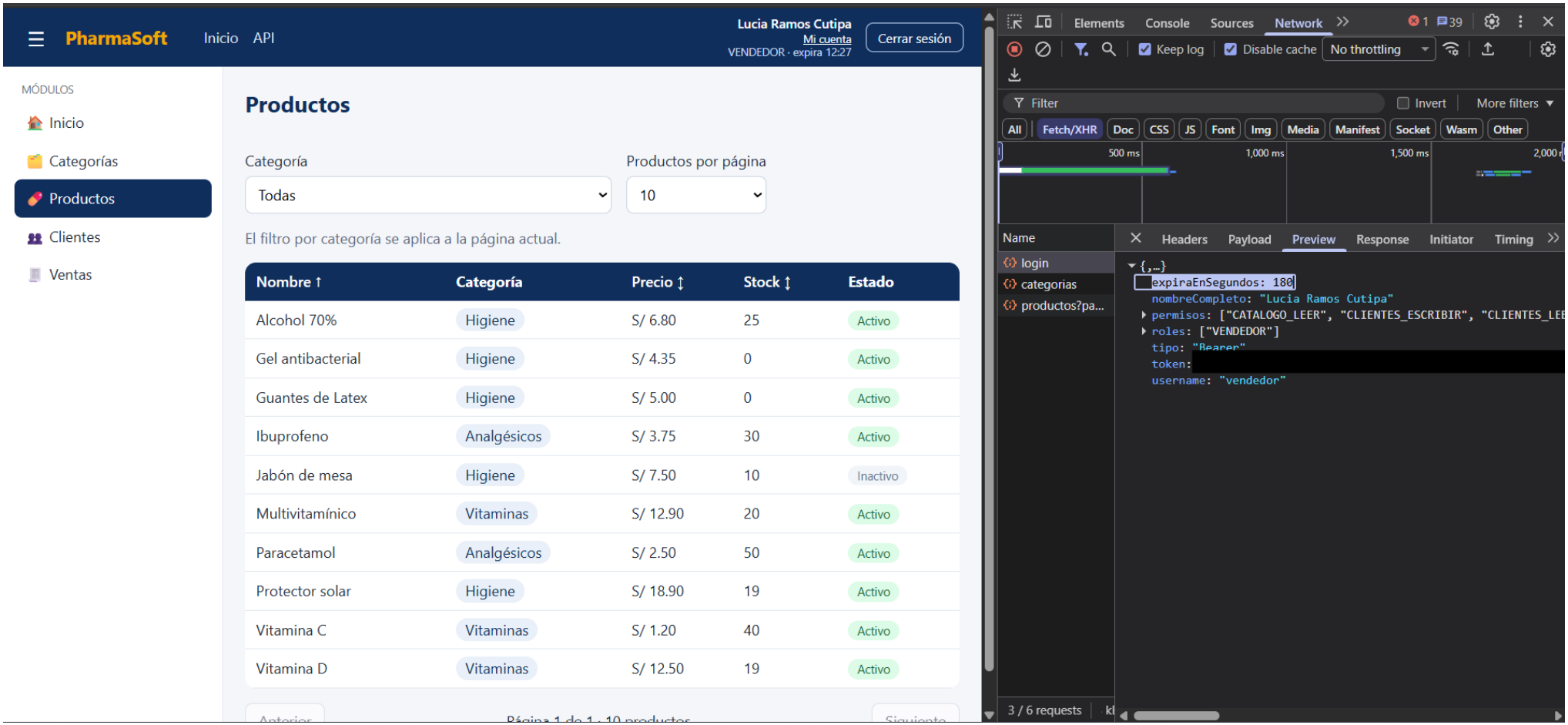
La respuesta identifica /api/v1/productos/21 y status 403; Alcohol 70% sigue Activo con stock 25.



Aviso previo y cierre de sesión

E062 · B-01 · Sesión de tres minutos

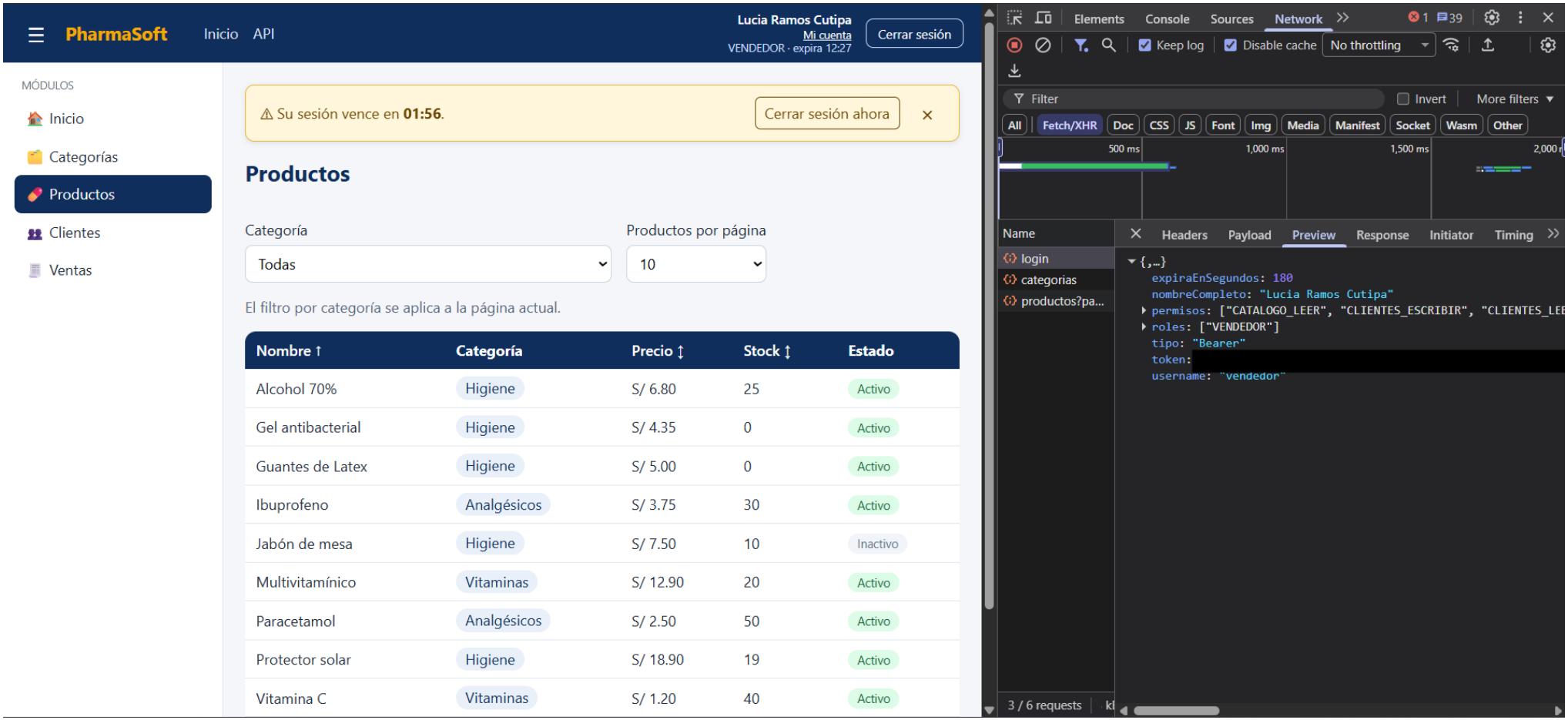
La respuesta de login indica expiraEnSegundos: 180 y todavía no se presenta el aviso.



Aviso previo y cierre de sesión

E063 · B-01 · Aviso previo visible

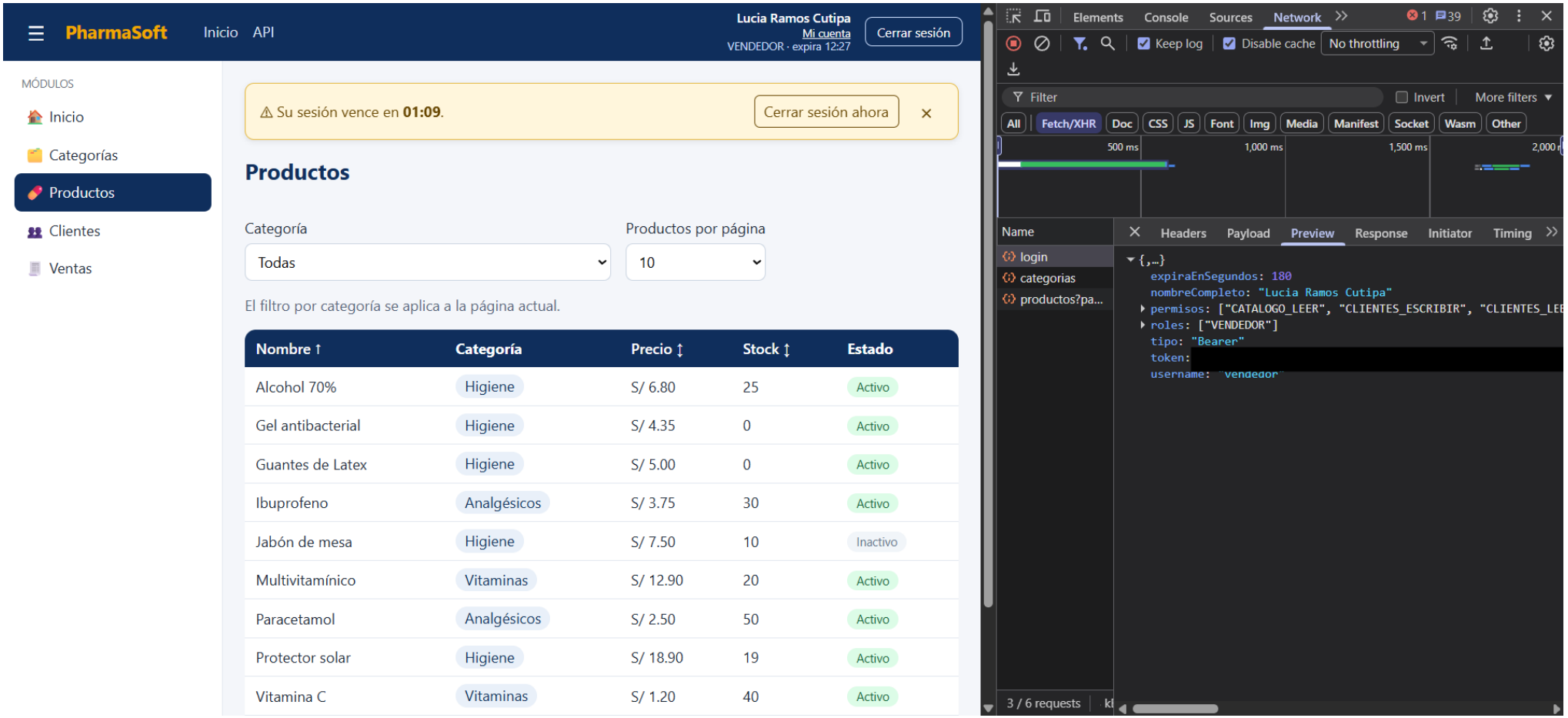
El aviso aparece sobre Productos cuando quedan menos de dos minutos; la captura muestra 01:56.



Aviso previo y cierre de sesión

E064 · B-02 · Cuenta regresiva en avance

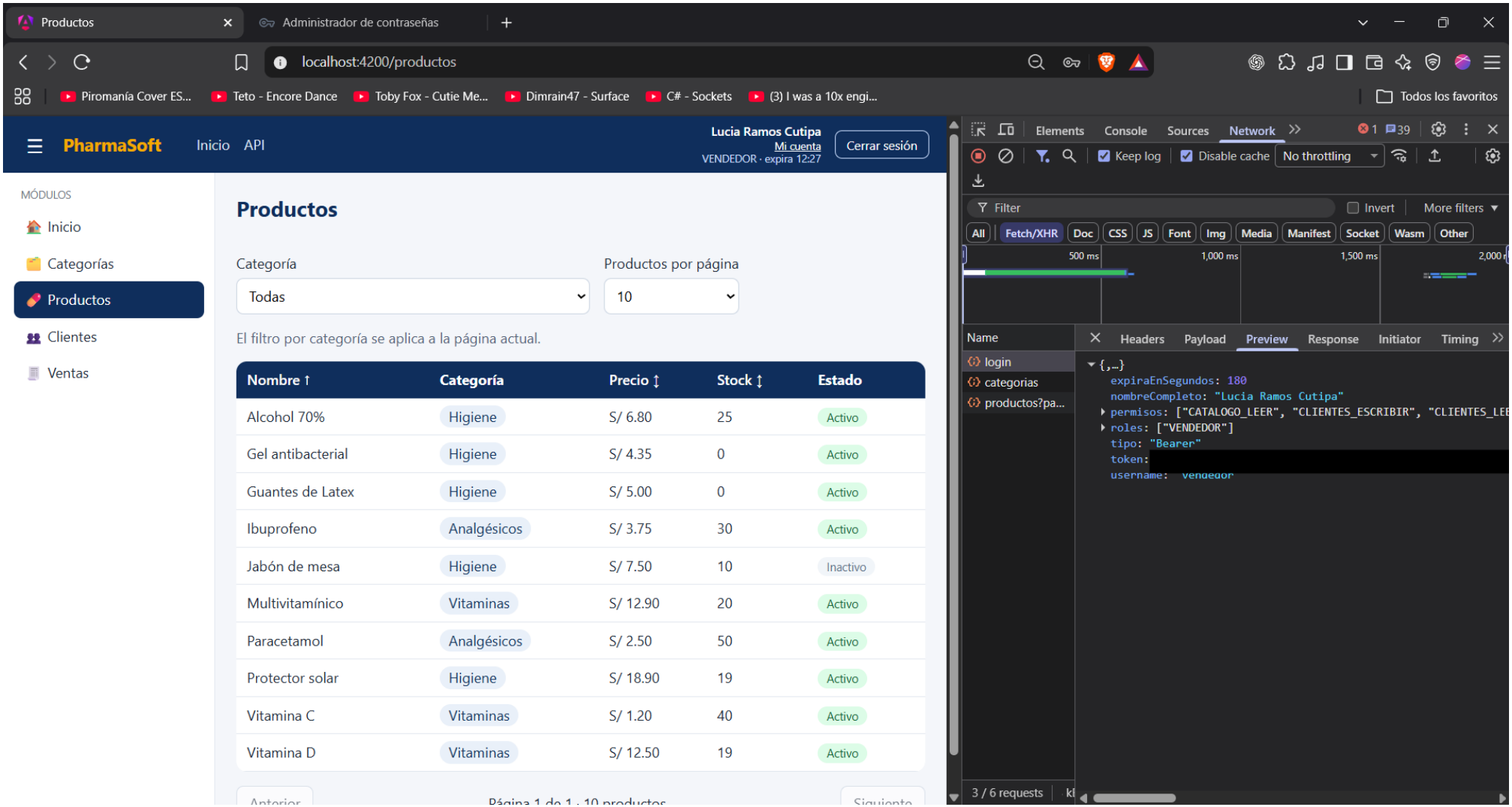
El mismo aviso muestra 01:09, manteniendo la duración de emisión de 180 segundos.



Aviso previo y cierre de sesión

E065 · B-03 · Aviso oculto

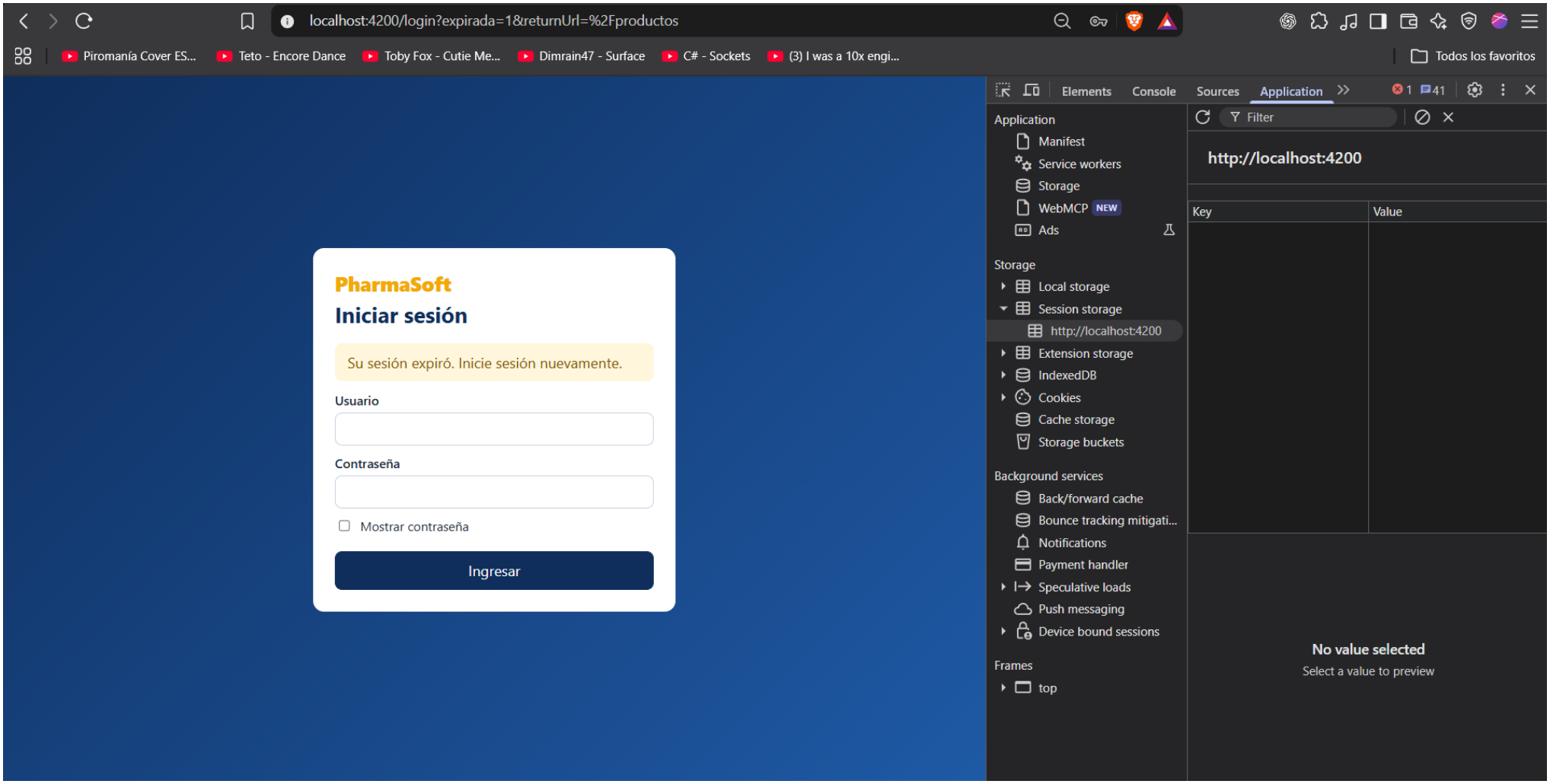
Después de pulsar × desaparece el aviso y Productos permanece disponible durante esa sesión.



Aviso previo y cierre de sesión

E066 · B-04 · Cierre automático al vencer

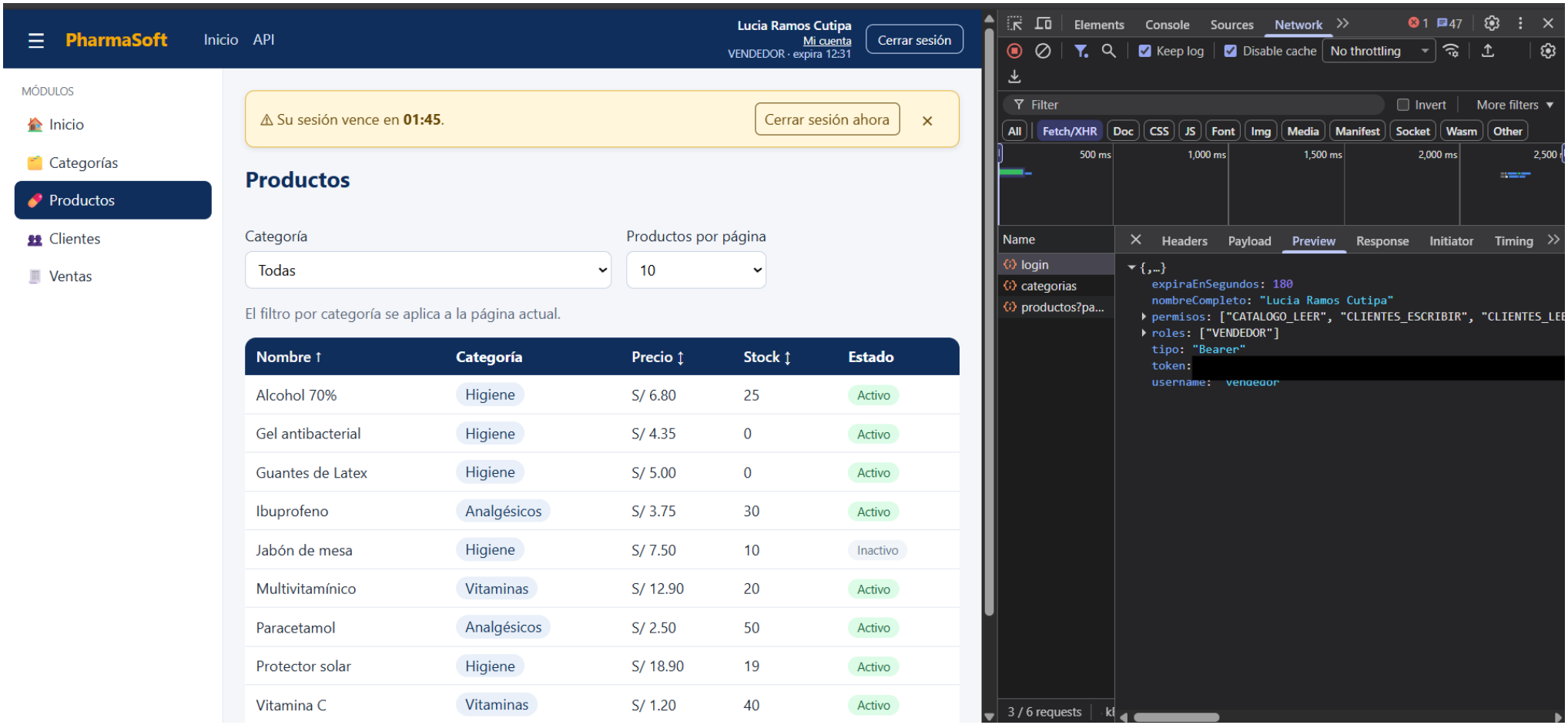
La aplicación presenta login con aviso de expiración y sessionStorage sin pharmasoft.sesion.



Aviso previo y cierre de sesión

E067 · B-04 · Aviso en una sesión nueva

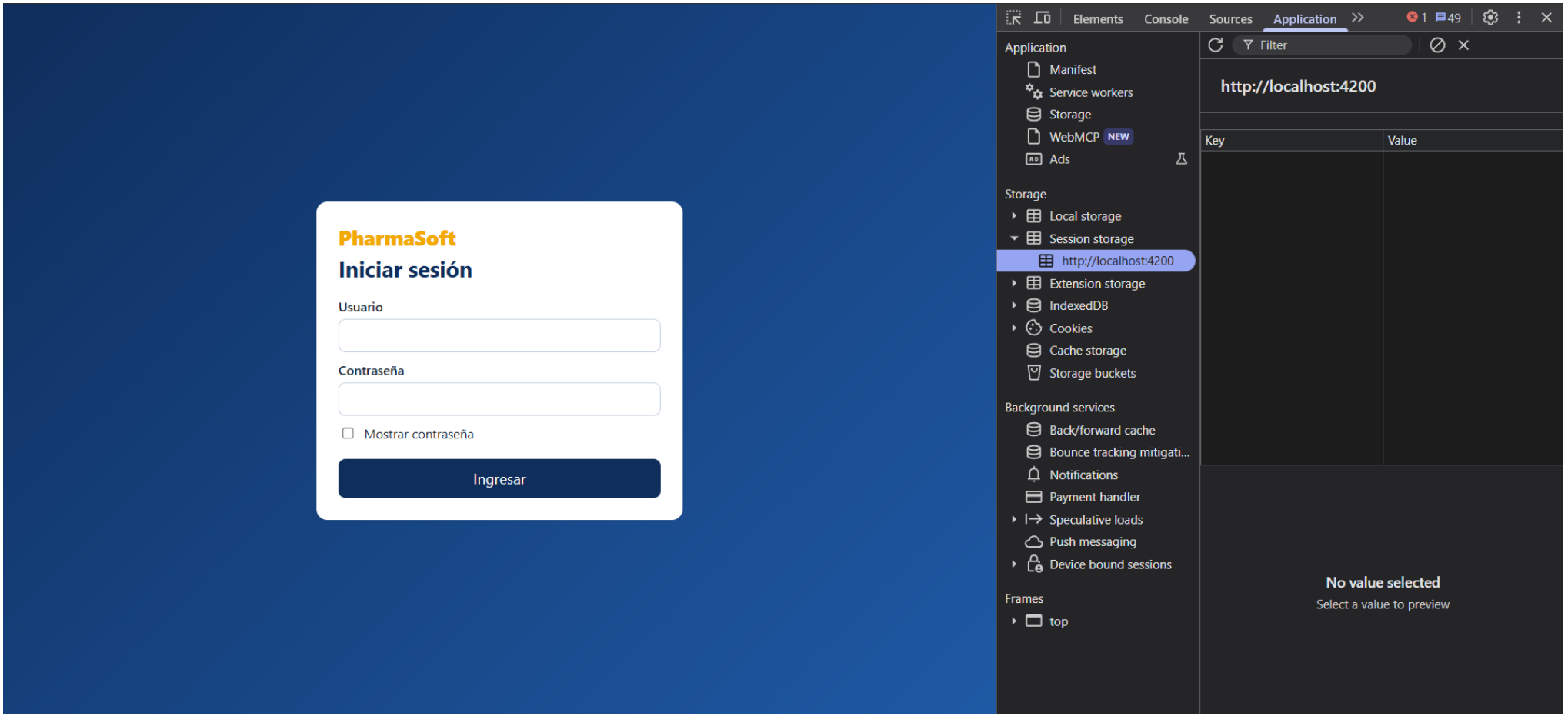
Un nuevo login vuelve a habilitar el aviso y muestra el botón Cerrar sesión ahora.



Aviso previo y cierre de sesión

E068 · B-04 · Cierre manual inmediato

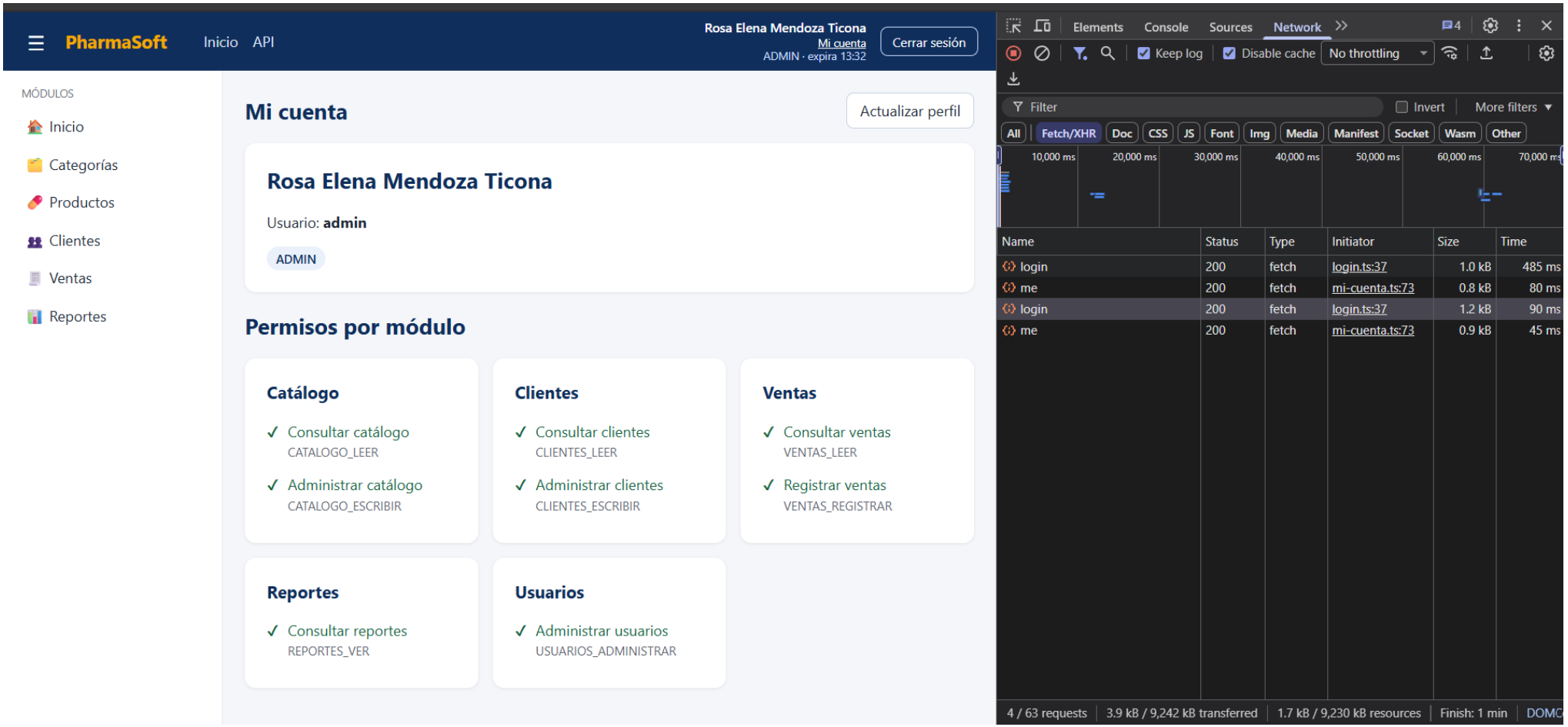
Después del cierre manual aparece login sin aviso de expiración y el almacenamiento de sesión queda vacío.



Perfil y permisos por módulo

E071 · C-01 · Perfil ADMIN

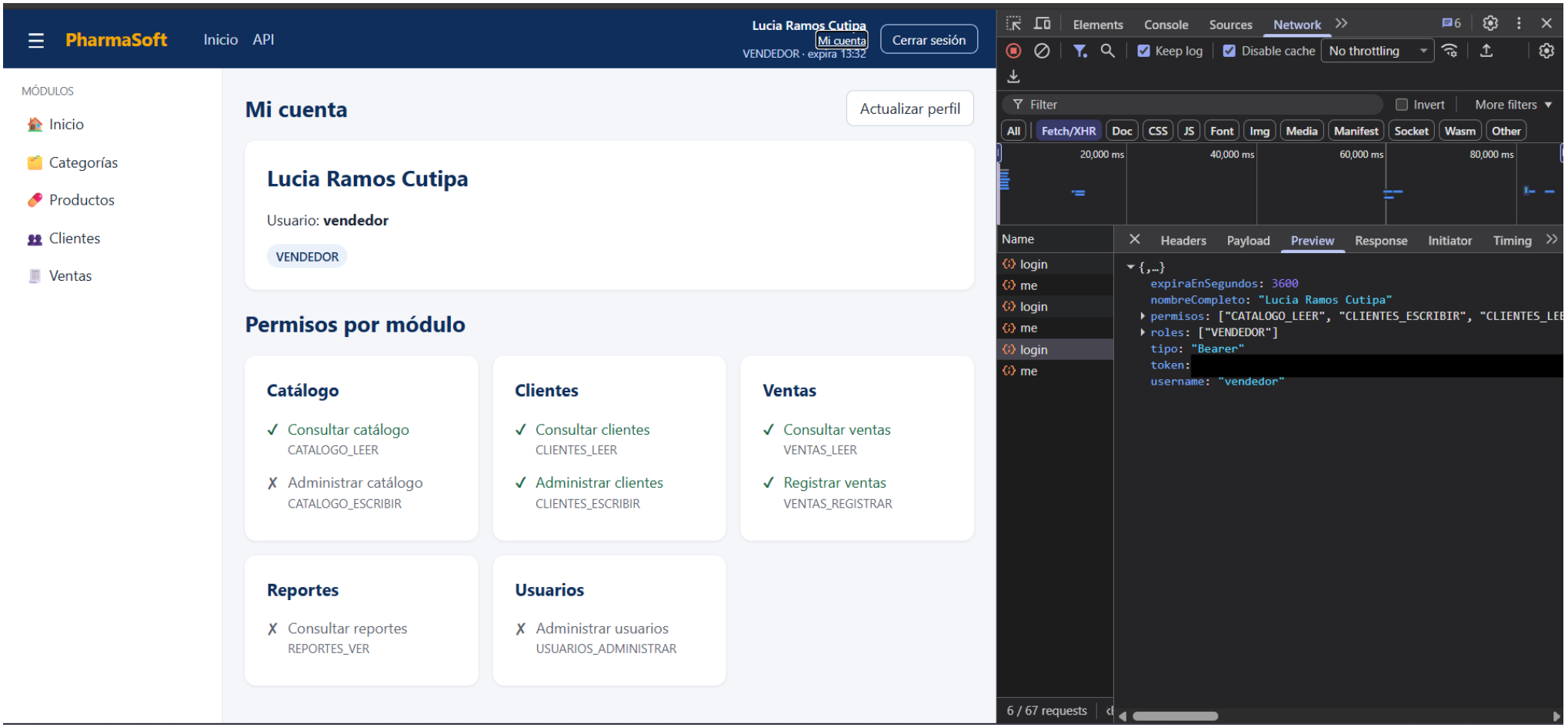
El perfil administrativo muestra nombre, usuario, rol y los ocho permisos concedidos en cinco módulos.



Perfil y permisos por módulo

E072 · C-01 · Perfil VENDEDOR

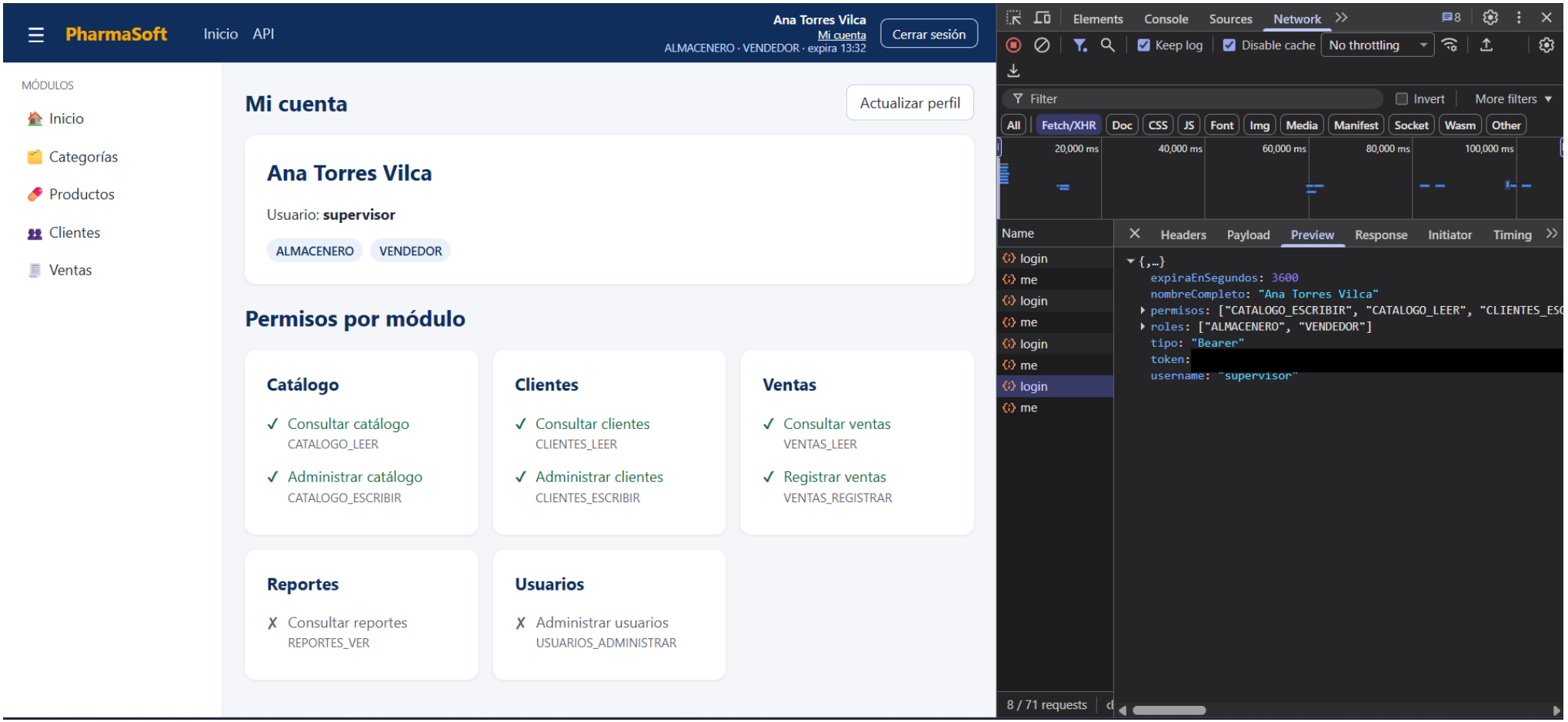
El perfil muestra permisos de lectura del catálogo, Clientes y Ventas; duración normal de 3600 segundos.



Perfil y permisos por módulo

E073 · C-01 · Perfil supervisor

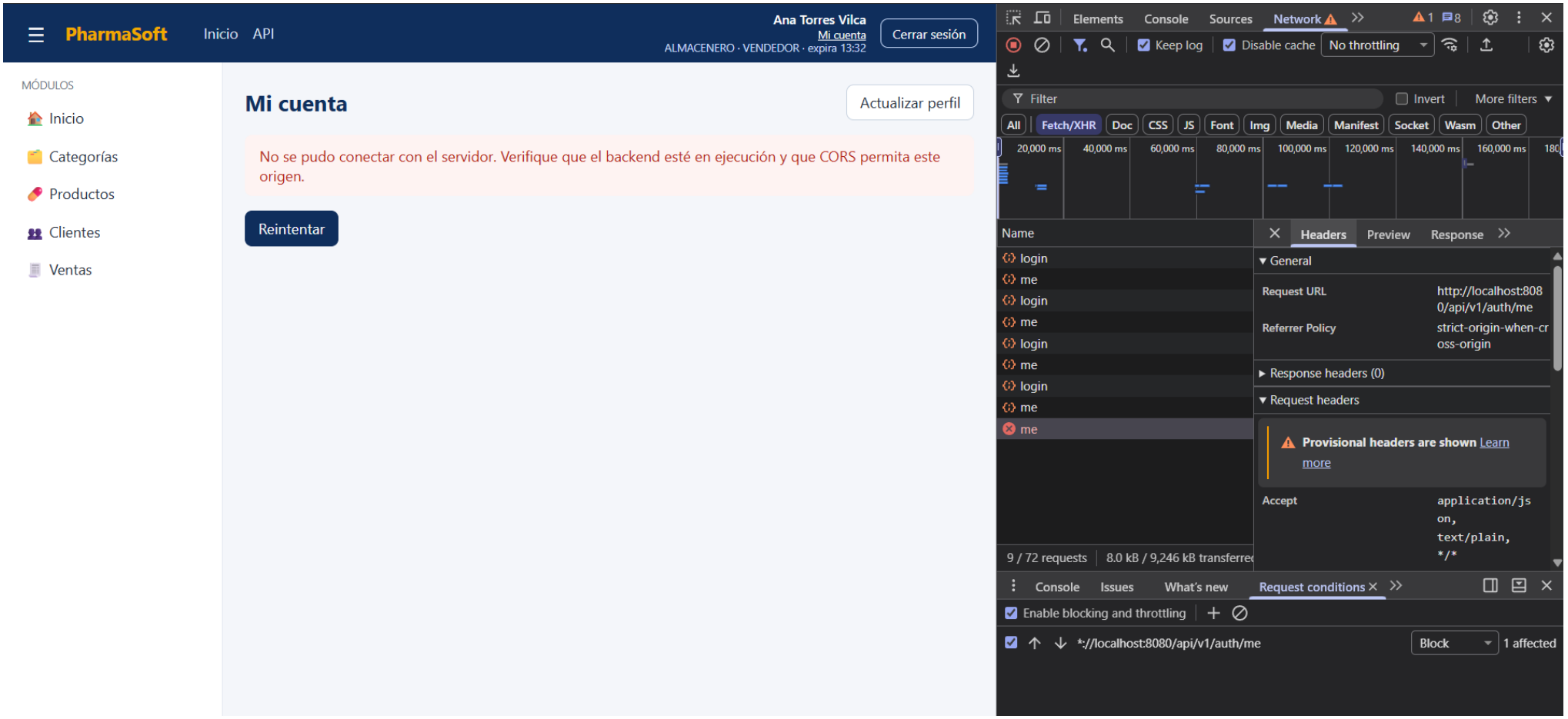
El perfil presenta ambos roles y la unión de permisos de Catálogo, Clientes y Ventas.



Perfil y permisos por módulo

E074 · C-02 · Error al consultar Mi cuenta

Al bloquear auth/me aparece un mensaje de conexión y Reintentar; se mantiene la sesión de supervisor.



Perfil y permisos por módulo

E075 · C-02 · Recuperación de Mi cuenta

Tras quitar el bloqueo, auth/me responde 200 y vuelven a mostrarse el perfil y sus permisos.

